

SECURITY INFRASTRUCTURE

보안 인프라 구축 가이드

티케팅 플랫폼 기반 AI 보안관제 · Splunk 연동

SK 실더스 루키즈 30기

팀명 : 야누스

작성자 : 송진우

작성일 : 2026.06.02 버전 : v1.0

목 차

1. 개요.....	1
1.1 문서 목적.....	1
1.2 프로젝트 범위 및 전제 조건.....	1
2. 전체 인프라 구성도.....	1
2.1 논리 구성도.....	1
2.2 네트워크 구성도.....	1
2.3 주요 구성 요소 및 데이터 흐름.....	1
3. 사전 준비 및 환경 구성.....	1
3.1 하드웨어 / 가상화 환경.....	1
3.2 OS 및 기본 패키지.....	1
3.3 계정 및 권한 체계.....	1
4. 가상 머신(VM) 구축.....	1
4.1 가상 네트워크(vSwitch) 구성.....	1
4.2 공통 VM 생성 절차.....	1
4.3 네트워크 장비.....	1
4.2.1 vyos-router (라우터).....	1
4.2.2 pfsense (방화벽).....	1
4.4 서비스 계층.....	1
4.3.1 Ticketing platform (WAS).....	1
4.3.2 oracle-db (DB 서버).....	1
4.5 보안 · 관제 계층.....	1
4.4.1 WAF (ModSecurity).....	1
4.4.2 security onion (IDS).....	1
4.4.3 splunk (SIEM).....	1
4.6 운영자 · 공격자 PC.....	1
4.5.1 SOC-mint (SOC팀 PC).....	1
4.5.2 DEV-mint (DEV팀 PC).....	1
4.5.3 kali_attacker (공격자 PC).....	1
5. 티켓팅 웹 서비스 구축.....	1
5.1 Web / WAS / DB 구성.....	1
5.2 서비스 배포 및 동작 확인.....	1
6. 네트워크 및 방화벽 보안.....	1
6.1 네트워크 분리 (세그멘테이션).....	1
6.2 방화벽 정책.....	1

6.3 IDS/IPS (pfSense Snort).....	1
6.4 콘텐츠 필터링 / 프록시 (pfSense SquidGuard).....	1
6.5 WAF 및 웹 보안.....	1
7. 로그 수집 및 전송 체계.....	1
7.1 수집 대상 로그.....	1
7.2 로그 전송 구조.....	1
8. Splunk 구축 및 연동.....	1
8.1 Splunk 설치 및 기본 구성.....	1
8.2 데이터 입력 (Index / Sourcetype).....	1
8.3 대시보드 구성.....	1
9. 보안 관제 시나리오 및 탐지 룰.....	1
9.1 주요 위협 시나리오.....	1
9.2 탐지 룰 (SPL) 정의.....	1
9.3 알림(Alert) 설정.....	1
10. AI 기반 이상 탐지 / 분석.....	1
10.1 AI 적용 영역.....	1
10.2 데이터 파이프라인.....	1
10.3 모델 연동 및 결과 활용.....	1
11. 대응 및 운영 프로세스.....	1
11.1 인시던트 대응 절차.....	1
11.2 운영 및 유지보수.....	1
12. 부록.....	1
12.1 용어 정리.....	1
12.2 참고 자료.....	1
12.3 변경 이력.....	1

1. 개요

1.1 문서 목적

해당 인프라 구축 가이드는 보안 관제 프로젝트 내에서, 가상의 인프라 구축을 통한 로그 수집 및 관제 룰 작성·검증의 전 과정을 체계적으로 정리한 문서이다. 단순한 시스템 설치 절차서에 그치지 않고, 티켓팅 플랫폼이라는 실제 서비스 환경을 가정하여 발생하는 로그를 수집하고, 이를 Splunk로 적재·분석하며, 위협 시나리오에 대응하는 관제 룰과 AI 기반 이상 탐지까지 이어지는 일련의 흐름을 담는 것을 목적으로 한다.

이를 통해 본 가이드는 다음을 달성하고자 한다.

- 가상 인프라(티켓팅 플랫폼) 구축부터 로그 수집·전송 체계 확립까지의 표준 절차 제공
- Splunk 연동 및 관제 룰(SPL) 작성·검증 과정의 재현 가능한 기준 마련
- AI 보안관제 적용 방향과 실제 구현 시 고려사항 정리

또한 본 문서는 프로젝트 종료 이후에도 동일한 환경을 재구성하거나, 새롭게 합류하는 팀원 및 외부 사용자가 전체 구축 과정을 이해하고 그대로 따라 할 수 있도록 작성되었다. 즉, 특정 인원의 경험이나 기억에 의존하지 않고 누구든 본 가이드를 참고하여 보안 관제 인프라를 구축·운영할 수 있도록 하는 것이 궁극적인 목적이다.

1.2 프로젝트 범위 및 전제 조건

본 가이드는 보안 관제 프로젝트의 인프라 구축 영역을 대상으로 하며, 가상의 티켓팅 플랫폼을 기준으로 로그 수집부터 Splunk 연동, 관제 룰 작성, AI 기반 이상 탐지까지의 과정을 다룬다. 실제 상용 서비스 운영이나 대규모 트래픽 부하 처리는 범위에 포함하지 않으며, 보안 관제 관점에서 필요한 최소한의 서비스 환경을 가상으로 구성하는 것을 전제로 한다.

적용 범위 (In Scope)

- 가상 티켓팅 플랫폼(Web / WAS / DB) 구축 및 서비스 동작 검증
- 네트워크 분리 및 방화벽·WAF 등 기본 보안 계층 구성
- 서비스·시스템·보안 장비 로그 수집 및 Splunk로의 전송 체계 구축
- Splunk 기반 로그 적재(Index/Sourcetype), 검색, 대시보드 구성
- 티켓팅 환경 위협 시나리오에 대한 관제 룰(SPL) 작성 및 탐지·알림 설정
- AI 기반 이상 탐지의 적용 방향 및 Splunk 연동 구조 설계

범위 외 (Out of Scope)

- 실제 결제·예매 트랜잭션 처리 및 상용 서비스 운영
- 대규모 부하 분산(로드밸런싱)·고가용성(HA) 구성 및 성능 튜닝
- 물리 보안, 망 분리 인증 등 규제·인증 대응 영역
- 운영 단계의 24시간 상시 관제 인력 운영 체계

전제 조건 (Prerequisites)

- 인프라는 가상화(VM) 또는 클라우드 환경에서 구성하는 것을 기준으로 한다.
- 각 구성 요소는 상호 네트워크 통신이 가능한 단일 관제 환경 내에 위치하는 것으로 가정한다.
- 로그 수집은 Splunk Universal Forwarder 등 에이전트 기반 전송 방식을 기본 전제로 한다.
- 사용되는 솔루션(OS, Splunk 등)은 평가판 또는 무료 라이선스 범위 내에서 구성 가능한 것으로 한다.
- 본 가이드의 명령어·설정 값은 문서에 명시된 버전을 기준으로 하며, 버전 차이에 따른 조정이 필요할 수 있다.

2. 전체 인프라 구성도

2.1 논리 구성도

[구성도 삽입] 서비스 영역 / 보안 영역 / 관제(Splunk·AI) 영역의 논리적 관계.

2.2 네트워크 구성도

[구성도 삽입] 네트워크 구간(DMZ/내부망/관리망), 주요 장비, IP 대역.

2.3 주요 구성 요소 및 데이터 흐름

- 웹/티케팅 서비스 계층
- 보안 계층 (방화벽 / WAF / IDS·IPS 등)
- 로그 수집·전송 계층 (Forwarder 등)
- 분석·관제 계층 (Splunk, AI 이상탐지)

3. 사전 준비 및 환경 구성

3.1 하드웨어 / 가상화 환경

본 프로젝트의 인프라는 단일 물리 PC 상에 가상화 환경을 구성하여 구축한다. 가상화 솔루션으로는 VMware Workstation 및 ESXi를 사용하며, 모든 구성 요소를 가상 머신(VM) 단위로 분리하여 서비스·보안·관제 영역이 독립적으로 동작하도록 한다.

호스트(물리 PC) 사양

구분 사양

CPU AMD Ryzen 7 2700 (8-Core / 16-Thread)

메모리 64 GB

저장장치 SSD 500 GB + HDD 1.8 TB

운영체제 Windows 10 Home

리소스 산정 및 고려사항

- 전체 VM에 할당된 메모리는 약 24.5 GB로, 호스트 메모리(64 GB) 대비 충분한 여유를 확보하여 모든 VM의 동시 구동에 무리가 없다.
- vCPU 총합은 23개로 물리 스레드(16) 대비 초과 할당(over-subscription)되어 있으나, 모든 VM이 동시에 최대 부하로 동작하지 않는 관제 실습 환경 특성상 정상적으로 운용 가능하다.
- 전체 디스크 사용량은 약 670 GB로 SSD(500 GB) 단독으로는 수용이 어려워, SSD와 HDD를 함께 활용한다. 디스크 I/O가 빈번한 splunk-security onion은 가능한 SSD에 배치하고, 부하가 적은 PC-라우터 계열은 HDD에 배치하는 것을 권장한다.
- security onion(IDS)과 splunk(SIEM)는 로그-패킷을 지속 적재하므로 디스크를 각각 200 GB, 100 GB로 크게 산정하였으며, 보관 기간과 수집 로그량에 따라 추가 확장이 필요할 수 있다.

가상 머신(VM) 구성

총 10대의 VM으로 구성하며, 서비스 계층(WAS·DB), 보안 계층(방화벽·WAF·IDS), 관제 계층(SIEM), 운영자·공격자 PC를 각각 분리하여 배치한다.

VM 명	역할	OS	vCPU	Memory(GB)	Disk(GB)
vyos-router	라우터	Debian GNU/Linux 6	1	0.5	10

VM 명	역할	OS (64bit)	vCPU	Memory(GB)	Disk(GB)
pfsense	방화벽	FreeBSD 11 (64bit)	2	2	48
WAF	웹 방화벽 (ModSecurity)	Ubuntu 20.04 LTS (64bit)	4	4	100
security onion	IDS	Ubuntu Linux (64bit)	2	4	200
splunk	SIEM	Ubuntu 20.04 LTS (64bit)	4	4	100
Ticketing platform	WAS	Ubuntu 20.04 LTS (64bit)	4	4	100
oracle-db	DB 서버	Oracle Linux 8 (64bit)	2	4	50
SOC-mint	SOC팀 PC	Linux Mint 22.3 (64bit)	1	2	16
DEV-mint	DEV팀 PC	Linux Mint 22.3 (64bit)	1	2	16
kali_attacker	공격자 PC	Debian GNU/Linux 10 (64bit)	4	2	80

리소스 산정 및 고려사항

- 전체 VM에 할당된 메모리는 약 28.5 GB로, 호스트 메모리(64 GB) 대비 충분한 여유를 확보하여 모든 VM의 동시 구동에 무리가 없다.
- vCPU 총합은 25개로 물리 스레드(16) 대비 초과 할당(over-subscription)되어 있으나, 모든 VM이 동시에 최대 부하로 동작하지 않는 관제 실습 환경 특성상 정상적으로 운용 가능하다.
- 전체 디스크 사용량은 약 720 GB로 SSD(500 GB) 단독으로는 수용이 어려워, SSD와 HDD를 함께 활용한다. 디스크 I/O가 빈번한 splunk·security onion·oracle-db는 가능한 SSD에 배치하고, 부하가 적은 PC·라우터 계열은 HDD에 배치하는 것을 권장한다.
- security onion(IDS)과 splunk(SIEM)는 로그·패킷을 지속 적재하므로 디스크를 각각 200 GB, 100 GB로 크게 산정하였으며, 보관 기간과 수집 로그량에 따라 추가 확장이 필요할 수 있다.
- DB 서버(oracle-db)는 WAS와 분리하여 별도 VM으로 구성함으로써 서비스 계층과 데이터 계층을 독립적으로 운영한다.

3.2 OS 및 기본 패키지

각 가상 머신은 역할에 맞는 운영체제를 설치한 후, 공통 초기 설정과 역할별 패키지 구성을 거쳐 서비스에 투입한다. 서비스·관제 서버는 안정성과 장기 지원이 보장되는 LTS 계열 리눅스를 기준으로 하며, 방화벽·라우터·IDS는 해당 기능에 특화된 전용 배포판을 사용한다.

OS 버전 정리

VM 명	역할	OS / 버전
Ticketing platform	WAS	Ubuntu 20.04 LTS Server
oracle-db	DB 서버	Oracle Linux 8 (64bit)
WAF	웹 방화벽	Ubuntu 20.04 LTS Server
splunk	SIEM	Ubuntu 20.04 LTS Server
SOC-mint	SOC팀 PC	Linux Mint 22.3 (Xfce, 64bit)
DEV-mint	DEV팀 PC	Linux Mint 22.3 (Xfce, 64bit)
vyos-router	라우터	VyOS 3.13.11
pfsense	방화벽	pfSense CE 2.7.2-RELEASE
security onion	IDS	Security Onion 16.04.6.6
kali_attacker	공격자 PC	Kali Linux 2025.2

공통 초기 설정

리눅스 서버 및 운영자 PC에는 다음 공통 설정을 동일하게 적용한다.

- 패키지 저장소 업데이트 및 최신화 (Ubuntu/Mint 계열은 apt, Oracle Linux는 dnf/yum 사용)
- 시간대(Asia/Seoul) 및 NTP 동기화 설정
- 고정 IP 및 네트워크 인터페이스 설정 (상세 구성은 5장 참조)

여기서 시간 동기화(NTP)는 단순 편의 설정이 아니라 관제의 전제 조건이다. 각 VM의 시각이 일치하지 않으면 Splunk에서 여러 장비의 로그를 시간 순으로 연계 분석할 때 이벤트 선후 관계가 어긋나므로, 모든 VM이 동일한 시간 기준을 갖도록 반드시 통일한다.

역할별 주요 패키지 / 구성요소

VM 명	주요 패키지 / 소프트웨어	버전	설치 방식
Ticketing platform	WAS 서비스 스택 (Java/Spring 계열, ojdbc8 드라이버)	ojdbc8 21.5.0.0	패키지 설치
oracle-db	Oracle Database 21c Express Edition (XE)	21.3.0.0.0 (XE)	패키지 설치
WAF	Nginx + ModSecurity-nginx, libmodsecurity3, OWASP CRS	connector v1.0.4 / lib v3.0.15	패키지 설치
splunk	Splunk Enterprise	10.4.0	패키지 설치
splunk / 로그 발생 서버	Splunk Universal Forwarder	10.4.0	패키지 설치
security onion	Suricata, Zeek 등 (배포판 내장)	—	
pfsense	방화벽 엔진 (배포판 내장)	—	
vyos-router	라우팅 데몬 (배포판 내장)	—	
SOC-mint / DEV-mint	웹 브라우저, Splunk 웹 접속 도구 등	—	
kali_attacker	nmap, hydra, sqlmap 등 공격 도구 (배포판 내장)	—	

WAF (ModSecurity) 구성

WAF는 Nginx 환경에서 ModSecurity를 연동하여 구성한다. Nginx 연동 모듈인 ModSecurity-nginx connector(v1.0.4)와 탐지 엔진인 libmodsecurity3(v3.0.15)를 함께 설치하며, 웹 공격 탐지 룰셋으로 OWASP Core Rule Set(CRS)을 적용한다. 룰셋의 세부 적용 및 차단 정책은 5장에서 다룬다.

Splunk 구성

로그 적재·분석을 담당하는 splunk 서버에는 Splunk Enterprise 10.4.0을 설치하고, 로그가 발생하는 서버(Ticketing platform, WAF 등)에는 동일 버전(10.4.0)의 Splunk Universal Forwarder를 설치하여 로그를 전송한다. Enterprise와 Forwarder의 버전을 동일하게 맞추는 것을 권장하며, 구체적인 전송 설정은 6장에서 다룬다.

Oracle Database 구성

티케팅 서비스의 데이터 저장소로 Oracle Database 21c Express Edition(XE)을 별도의 DB 전용 서버(oracle-db, Oracle Linux 8)에 설치하여 운영한다. WAS(Ticketing platform)와 DB 서버를 분리함으로써 서비스 계층과 데이터 계층을 독립적으로 구성하였으며, 애플리케이션은 ojdbc8(21.5.0.0) 드라이버를 통해 DB 서버의 PDB(XEPDB1)에 네트워크로 접속한다.

항목	값
설치 위치	oracle-db VM (Oracle Linux 8, 64bit)
에디션	Oracle Database 21c Express Edition (XE)
Release	21.0.0.0.0 Production
세부 버전	21.3.0.0.0
인스턴스(SID)	XE
PDB	XEPDB1
JDBC 드라이버	ojdbc8 21.5.0.0 (pom.xml)

WAS는 별도 VM에서 동작하므로, 애플리케이션의 DB 접속 설정에는 localhost가 아니라 oracle-db VM의 고정 IP(또는 호스트명)가 사용된다. 구체적인 IP 및 접속 경로는 5장(네트워크)에서 함께 정리한다.

전용 배포판과 패키지 설치 방식 구분

vyos-router, pfSense, Security Onion, Kali는 패키지를 개별 설치하는 방식이 아니라, 해당 기능이 통합된 전용 배포판(이미지)을 그대로 설치하여 사용한다. 반면 Ubuntu·Oracle Linux 기반의 서비스·관제 서버는 기본 OS 설치 후 필요한 패키지를 추가로 설치하여 역할을 구성한다.

3.3 계정 및 권한 체계

3.3 계정 및 권한 체계

본 인프라는 최소 권한 원칙(Least Privilege)에 따라 VM별로 운영 계정과 관리 계정을 분리하여 운영한다. 각 VM에는 서비스 전용 계정과 관리 목적의 `sudo` 계정을 별도로 두며, 원격 접속은 공개키 기반 SSH 인증을 권고한다. 공통 비밀번호는 초기 구축 단계에서 `rhkswp1234`로 통일하되, 운영 단계에서는 키 인증 전환 및 강제 변경을 전제로 한다.

3.3.1 VM별 운영 계정 표

VM	호스트네임	시스템 관리 계정	서비스 운영 계정	sudo 권한	비고
<i>vyos-router</i>	<i>vyos</i>	<code>`vyos`</code>	-	<code>`vyos`</code> (operator/admin)	VyOS 전용 계정 체계
<i>pfsense</i>	<i>pfsense</i>	<code>`root`</code>	<code>`admin`</code> (webGUI)	<code>`root`</code>	webGUI 별도 인증
<i>kali_attacker</i>	<i>kali</i>	<code>`kali`</code>	-	wheel: <code>`kali`</code>	공격 시나리오 용
WAF	<i>waf</i>	<code>`souser`</code>	<code>`nginx`</code> (서비스 데몬)	wheel: <code>`souser`</code>	nginx + ModSecurity
<i>Ticketing platform</i>	<i>was</i>	<code>`souser`</code>	<code>`was`</code>	wheel: <code>`souser`</code>	Tomcat 9 구동 전용 <code>`was`</code>
<i>oracle-db</i>	<i>oradb</i>	<code>`souser`</code>	<code>`oracle`</code>	wheel: <code>`souser`</code>	Oracle XE 21c 설치 사용자
<i>splunk</i>	<i>splunk</i>	<code>`souser`</code>	<code>`splunk`</code>	wheel: <code>`souser`</code>	Splunk Enterprise 데몬
<i>security onion</i>	<i>so</i>	<code>`souser`</code>	<code>`so-user`</code> (자동 생성)	wheel: <code>`souser`</code>	Security Onion 표준 계

					정
<i>SOC-mint</i>	<i>soc-mint</i>	<i>'soc'</i>	-	<i>wheel: 'soc'</i>	관제팀 PC
<i>DEV-mint</i>	<i>dev-mint</i>	<i>'dev'</i>	-	<i>wheel: 'dev'</i>	개발팀 PC

모든 리눅스 계열 VM에서 관리 계정은 *wheel* 또는 *sudo* 그룹에 소속시키며, *root* 직접 로그인은 */etc/ssh/sshd_config*에서 *PermitRootLogin no*로 차단한다. 서비스 운영 계정(*was*, *oracle*, *splunk* 등)은 셸 로그인을 최소화하고 데몬 실행 전용으로만 사용한다.

3.3.2 Oracle DB 계정 분리

Oracle 환경에서는 데이터베이스 인스턴스 관리 권한과 애플리케이션 권한을 명확히 분리하여 운영한다. *SYS/SYSTEM* 계정은 DBA 작업에만 사용하며, 애플리케이션은 전용 스키마 계정을 통해서만 PDB에 접근한다.

계정	접속 대상	권한 범위	용도
<i>'SYS'</i>	<i>CDB (XE)</i>	<i>'SYSDBA'</i>	인스턴스 시작·정지, 백업/복구
<i>'SYSTEM'</i>	<i>CDB (XE)</i>	<i>'DBA'</i>	<i>CDB</i> 레벨 관리, 모니터링
<i>'PDBADMIN'</i>	<i>PDB (XEPDB1)</i>	<i>'PDB_DBA'</i>	<i>XEPDB1</i> 내부 관리
<i>'ticket_app'</i>	<i>PDB (XEPDB1)</i>	<i>'CONNECT', 'RESOURCE', 테이블스페이스 quota</i>	티켓팅 애플리케이션 전용 스키마

ticket_app 계정은 *PDB(XEPDB1)*에 한정된 스키마 소유자이며, 시스템 권한(*DBA*, *SYSDBA*)은 부여하지 않는다. JDBC 접속 시 서비스 이름은 *XEPDB1*을 사용한다.

```
-- SYS as SYSDBA 로 PDB 접속 후
ALTER SESSION SET CONTAINER = XEPDB1;

CREATE USER ticket_app IDENTIFIED BY ticket_app_2026
  DEFAULT TABLESPACE USERS
  TEMPORARY TABLESPACE TEMP
```

```
QUOTA UNLIMITED ON USERS;

GRANT CONNECT, RESOURCE TO ticket_app;
GRANT CREATE SESSION, CREATE TABLE, CREATE SEQUENCE, CREATE VIEW TO ticket_app;
```

3.3.3 애플리케이션 관리자 계정

티케팅 웹 애플리케이션 내부에서 운영되는 관리자 계정은 DB 계정과 별개로, 애플리케이션 인증 테이블(USER/ROLE)에서 관리한다.

계정	비밀번호 (원문)	저장 방식	권한
'admin'	'rhkswp1234'	BCrypt 해시 (cost=10)	ROLE_ADMIN

비밀번호는 평문으로 저장하지 않고 Spring Security의 BCryptPasswordEncoder를 통해 해시 처리하여 USER 테이블에 적재한다.

3.3.4 pfSense 관리 계정

pfSense webGUI 관리자는 OS 계정과 별도로 운영된다. 초기 자격증명(admin / pfsense)은 최초 구성 직후 즉시 변경한다. SSH는 기본 비활성 상태로 두고, webGUI 접근은 관제 세그먼트(soc-net, 10.0.100.0/24)에서만 허용한다.

접근 경로	계정	인증 방식
webGUI (HTTPS)	'admin'	패스워드 + 접근 ACL (soc-net 한정)
콘솔 (메뉴)	'admin'	콘솔 로그인

3.3.5 SSH 키 기반 인증 권고

관제 PC(SOC-mint)와 개발 PC(DEV-mint)에서 각 서버 VM에 접속할 때는 SSH 공개키 인증을 표준으로 사용한다. 패스워드 인증은 초기 부트스트랩 단계 외에는 비활성화를 권고한다.

```
# SOC-mint 또는 DEV-mint 에서 키 생성
ssh-keygen -t ed25519 -C "soc@soc-mint"

# 대상 서버로 키 배포
ssh-copy-id -i ~/.ssh/id_ed25519.pub souser@10.0.10.2      # WAF
ssh-copy-id -i ~/.ssh/id_ed25519.pub souser@10.0.10.100   # WAS
ssh-copy-id -i ~/.ssh/id_ed25519.pub souser@10.0.200.100  # DB
ssh-copy-id -i ~/.ssh/id_ed25519.pub souser@10.0.200.201  # Splunk
```

키 등록 후 `/etc/ssh/sshd_config`에서 다음 항목을 적용하여 보안을 강화한다.

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
AllowGroups wheel
```

4. 가상 머신(VM) 구축

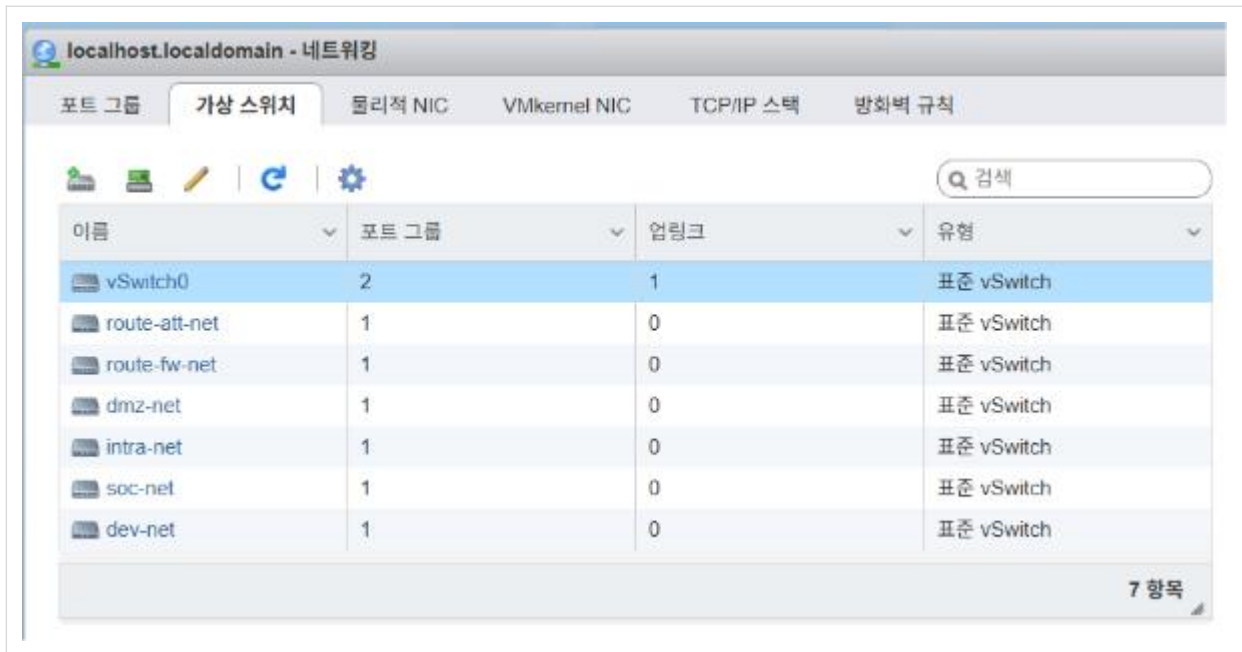
4.1 가상 네트워크(vSwitch) 구성

VM을 생성하기에 앞서, 각 VM이 연결될 가상 네트워크를 먼저 구성한다. 본 환경은 VMware ESXi의 표준 vSwitch와 포트그룹으로 망을 구간별로 분리하며, 외부 연결용 vSwitch0을 제외한 나머지 가상 망은 물리 NIC와 연결되지 않은(업링크 0) 내부 전용 격리망으로 구성하여 ESXi 내부 VM 간 통신만 허용한다.

가상 네트워크(vSwitch) 목록

vSwitch / 포트그룹	구간 용도	업링크	연결 VM
vSwitch0	관리 / 외부 연결	1 (물리 NIC)	(관리 인터페이스)
route-att-net	라우터 ↔ 공격자 구간	0	vyos-router, kali_attacker
route-fw-net	라우터 ↔ 방화벽 구간	0	vyos-router, pfsense
dmz-net	DMZ (외부 공개 서비스)	0	WAF, Ticketing platform, security onion(모니터링)
intra-net	내부 서비스 · 관제	0	oracle-db, splunk, security onion
soc-net	관제팀 PC 구간	0	SOC-mint

vSwitch / 포트그룹	구간 용도	업링크	연결 VM
dev-net	개발팀 PC 구간	0	DEV-mint



VM ↔ 가상망 ↔ IP 매핑

VM 명	연결 포트그룹	IP 주소
vyos-router	route-att-net / route-fw-net / vSwitch0	10.44.44.1/24 10.0.0.1/24 192.168.126.131/24
kali_attacker	route-att-net	10.44.44.44/24
pfsense	route-fw-net / dmz-net / soc-net / dev-net / intra-net	10.0.0.
WAF	dmz-net	[기재]
Ticketing platform	dmz-net	[기재]
security onion	intra-net / dmz-net(모니터링)	[기재]
oracle-db	intra-net	[기재]
splunk	intra-net	[기재]

VM 명	연결 포트그룹	IP 주소
SOC-mint	soc-net	[기재]
DEV-mint	dev-net	[기재]

IDS(security onion) 모니터링 구성

security onion은 관제 트래픽을 주고받는 intra-net과, 탐지 대상 트래픽을 수집하는 dmz-net 양쪽에 NIC를 연결한다. dmz-net 측 인터페이스로 DMZ 구간의 패킷을 수집·분석하고, intra-net 측 인터페이스로 관리 및 Splunk 연동 트래픽을 처리한다. 구체적인 트래픽 미러링(SPAN) 및 인터페이스 설정은 6장에서 다룬다.

확장성 고려

본 구성은 현재 프로젝트 기준이며, 동일한 망 분리 원칙(구간별 포트그룹 분리, 내부망은 업링크 0의 격리망 구성)을 따른다. 이후 VM을 추가할 경우, 역할에 맞는 기존 포트그룹에 연결하거나 새로운 포트그룹을 추가하고 위 두 표(가상망 목록 / VM 매핑)에 행을 추가하여 갱신한다.

4.2 공통 VM 생성 절차

본 인프라의 모든 가상 머신은 ESXi 6.7 Host Client(웹 UI, <https://192.168.126.130/ui>) 의 [가상 머신] → [VM 생성/등록] 마법사를 통해 동일한 절차로 생성한다. VM별 세부 사양(CPU-RAM·디스크·네트워크 어댑터)은 4.3 절의 개별 VM 구성표를 따르며, 본 절에서는 모든 VM에 공통으로 적용되는 마법사 단계와 표준 옵션을 정의한다.

4.2.1 마법사 단계 개요

ESXi Host Client의 VM 생성 마법사는 7단계로 구성된다.

단계	항목	표준 선택값
1	생성 유형 선택	"새 가상 머신 생성"
2	이름·게스트 OS 지정	VM 이름은 VM 목록 표와 일치, 호환성은 ESXi 6.7 가상 머신 (HW v14)
3	스토리지 선택	`datastore1` (SSD) — 단, oracle-db는 HDD 데이터스토어 권장
4	설정 사용자 정의	CPU, RAM, 디스크, 네트워크 어댑터, CD/DVD 설정
5	VM 옵션	부팅 펌웨어(BIOS/UEFI), 부팅 지연 등
6	완료 전 검토	사양 요약 확인
7	콘솔 진입	ISO 부팅 후 게스트 OS 설치

4.2.2 1단계: 생성 유형

Host Client 좌측 트리에서 [가상 머신] → 상단 [VM 생성/등록] 클릭 → "새 가상 머신 생성"을 선택한다. OVA/OVF 배포가 필요한 VM(예: pfSense 일부 이미지)은 해당 옵션 대신 "OVF 또는 OVA 파일에서 가상 머신 배포"를 선택한다.

4.2.3 2단계: 이름 및 게스트 OS

VM 이름은 3장에서 정의한 VM 목록의 이름을 그대로 사용한다(예: vyos-router, WAF, oracle-db). 호환성은 ESXi 6.7 가상 머신 (가상 하드웨어 버전 14)으로 고정한다. 게스트 OS 패밀리/버전은 다음 표를 따른다.

VM	게스트 OS 패밀리	게스트 OS 버전
vyos-router	Linux	Debian GNU/Linux 10 (64비트)
pfsense	기타	FreeBSD 11 (64비트)
kali_attacker	Linux	Debian GNU/Linux 12 (64비트)
WAF	Linux	Ubuntu Linux (64비트)
Ticketing platform	Linux	Ubuntu Linux (64비트)
oracle-db	Linux	Oracle Linux 8 (64비트)
security onion	Linux	Ubuntu Linux (64비트)
splunk	Linux	Ubuntu Linux (64비트)
SOC-mint / DEV-mint	Linux	기타 Linux 5.x 커널 (64비트)

4.2.4 3단계: 스토리지 선택

기본적으로 SSD 기반 datastore1(500GB)에 배치한다. 데이터 증분이 큰 VM은 별도 HDD 데이터스토어(1.8TB)에 분산한다.

데이터스토어	매체	배치 VM
datastore1	SSD 500GB	vyos-router, pfsense, kali_attacker, WAF, WAS, SOC-mint, DEV-mint
datastore2	HDD 1.8TB	oracle-db, splunk, security onion

4.2.5 4단계: 설정 사용자 정의

항목	표준값	비고
CPU 코어	VM별 표	소켓당 코어 = 1
메모리 예약	미예약	부팅 시 동적 할당
하드 디스크 유형	Thin Provisioning	실제 사용량만 소비
디스크 컨트롤러	LSI Logic Parallel (Linux 기본)	FreeBSD는 LSI Logic SAS
네트워크 어댑터 유형	VMXNET3	VyOS-pfSense는 E1000 권장
CD/DVD 드라이브 1	데이터스토어 ISO 파일	4.1에서 업로드한 설치 ISO 지정
부팅 시 연결	체크	설치 완료 후 해제

네트워크 어댑터는 마법사 단계에서 VM의 역할에 맞는 포트그룹을 지정한다. 다중 NIC 구성이 필요한 VM(vyos-router, pfsense)은 [네트워크 어댑터 추가]를 통해 NIC를 추가한다.

VM	NIC1	NIC2	NIC3	NIC4	NIC5
vyos-router	vSwitch0 (관리)	route-att-net	route-fw-net	-	-
pfsense	route-fw-net (WAN)	soc-net (LAN)	dev-net (OPT1)	dmz-net (OPT2)	intra-net (OPT3)
kali_attacker	route-att-net	-	-	-	-
WAF / WAS	dmz-net	-	-	-	-
oracle-db / splunk	intra-net	-	-	-	-
security onion	intra-net (관리)	dmz-net (모니터링, 무차별 모드)	-	-	-
SOC-mint	soc-net	-	-	-	-
DEV-mint	dev-net	-	-	-	-

4.2.6 5단계: 부팅 펌웨어 (UEFI vs BIOS)

VM 옵션 → [부팅 옵션] → "펌웨어" 항목에서 부팅 모드를 결정한다. 게스트 OS의 설치 미디어가 UEFI를 정식 지원하지 않거나, 어플라이언스가 BIOS를 전제로 빌드된 경우에는 BIOS를 선택한다.

펌웨어	적용 VM	근거
BIOS (Legacy)	vyos-router, pfsense, security onion	어플라이언스 ISO가 BIOS 부팅 기준
UEFI	kali_attacker, WAF, WAS, oracle-db, splunk, SOC-mint, DEV-mint	최신 배포판 표준, Secure Boot는 비활성

Secure Boot는 라이선스 키·커널 모듈 호환성을 고려하여 비활성 상태로 둔다. 부팅 지연(Boot Delay)은 BIOS 진입이 필요한 경우 2000ms 정도로 설정한다.

4.2.7 6단계: 완료 전 검토 및 7단계: 콘솔 진입

검토 화면에서 VM 이름, 게스트 OS, CPU/RAM, 디스크 크기, 네트워크 어댑터 매핑, ISO 마운트 여부를 최종 확인한 후 [완료]를 클릭한다. 생성된 VM을 선택하고 [전원 켜기] → [콘솔] 열기로 진입하여 게스트 OS 설치 마법사를 진행한다.

4.2.8 디스크 Thin Provisioning 정책

모든 VM의 가상 디스크는 Thin Provisioning을 기본으로 적용하여 데이터스토어 공간을 효율적으로 사용한다. Thin 디스크는 실제 게스트 OS가 기록한 블록만큼만 데이터스토어 공간을 점유하므로, 본 인프라의 500GB SSD + 1.8TB HDD 환경에서 다수 VM을 동시에 운용하기에 적합하다.

프로비저닝 방식	채택 여부	사유
Thin Provisioned	채택 (전체 VM 기본)	공간 효율, 신규 VM 추가 여유 확보
Thick Lazy Zeroed	미채택	초기 공간 점유로 인한 데이터 스토어 압박
Thick Eager Zeroed	미채택	성능 이점 대비 SSD 수명 부담

4.2.9 공통 사후 작업

게스트 OS 설치가 완료되면 다음 공통 사후 작업을 수행한다.

1. ISO 분리: VM 편집 → CD/DVD 드라이브 1 → "호스트 장치" 또는 "연결 해제"로 변경하고 "전원 켜기 시 연결"을 해제한다.
2. VMware Tools / open-vm-tools 설치: 리눅스 VM은 `apt install open-vm-tools` 또는 `dnf install open-vm-tools`로 설치한다. VyOS-pfSense는 배포판 패키지를 사용한다.
3. 시간 동기화: 게스트 OS의 NTP를 활성화하고, ESXi 호스트의 시간과 동기화한다.
4. 스냅샷: 게스트 OS 설치 직후 "clean-install" 라벨로 1차 스냅샷을 생성하여 롤백 지점을 확보한다.

예: Ubuntu 계열 사후 작업

```
sudo apt update && sudo apt install -y open-vm-tools chrony
sudo systemctl enable --now chrony
```

4.3 네트워크 장비

4.3.1 vyos-router (라우터)

① 설치

4.3.1 vyos-router ① 설치

VyOS 1.3.11은 외부망(공격자 세그먼트)과 내부 보안 인프라(pfSense WAN) 사이를 연결하는 코어 라우터 역할을 수행한다. ESXi에 신규 가상머신을 생성한 뒤 ISO를 마운트하여 라이브 환경으로 부팅하고, install image 명령으로 디스크에 영구 설치를 진행한다.

VM 사양

항목	값
게스트 OS	Debian Linux (64-bit)
vCPU	2
메모리	2 GB
디스크	20 GB (Thin)
NIC #1	route-att-net (eth0)
NIC #2	route-fw-net (eth1)
NIC #3	vSwitch0 / 관리·외부 (eth2)
ISO	vyos-1.3.11-amd64.iso

설치 절차

순서	단계	비고
1	ISO로 부팅 후 라이브 로그인	계정 `vyos` / 패스워드 `vyos`
2	`install image` 입력	영구 설치 마법사 시작

3	설치 모드 선택	기본값 `Auto` 사용
4	설치 디스크 선택	`sda` (20 GB) 선택
5	파티션 사이즈 입력	기본값(전체) 그대로 사용
6	설정 파일 복사 여부	`Yes`
7	root(관리자) 패스워드	`rhkswp1234`
8	GRUB 설치 디스크	`sda`
9	`reboot` 후 ISO 제거	디스크에서 부팅

설치 후 첫 로그인

```
vyos login: vyos
Password: rhkswp1234
vyos@vyos:~$ show version
```

버전 출력에 Version : VyOS 1.3.11 이 포함되면 정상적으로 디스크 설치가 완료된 상태이다.

[이미지 삽입]

② 설정

4.3.1 vyos-router ② 설정

라우터에 3개의 인터페이스 IP를 부여하고, 외부망(vSwitch0) 방향으로 NAT 마스크레이드를 적용한다. VyOS는 configure 모드에서 변경 후 commit → save 순으로 설정을 영속화한다.

인터페이스 매핑

인터페이스	포트그룹	주소	역할
eth0	route-att-net	10.44.44.1/24	공격자 세그먼트 게이 트웨이

eth1	route-fw-net	10.0.0.1/24	pfSense WAN 측 업링크
eth2	vSwitch0	192.168.126.131/24	관리·외부망(인터넷)

설정 명령

```
configure

# 인터페이스 IP 설정
set interfaces ethernet eth0 address '10.44.44.1/24'
set interfaces ethernet eth0 description 'route-att-net'
set interfaces ethernet eth1 address '10.0.0.1/24'
set interfaces ethernet eth1 description 'route-fw-net'
set interfaces ethernet eth2 address '192.168.126.131/24'
set interfaces ethernet eth2 description 'uplink-vSwitch0'

# 기본 게이트웨이 및 DNS
set protocols static route 0.0.0.0/0 next-hop 192.168.126.2
set system name-server '8.8.8.8'
set system name-server '1.1.1.1'

# NAT (외부망 방향 마스커레이드)
set nat source rule 100 outbound-interface 'eth2'
set nat source rule 100 source address '10.0.0.0/8'
set nat source rule 100 translation address 'masquerade'

# SSH 관리 접속
set service ssh port '22'
set service ssh listen-address '192.168.126.131'

commit
save
exit
```

적용 포인트

항목	설명
`commit`	런타임 적용
`save`	`/config/config.boot`에 영속 저장
NAT rule 100	사설망(10.0.0.0/8) → eth2 출구 시 SNAT

static route	vSwitch0 의 기본 게이트웨이 192.168.126.2 로 외부 도달
--------------	---

[이미지 삽입]

③ 확인

4.3.1 vyos-router ③ 확인

인터페이스 IP 부여 결과와 라우팅 테이블을 점검하고, 공격자(kali_attacker)에서 pfSense WAN(10.0.0.254) 까지 ICMP 도달이 이루어지는지 확인한다.

인터페이스 상태 확인

```
vyos@vyos:~$ show interfaces ethernet
```

인터페이스	기대 주소	상태
eth0	10.44.44.1/24	u/u
eth1	10.0.0.1/24	u/u
eth2	192.168.126.131/24	u/u

라우팅 테이블 확인

```
vyos@vyos:~$ show ip route
S>* 0.0.0.0/0 [1/0] via 192.168.126.2, eth2
C>* 10.0.0.0/24 is directly connected, eth1
C>* 10.44.44.0/24 is directly connected, eth0
C>* 192.168.126.0/24 is directly connected, eth2
```

기본 경로(0.0.0.0/0)가 eth2 로 향하고, 사설망 두 개가 directly connected 로 등록되어야 한다.

NAT 룰 확인

```
vyos@vyos:~$ show nat source rules
rule 100
  outbound-interface: eth2
  source address      : 10.0.0.0/8
  translation         : masquerade
```

End-to-End 도달성 점검

공격자 VM(kali_attacker, 10.44.44.44)에서 pfSense WAN 측을 핑한다.

```
kali@kali:~$ ip route add default via 10.44.44.1
kali@kali:~$ ping -c 3 10.0.0.254
64 bytes from 10.0.0.254: icmp_seq=1 ttl=63 time=0.8 ms
64 bytes from 10.0.0.254: icmp_seq=2 ttl=63 time=0.6 ms
64 bytes from 10.0.0.254: icmp_seq=3 ttl=63 time=0.7 ms
```

TTL 이 63 으로 보이는 것은 VyOS 1 홉을 거쳐 pfSense WAN 에 도달했다는 의미이며, 라우터의 포워딩과 인터페이스 결선이 정상임을 입증한다.

[이미지 삽입]

4.3.2 pfsense (방화벽)

① 설치

부팅 단계 설치 과정

단계	동작
Copyright/license	Accept
Welcome	Install pfSense
Keymap	Continue with default keymap
Partitioning	Auto (ZFS) ← 기본값
Pool Type	stripe (디스크 1개)
Disk Selection	da0 (50 GB) 스페이스바로 선택 → OK
확인	YES - Last Chance!
설치 진행	5-10분 대기
Manual Configuration?	No
Complete	Reboot

② 설정

초기 인터페이스 할당 – 추후 재설정

```
pfsense
Enter the WAN interface name or 'a' for auto-detection
(vmx0 vmx1 vmx2 vmx3 vmx4 or a): vmx0

Enter the LAN interface name or 'a' for auto-detection
NOTE: this enables full Firewalling/NAT mode.
(vmx1 vmx2 vmx3 vmx4 a or nothing if finished): vmx1

Enter the Optional 1 interface name or 'a' for auto-detection
(vmx2 vmx3 vmx4 a or nothing if finished): vmx2

Enter the Optional 2 interface name or 'a' for auto-detection
(vmx3 vmx4 a or nothing if finished): vmx3

Enter the Optional 3 interface name or 'a' for auto-detection
(vmx4 a or nothing if finished): vmx4

The interfaces will be assigned as follows:

WAN -> vmx0
LAN -> vmx1
OPT1 -> vmx2
OPT2 -> vmx3
OPT3 -> vmx4

Do you want to proceed [y;n]? y
```

부팅 후 초기 설정

WAN interface name → vmx0

LAN interface name → vmx1

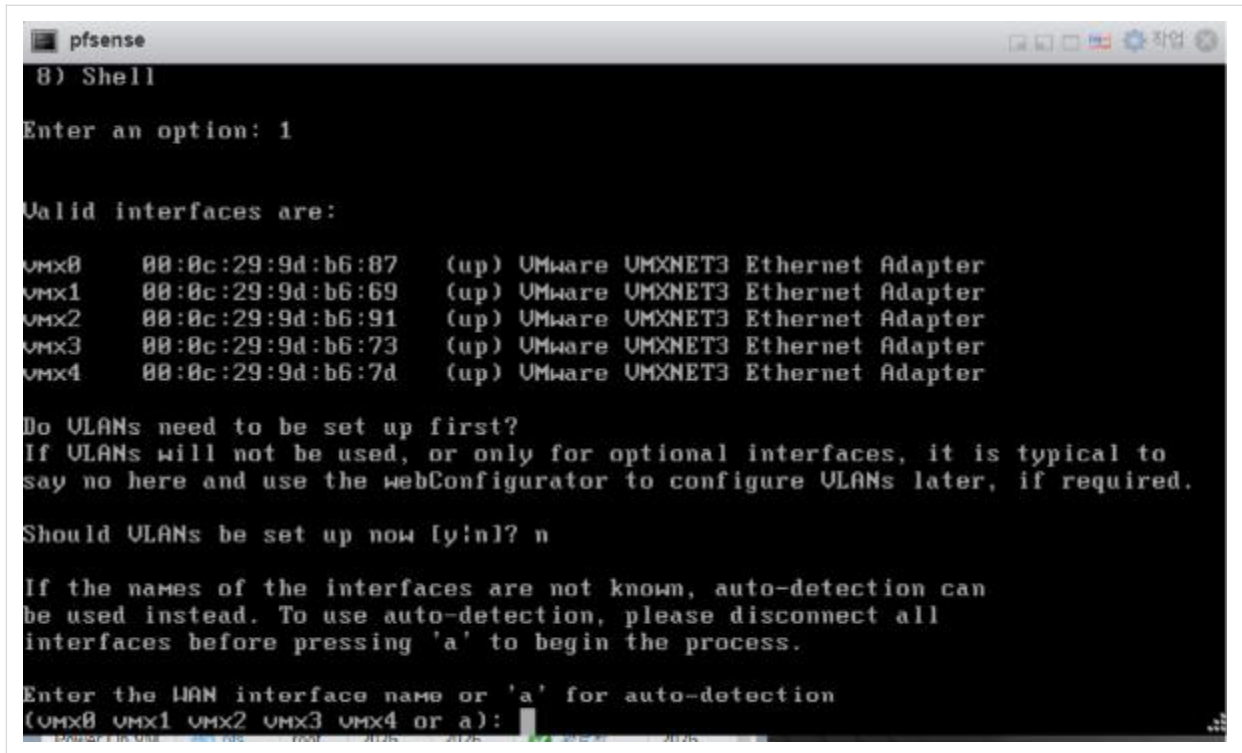
OPT1 → vmx4

OPT2 → vmx2

OPT3 → vmx3

Proceed? → y

인터페이스 재할당

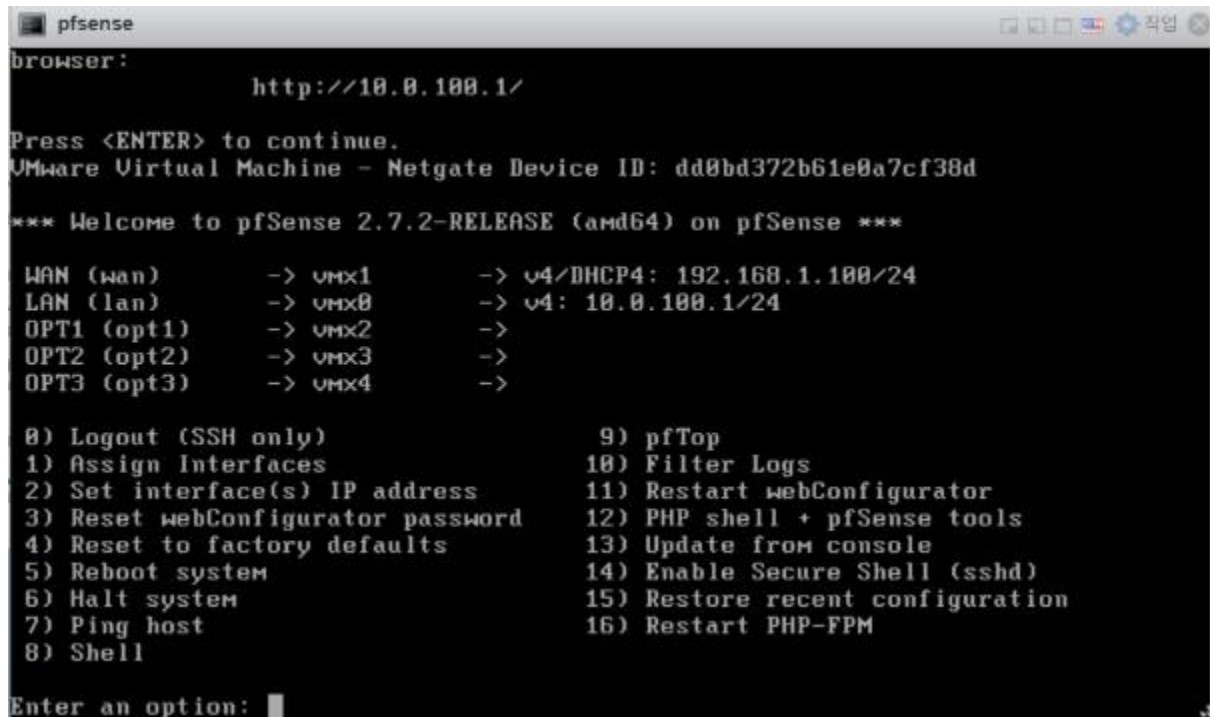


실제 인터페이스에 맞게 vmxN을 재연결. 이때 ESXi 콘솔에 확인한 실제 네트워크 인터페이스의 MAC주소를 확인하고 기록해 놓아야, 올바른 연결이 가능.

WAN의 경우 Router와 연결되는 route-fw-net, LAN의 경우 pfSense에 직접 접근할 수 있는 soc-net이 할당되어야 한다. 나머지 opt는 남은 vmxN을 순서대로 부여.

MAC 주소	ESXi 포트그룹	pfSense 역할	게이트웨이 IP
00:0c:29:9d:b6:69	route-fw-net	WAN	VyOS에서 받음
00:0c:29:9d:b6:87	soc-net	LAN	10.0.100.1/24
00:0c:29:9d:b6:7d	dev-net	OPT1 (DEV)	10.0.150.1/24
00:0c:29:9d:b6:73	dmz-net	OPT2 (DMZ)	10.0.10.1/24
00:0c:29:9d:b6:91	intra-net	OPT3 (INTRA)	10.0.200.1/24

LAN IP 할당



메인 메뉴에서 2) Set interface(s) IP address → 2) LAN 선택:

Configure IPv4 address LAN interface via DHCP? → n

Enter the new LAN IPv4 address → 10.0.10.1

Subnet bit count → 24

LAN IPv4 upstream gateway → (엔터, 비움)

Configure IPv6 by DHCP6? → n

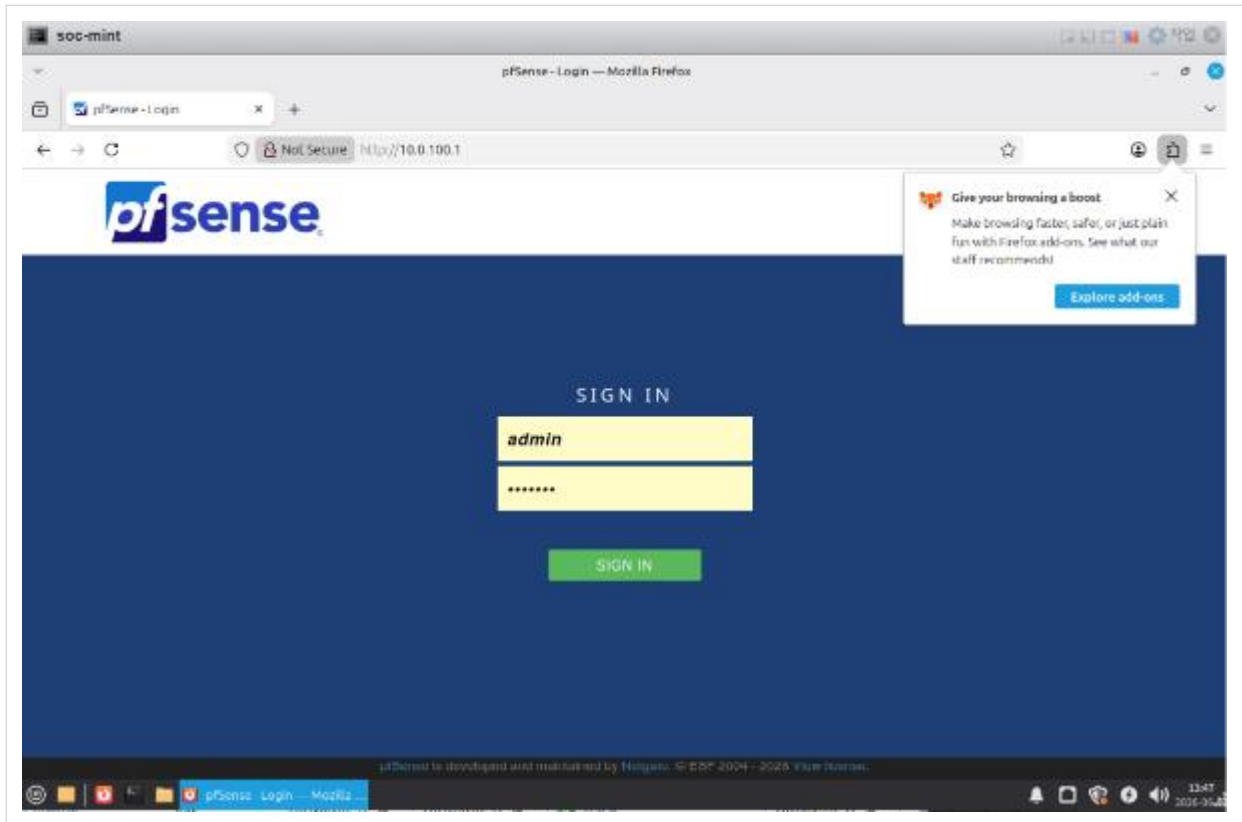
LAN IPv6 → (엔터, 비움)

Do you want to enable the DHCP server on LAN? → n

Revert to HTTP webGUI? → y ← (자체 인증서 만들면 HTTPS 가능, 일단 HTTP가 편함)

해당 설정이 완료되면, 10.0.100.1를 가진 soc-net의 PC로 pfsense의 web-gui 이용 가능

soc-mint로 pfsense gui 접속

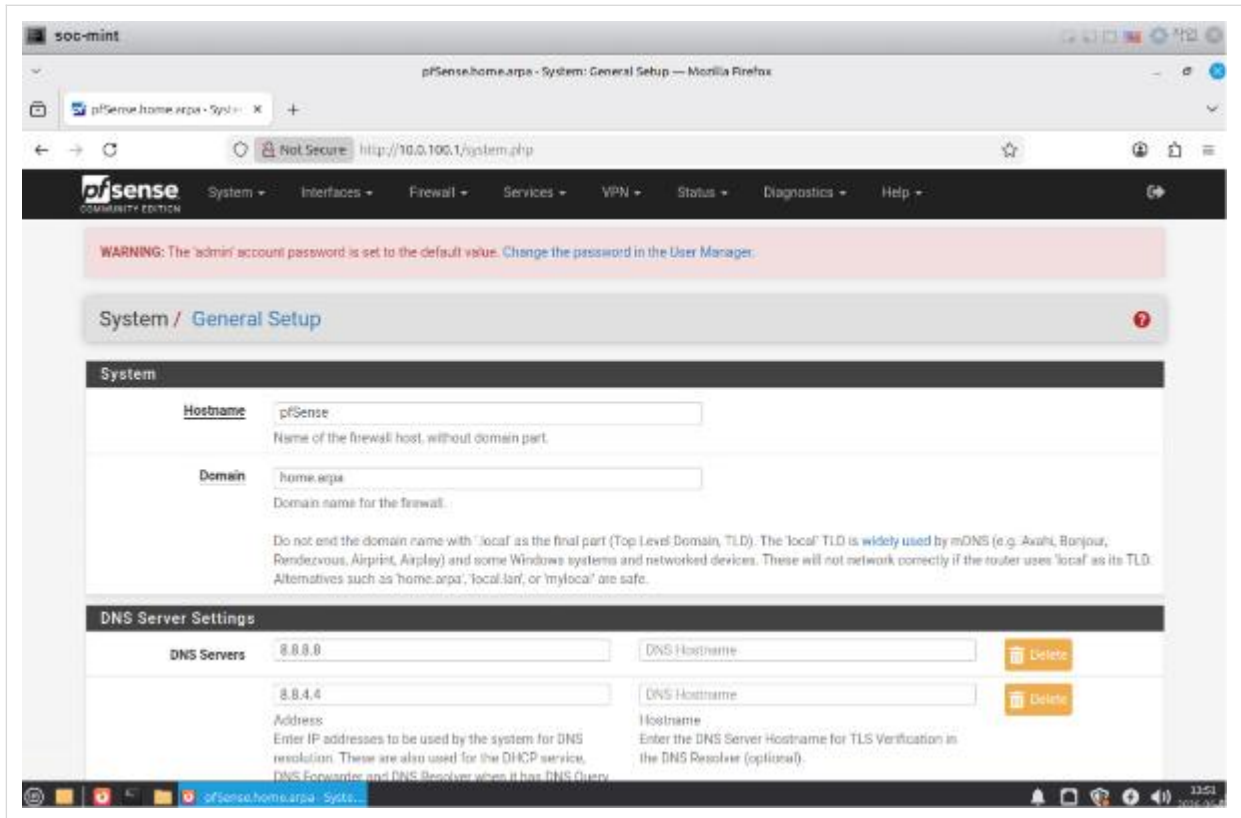


soc-mint VM이 구축되었다면, LAN으로 설정한 10.0.100.1 주소로 pfsense web gui 접속 가능

초기 아이디 : admin

초기 비밀번호 : pfsense

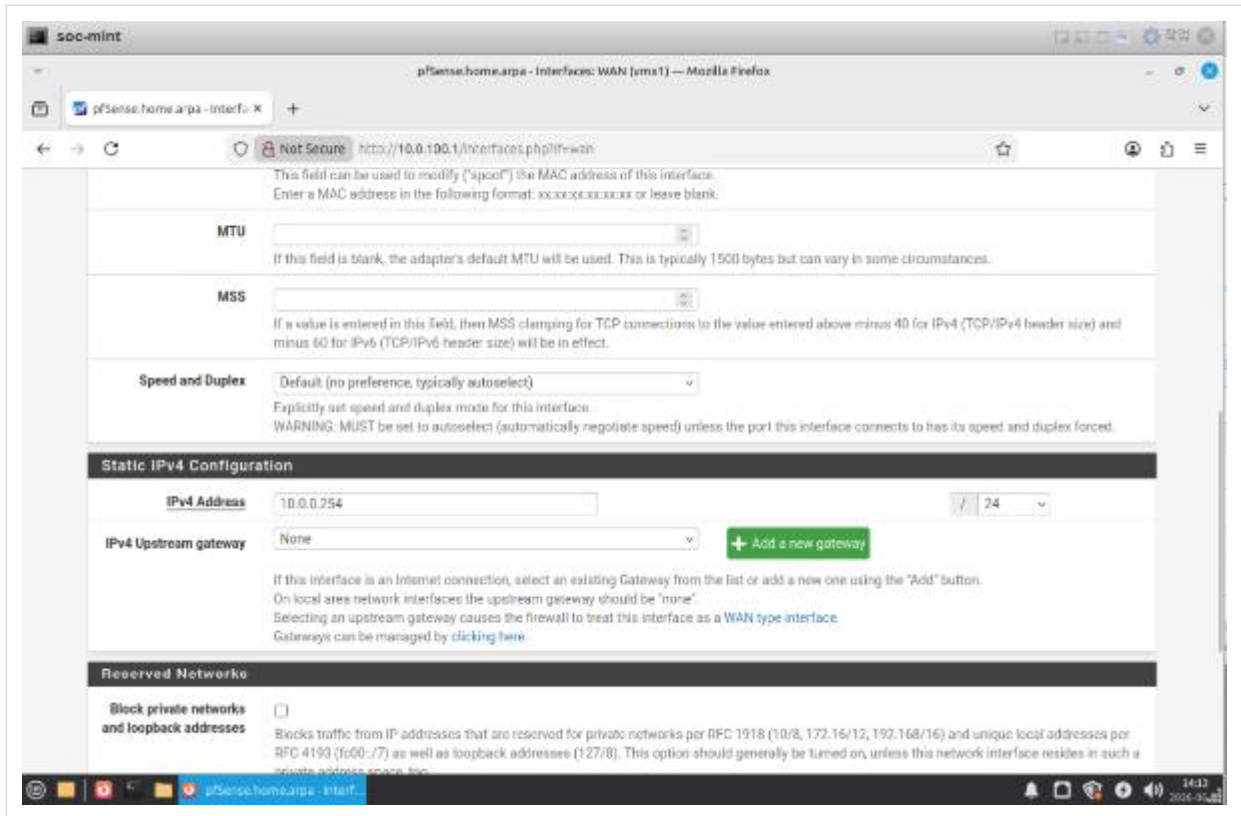
Pfsense web gui 설정



System -> General Setup [DNS Server Settings]

DNS Servers에 8.8.8.8, 8.8.4.4 추가 후 SAVE

WAN Interfaces 설정



Interfaces -> WAN 선택

General Configuration -> IPv4 Configuration Type [Static IPv4]

General Configuration -> IPv6 Configuration Type [None]

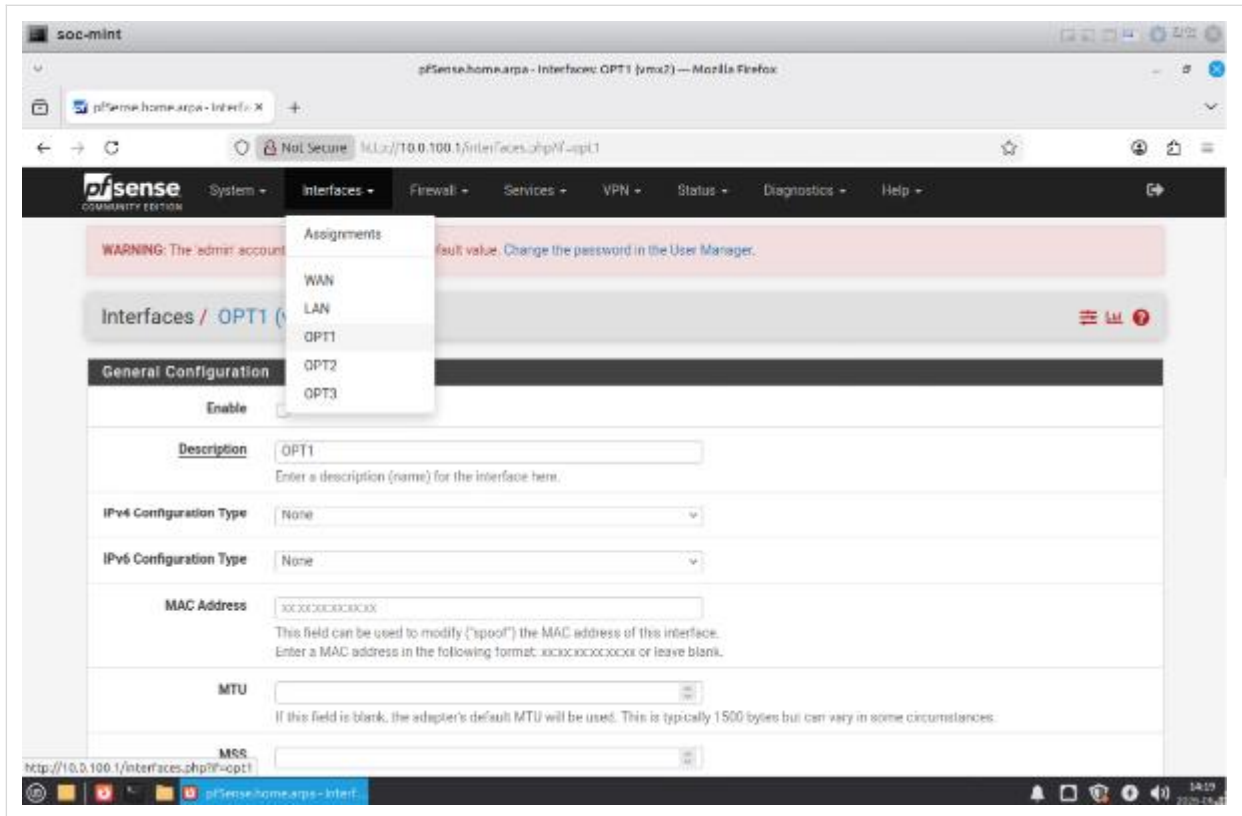
Static IPv4 Configuration -> IPv4 Address : 10.0.0.254 / 24

Add a new gateway -> Gateway IPv4 : 10.0.0.1 (Vyos의 주소)

Reserved Networks 체크박스 모두 해제

Save -> 상단 탭 Apply Changes

OPT1, OPT2, OPT3 Interfaces 설정



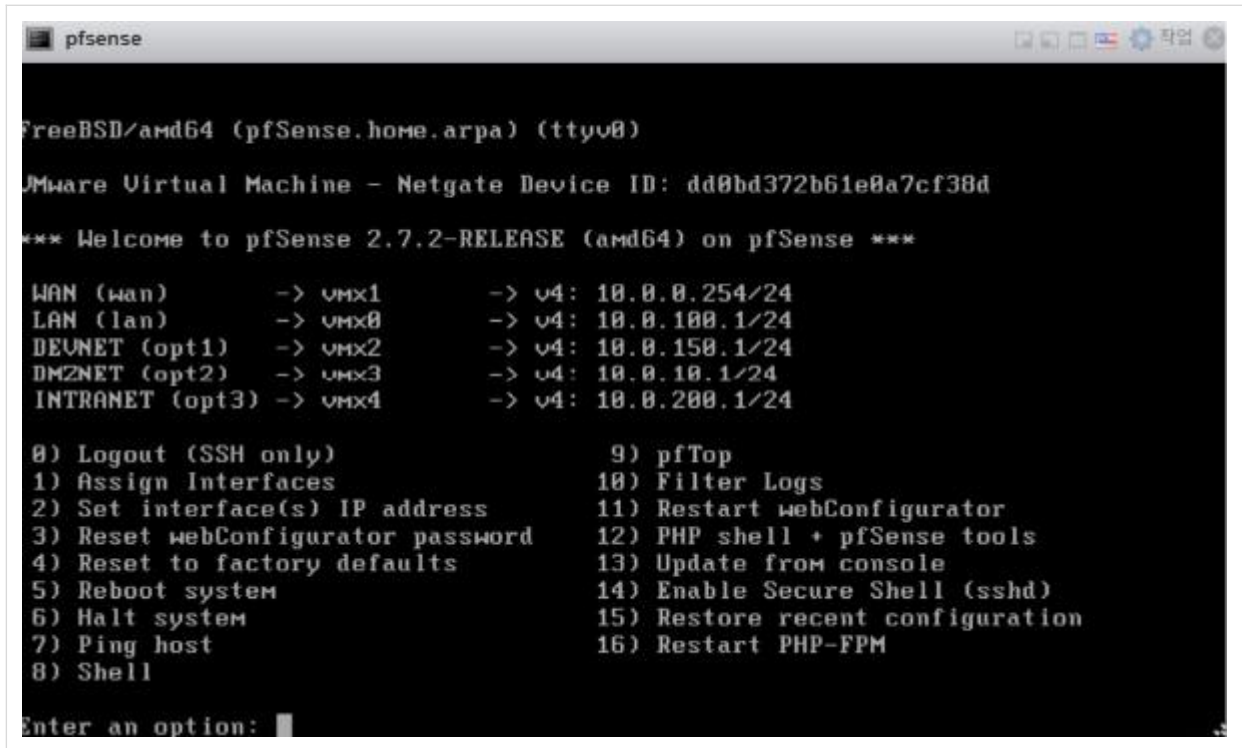
모든 인터페이스 Enable 체크 박스 활성화

Description	OPT1 -> dev-net	OPT2 -> dmz-net	OPT3 -> intra-net
IPv4 Configuration Type	Static IPv4	Static IPv4	Static IPv4
IPv4 Address	10.0.150.1/24	10.0.10.1/24	10.0.200.1/24

각 인터페이스에 대한 설정 완료 후 Apply Changes

③ 확인

Pfsense VM에서 수정된 인터페이스 확인



수정된 네트워크 인터페이스가 반영되었는지 pfSense VM 메인 화면에서 확인

4.4 서비스 계층

4.4.1 Ticketing platform (WAS)

① 설치

4.4.1 Ticketing platform (WAS) ① 설치

티케팅 서비스의 애플리케이션 서버(WAS)는 DMZ 세그먼트에 배치한다. 외부 사용자 트래픽은 WAF(10.0.10.2)를 거쳐 본 WAS(10.0.10.100)로 도달하는 구조이므로, NIC은 dmz-net 포트그룹 한 장만 부여한다.

VM 사양

항목	값
OS	Ubuntu 20.04 LTS Server (minimized)
vCPU	2
메모리	4 GB
디스크	100 GB (ext4, LVM 단일 볼륨)
NIC	dmz-net (ens160)
호스트네임	was
일반 사용자	`was` / `rhkswp1234`

설치 절차

순서	단계	선택 값
1	부팅 미디어	Ubuntu 20.04.6 Server ISO
2	언어	English
3	키보드	English (US)

4	설치 종류	Ubuntu Server (minimized)
5	네트워크	ens160 임시 DHCP (이후 netplan 으로 고정 전환)
6	프록시	(공백)
7	미러	기본값 사용
8	스토리지	전체 디스크 사용, LVM 활성화
9	파일시스템	`>` ext4, 100 GB 전체 할당
10	프로파일	name=was, server=was, user=was, pw=rhkswp1234
11	SSH	Install OpenSSH server 체크
12	Snap 패키지	선택 안 함
13	재부팅 후 ISO 분리	—

설치 직후 점검

```
was@was:~$ uname -a
Linux was 5.4.0-x-generic ... Ubuntu SMP x86_64 GNU/Linux
was@was:~$ ip -br a
ens160 UP <DHCP-IP>/24
was@was:~$ sudo systemctl status ssh
```

OS, 단일 NIC, SSH 데몬이 모두 활성화 상태인 것을 확인하면 ② 설정 단계로 진입한다.

[이미지 삽입]

② 설정

4.4.1 Ticketing platform ② 설정

JDK 8, Tomcat 9, 고정 IP, 한글 인코딩(UTF-8), systemd 부팅 자동화까지 4단계로 구성한다. Tomcat 은 /home/was/tomcat 경로에 배치하고, 소유자는 일반 사용자 was 로 통일한다.

1) JDK 및 환경 변수

```
sudo apt update
sudo apt install -y openjdk-8-jdk curl tar

sudo tee /etc/profile.d/java.sh >/dev/null <<'EOF'
export JAVA_HOME=/usr/lib/jvm/java-8-openjdk-amd64
export PATH=$JAVA_HOME/bin:$PATH
EOF
source /etc/profile.d/java.sh
java -version
```

2) 고정 IP (netplan)

```
# /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
    ens160:
      dhcp4: false
      addresses: [10.0.10.100/24]
      gateway4: 10.0.10.1
      nameservers:
        addresses: [8.8.8.8, 1.1.1.1]
```

```
sudo netplan apply
ip -br a show ens160
```

3) Tomcat 9 배치

```
cd /home/was
curl -LO https://archive.apache.org/dist/tomcat/tomcat-9/v9.0.89/bin/apache-tomcat-9.0.89.tar.gz
tar xzf apache-tomcat-9.0.89.tar.gz
mv apache-tomcat-9.0.89 tomcat
sudo chown -R was:was /home/was/tomcat
```

4) UTF-8 인코딩 적용

```
# /home/was/tomcat/bin/setenv.sh
```

```

cat > /home/was/tomcat/bin/setenv.sh <<'EOF'
export JAVA_HOME=/usr/lib/jvm/java-8-openjdk-amd64
export JAVA_OPTS="-Dfile.encoding=UTF-8 -Duser.language=ko -Duser.region=KR -Xms512m -
Xmx1024m"
EOF
chmod +x /home/was/tomcat/bin/setenv.sh

```

/home/was/tomcat/conf/server.xml 의 8080 Connector 에 URIEncoding="UTF-8" 속성을 추가한다.

```

<Connector port="8080" protocol="HTTP/1.1"
connectionTimeout="20000"
redirectPort="8443"
URIEncoding="UTF-8" />

```

5) systemd 서비스 등록

```

# /etc/systemd/system/tomcat.service
[Unit]
Description=Apache Tomcat 9 (Ticketing WAS)
After=network.target

[Service]
Type=forking
User=was
Group=was
Environment="JAVA_HOME=/usr/lib/jvm/java-8-openjdk-amd64"
Environment="CATALINA_HOME=/home/was/tomcat"
Environment="CATALINA_BASE=/home/was/tomcat"
ExecStart=/home/was/tomcat/bin/startup.sh
ExecStop=/home/was/tomcat/bin/shutdown.sh
Restart=on-failure

[Install]
WantedBy=multi-user.target

```

```

sudo systemctl daemon-reload
sudo systemctl enable --now tomcat

```

설정 요약

항목	값
----	---

JDK	OpenJDK 8 (`/usr/lib/jvm/java-8-openjdk-amd64`)
Tomcat	9.0.89 / `/home/was/tomcat` / 소유자 `was`
포트	8080 (HTTP)
인코딩	`-Dfile.encoding=UTF-8`, `URIEncoding="UTF-8"`
IP/GW/DNS	10.0.10.100/24 / 10.0.10.1 / 8.8.8.8
부팅 자동화	`systemctl enable tomcat`

[이미지 삽입]

③ 확인**4.4.1 Ticketing platform ③ 확인**

Tomcat 데몬이 정상적으로 기동되어 8080 포트에서 HTTP 응답을 반환하는지, 그리고 DMZ 게이트웨이(pfSense OPT2, 10.0.10.1) 까지 L3 통신이 가능한지를 검증한다.

1) 서비스 상태

```
was@was:~$ sudo systemctl status tomcat --no-pager
● tomcat.service - Apache Tomcat 9 (Ticketing WAS)
Loaded: loaded (/etc/systemd/system/tomcat.service; enabled)
Active: active (running) since ...
Main PID: xxxxx (java)
```

enabled 와 active (running) 두 상태가 모두 표시되어야 한다.

2) 포트 리스닝 확인

```
was@was:~$ ss -tln | grep 8080
LISTEN 0 100 *:8080 *:*
```

IPv4/IPv6 와 무관하게 8080 이 LISTEN 상태이면 Connector 기동이 정상이다.

3) HTTP 응답 확인

```
was@was:~$ curl -I http://localhost:8080
HTTP/1.1 200
Content-Type: text/html; charset=UTF-8
Date: ...
```

응답 코드 200 및 Content-Type 의 charset=UTF-8 표기로 인코딩 설정 반영이 확인된다.

4) 네트워크 도달성 확인

```
was@was:~$ ip -br a show ens160
ens160 UP 10.0.10.10/24
was@was:~$ ping -c 3 10.0.10.1
64 bytes from 10.0.10.1: icmp_seq=1 ttl=64 time=0.5 ms
64 bytes from 10.0.10.1: icmp_seq=2 ttl=64 time=0.4 ms
64 bytes from 10.0.10.1: icmp_seq=3 ttl=64 time=0.5 ms
```

검증 체크리스트

항목	기대값	결과
Tomcat systemd 상태	active (running)	OK
8080 LISTEN	`ss -tln` 에 노출	OK
HTTP 응답 코드	200	OK
응답 인코딩	UTF-8	OK
DMZ GW 핑 (10.0.10.1)	TTL 64	OK

본 확인 단계가 모두 통과되면, 상위 WAF(10.0.10.2) 의 upstream 대상으로 본 WAS(10.0.10.100:8080)를 등록할 수 있는 준비가 완료된 상태이다.

[이미지 삽입]

4.4.2 oracle-db (DB 서버)

① 설치

초기 설정



단계	핵심 값
Software Selection	Server
Installation Destination	sda (40GB) 만 체크 , sdb 60GB는 체크 X
Network — ens160 (MAC :9f)	Manual 10.0.200.100/24 GW 10.0.200.1 DNS 8.8.8.8 (INTRA)
Hostname	oracle-db
Root password	rhkswp1234
User	oracle / rhkswp1234, ☒ administrator
Time	아시아 / 서울

약 15~20분 동안 설치 진행. 설치가 끝나면 재시작 후 라이선스 동의 선택

② 설정

4.4.2 oracle-db ② 설정

Oracle XE 21c 의 정상 동작을 위해서는 OS 사전 패키지, 커널 파라미터, 사용자/그룹, 보안 정책이 일괄적으로 준비되어야 한다. Oracle 이 제공하는 oracle-database-preinstall-21c 패키지를 사용하면 이 모든 항목이 자동으로 적용된다. 본 절차는 데이터 디스크(/opt/oracle/oradata) 마운트가 완료된 상태(Phase 5)에서 진행한다.

4.4.2-2-1 사전 패키지 설치 (preinstall)

oracle-database-preinstall-21c 는 다음 항목을 한 번에 수행한다.

자동 적용 항목	내용
커널 파라미터	`/etc/sysctl.d/99-oracle-database-preinstall-21c-sysctl.conf` (kernel.shmmax / shmall / semmsl / aio-max-nr 등)
사용자/그룹	`oracle` 사용자, `oinstall`/`dba` 그룹 생성
limits	`/etc/security/limits.d/oracle-database-preinstall-21c.conf` (nofile 65536, nproc 16384, stack 10240)
의존 패키지	glibc, libaio, libnsl, libstdc++ 등 자동 해결

```
sudo dnf install -y oracle-database-preinstall-21c
sudo passwd oracle # rhkswp1234
```

적용 후 커널 파라미터가 반영되었는지 확인한다.

```
sudo sysctl -p /etc/sysctl.d/99-oracle-database-preinstall-21c-sysctl.conf
id oracle
# uid=54321(oracle) gid=54321(oinstall) groups=54321(oinstall),54322(dba)
```

4.4.2-2-2 Oracle XE 21c RPM 설치

Oracle 공식 yum 저장소에서 RPM 을 받아 dnf localinstall 로 설치한다. 사전 패키지가 의존성을 모두 해소해 두었으므로 추가 패키지 충돌 없이 진행된다.

```
cd /opt
sudo curl -O https://download.oracle.com/otn-pub/otn_software/db-express/oracle-database-
xe-21c-1.0-1.018.x86_64.rpm
sudo dnf -y localinstall oracle-database-xe-21c-1.0-1.018.x86_64.rpm
```

설치가 완료되면 /etc/init.d/oracle-xe-21c 스크립트와 /opt/oracle/product/21c/dbhomeXE 가 배포된다.

4.4.2-2-3 DB 초기화 (configure)

/etc/init.d/oracle-xe-21c configure 를 실행하면 CDB(XE) 와 PDB(XEPDB1) 가 생성되고, 리스너가 1521 포트로 기동된다. SYS / SYSTEM / PDBADMIN 비밀번호는 표준 자격증명 rhkswp1234 로 통일한다.

```
sudo /etc/init.d/oracle-xe-21c configure
# Specify a password to be used for database accounts: rhkswp1234
# Confirm the password: rhkswp1234
```

데이터파일은 4.4.2-1 에서 마운트한 /opt/oracle/oradata 로 자동 배치된다. 부팅 시 자동 기동되도록 systemd 서비스를 활성화한다.

```
sudo systemctl enable oracle-xe-21c
sudo systemctl start oracle-xe-21c
```

4.4.2-2-4 방화벽 / SELinux 정책

WAS(10.0.10.100) 가 DMZ → INTRA 로 1521/TCP 접속을 수행하므로, OS 방화벽에서 해당 포트를 허용한다. SELinux 는 Oracle XE 가 정식 지원하지 않는 enforcing 모드를 피하여 permissive 로 운영한다.

```
sudo firewall-cmd --permanent --add-port=1521/tcp
sudo firewall-cmd --reload

sudo sed -i 's/^SELINUX=enforcing/SELINUX=permissive/' /etc/selinux/config
sudo setenforce 0
```

4.4.2-2-5 애플리케이션 스키마 적용

WAS 가 사용할 ticket_app 사용자를 PDB(XEPDB1) 에 생성하고, 테이블 DDL 과 시드 데이터를 적재한다. 권한은 운영 최소 권한 원칙에 따라 CONNECT, RESOURCE 와 객체 생성 권한만 부여한다.

```
sudo su - oracle
export ORACLE_SID=XE
sqlplus / as sysdba
```

```
ALTER SESSION SET CONTAINER = XEPDB1;

CREATE USER ticket_app IDENTIFIED BY "ticket_app_2026"
  DEFAULT TABLESPACE USERS
  TEMPORARY TABLESPACE TEMP
  QUOTA UNLIMITED ON USERS;

GRANT CONNECT, RESOURCE TO ticket_app;
GRANT CREATE VIEW, CREATE SEQUENCE, CREATE PROCEDURE,
  CREATE TRIGGER, CREATE SYNONYM TO ticket_app;
```

DDL 과 시드는 db/init/ 디렉터리의 표준 파일을 순서대로 적용한다.

순서	파일	내용
1	`02_ddl.sql`	회원·공연·좌석·예매 등 14개 테이블
2	`seed/01_members.sql`	회원 5명

3	`seed/02_concerts.sql`	공연 5개
4	`seed/03_concert_schedules.sql` `seed/04_seats.sql`	회차 8건
5	`seed/04_seats.sql`	좌석 4,000건
6	`seed/05_bookings.sql`	예매 4건

```
sqlplus ticket_app/ticket_app_2026@localhost:1521/XEPDB1 @02_ddl.sql
sqlplus ticket_app/ticket_app_2026@localhost:1521/XEPDB1 @seed/01_members.sql
# ... 동일하게 02 ~ 05 적용
```

적용이 끝나면 본 절은 종료되고, 다음 절(③ 확인)에서 리스너 상태와 WAS 측 도달성을 검증한다.

[이미지 삽입]

③ 확인

4.4.2 oracle-db ③ 확인

DB 구성이 정상적으로 완료되었는지 다음 세 단계로 검증한다. (1) 리스너에 XEPDB1 서비스가 정상 등록되었는가, (2) CDB/PDB 가 정상 OPEN 상태인가, (3) WAS(10.0.10.100) 에서 INTRA(10.0.200.100:1521) 로 TCP 도달이 가능한가.

4.4.2-3-1 리스너 상태

lsnrctl status 결과에서 XE, XEPDB1 두 서비스가 모두 READY 상태로 등록되어 있어야 WAS 의 JDBC URL jdbc:oracle:thin:@10.0.200.100:1521/XEPDB1 가 정상 해석된다.

```
sudo su - oracle
lsnrctl status
```

예상 출력 (핵심 부분 발췌).

```

      Listening Endpoints Summary...
      (DESCRIPTION=(ADDRESS=(PROTOCOL=tcp)(HOST=oracle-db)(PORT=1521)))
      Services Summary...
      Service "XE"          has 1 instance(s).
      Instance "XE", status READY, has 1 handler(s) for this service...
      Service "XEPDB1" has 1 instance(s).
      Instance "XE", status READY, has 1 handler(s) for this service...
      The command completed successfully

```

4.4.2-3-2 CDB / PDB OPEN 상태

SYS 로 접속하여 컨테이너 상태를 확인한다. CDB(XE) 는 READ WRITE, PDB(XEPDB1) 는 READ WRITE 여야 한다.

```
sqlplus / as sysdba
```

```

SELECT NAME, OPEN_MODE FROM V$DATABASE;
-- NAME    OPEN_MODE
-- XE      READ WRITE

SELECT NAME, OPEN_MODE FROM V$PDBS;
-- NAME      OPEN_MODE
-- PDB$SEED   READ ONLY
-- XEPDB1     READ WRITE

```

PDB 가 MOUNTED 로 보일 경우 자동 OPEN 트리거를 다음과 같이 등록해 둔다(부팅 시 자동 재 OPEN).

```
ALTER PLUGGABLE DATABASE XEPDB1 SAVE STATE;
```

애플리케이션 계정도 정상 접속되는지 확인한다.

```

sqlplus ticket_app/ticket_app_2026@localhost:1521/XEPDB1 <<'SQL '
SELECT COUNT(*) AS members FROM members;
SELECT COUNT(*) AS seats   FROM seats;
EXIT;
SQL

```

시드 적재가 정상이면 members=5, seats=4000 가 출력된다.

4.4.2-3-3 WAS → DB 네트워크 도달성

방화벽(pfSense) 의 DMZ → INTRA 정책 (6.2 절) 이 정상 적용되어 있어야 한다. WAS(10.0.10.100) 에서 nc 로 1521/TCP 의 도달성을 확인한다.

```
# WAS 콘솔 (was@ticketing-was)
nc -zv 10.0.200.100 1521
# Connection to 10.0.200.100 1521 port [tcp/*] succeeded!
```

추가로 JDBC 클라이언트 레벨의 핸드셰이크까지 확인하려면 tnsping 또는 sqlplus thin URL 로 직접 접속한다.

```
sqlplus ticket_app/ticket_app_2026@//10.0.200.100:1521/XEPDB1
# Connected to:
# Oracle Database 21c Express Edition Release 21.0.0.0.0 - Production
```

4.4.2-3-4 검증 체크리스트

항목	기대값	확인 명령
리스너 기동	LISTENER UP, XEPDB1 READY	`lsnrctl status`
CDB OPEN	XE / READ WRITE	`SELECT ... V\$DATABASE`
PDB OPEN	XEPDB1 / READ WRITE	`SELECT ... V\$PDBS`
앱 계정 로그인	정상 SELECT	`sqlplus ticket_app/...`
시드 적재	members=5, seats=4000	`SELECT COUNT(*)`
WAS→DB TCP	succeeded	`nc -zv 10.0.200.100 1521`

systemd 자동 기동	enabled / active	`systemctl status oracle-xe-21c`
---------------	------------------	----------------------------------

위 7개 항목이 모두 충족되면 DB 인프라 단계는 종료된다. 이후 WAS(4.4.3) 가 본 PDB 에 JDBC 로 접속하여 티켓팅 서비스를 기동한다.

[이미지 삽입]

4.5 보안 · 관제 계층

4.5.1 WAF (ModSecurity)

① 설치

4.5.1 WAF (ModSecurity) ① 설치

DMZ 의 진입점에서 동작하는 WAF 는 nginx 리버스 프록시 위에 libmodsecurity v3 (libmodsecurity3) 라이브러리와 ModSecurity-nginx 동적 모듈을 결합한 구성으로 운영한다. 룰셋은 OWASP CRS(Core Rule Set) 를 사용한다. 본 절차는 WAF VM(10.0.10.2/24, Ubuntu 20.04 LTS) 에서 수행한다.

4.5.1-1-1 사전 패키지 및 빌드 의존성

libmodsecurity 와 connector 는 모두 소스 빌드로 설치하므로 컴파일러와 헤더 패키지가 필요하다. nginx 본체는 Ubuntu 공식 저장소 패키지(nginx-full) 를 사용한다.

구분	패키지
컴파일러/빌드 도구	`gcc`, `g++`, `make`, `automake`, `autoconf`, `libtool`, `pkg-config`
libmodsecurity 의존	`libpcre3-dev`, `libxml2-dev`, `libyajl-dev`, `liblua5.3-dev`, `libgeoip-dev`, `libcurl4-openssl- dev`, `libssl-dev`, `zlib1g-dev`
connector 빌드용	`nginx` 소스 (동일 버전)
보조 도구	`git`, `wget`, `unzip`

```
sudo apt update
sudo apt install -y nginx git build-essential automake autoconf libtool \
  pkg-config libpcre3-dev libxml2-dev libyajl-dev liblua5.3-dev \
  libgeoip-dev libcurl4-openssl-dev libssl-dev zlib1g-dev wget
```

4.5.1-1-2 libmodsecurity v3.0.15 빌드

OWASP 의 ModSecurity 라이브러리(런타임 엔진) 를 v3.0.15 로 빌드한다. --with-pcre, --with-yajl 등 의존 옵션은 기본값으로도 자동 탐지된다.

```
cd /usr/local/src
sudo git clone --depth 1 -b v3.0.15 https://github.com/owasp-modsecurity/ModSecurity
cd ModSecurity
sudo git submodule init && sudo git submodule update
sudo ./build.sh
sudo ./configure
sudo make -j$(nproc)
sudo make install
```

설치 결과는 다음과 같다.

산출물	경로
라이브러리	`/usr/local/modsecurity/lib/libmodsecurity.so.3`
헤더	`/usr/local/modsecurity/include/modsecurity/`
기본 설정 샘플	`/usr/local/src/ModSecurity/modsecurity.conf-recommended`
Unicode 매핑	`/usr/local/src/ModSecurity/unicode.mapping`

4.5.1-1-3 ModSecurity-nginx connector v1.0.4 빌드 (동적 모듈)

nginx 본체와 동일 버전의 소스를 받아, --add-dynamic-module 옵션으로 connector 를 동적 모듈 (.so) 형태로 빌드한다. 동적 모듈을 사용하면 nginx 본체를 교체하지 않고도 WAF 기능만 끌 수 있다.

```
NGX_VER=$(nginx -v 2>&1 | awk -F/ '{print $2}')
cd /usr/local/src
sudo git clone --depth 1 -b v1.0.4 https://github.com/owasp-modsecurity/ModSecurity-nginx
sudo wget http://nginx.org/download/nginx-${NGX_VER}.tar.gz
sudo tar xzf nginx-${NGX_VER}.tar.gz
cd nginx-${NGX_VER}

sudo ./configure --with-compat \
--add-dynamic-module=/usr/local/src/ModSecurity-nginx
sudo make modules
```

```
sudo cp objs/nginx_http_modsecurity_module.so /etc/nginx/modules/
```

4.5.1-1-4 OWASP CRS v3.3 배치

룰셋은 OWASP Core Rule Set v3.3 (안정 버전) 을 사용한다. /etc/nginx/modsec/ 아래에 main.conf, ModSecurity 권장 설정, Unicode 매핑, CRS 본체를 함께 둔다.

```
sudo mkdir -p /etc/nginx/modsec
sudo cp /usr/local/src/ModSecurity/modsecurity.conf-recommended \
/etc/nginx/modsec/modsecurity.conf
sudo cp /usr/local/src/ModSecurity/unicode.mapping /etc/nginx/modsec/

cd /etc/nginx/modsec
sudo git clone --depth 1 -b v3.3/master \
https://github.com/coreruleset/coreruleset.git coreruleset
sudo cp coreruleset/crs-setup.conf.example coreruleset/crs-setup.conf
```

4.5.1-1-5 설치 단계 요약

단계	구성요소	버전	결과
1	nginx	1.18 (Ubuntu 20.04 기본)	리버스 프록시 본체
2	libmodsecurity3	v3.0.15	WAF 엔진 라이브러리
3	ModSecurity-nginx	v1.0.4	nginx 동적 모듈
4	OWASP CRS	v3.3	시그니처 룰셋
5	설정 디렉터리	/etc/nginx/modsec/	`modsecurity.conf`, `unicode.mapping`, `coreruleset/`

이상으로 WAF 의 바이너리·모듈·룰셋 배치가 완료되었다. 다음 절(② 설정) 에서 nginx 의 load_module, server 블록, main.conf 를 작성하여 실제 트래픽이 ModSecurity 를 통해 흐르도록 연결한다.

[이미지 삽입]

② 설정**4.5.1 WAF ② 설정**

빌드된 ngx_http_modsecurity_module.so 와 OWASP CRS 를 실제 트래픽 경로에 연결한다. WAF VM(10.0.10.2) 은 외부에서 들어온 HTTP 요청을 ModSecurity 로 1차 검사한 뒤 백엔드 WAS(10.0.10.100:8080) 로 프록시한다. 도메인은 사내 호스트 yanus.com 을 사용한다.

4.5.1-2-1 nginx.conf (모듈 로드)

/etc/nginx/nginx.conf 의 최상단 main 블록에 동적 모듈 로드를 추가한다. 동적 모듈은 events {} 블록보다 앞에 와야 한다.

```
# /etc/nginx/nginx.conf (발췌)
user www-data;
worker_processes auto;

load_module modules/ngx_http_modsecurity_module.so;

events {
    worker_connections 1024;
}

http {
    include /etc/nginx/mime.types;
    default_type application/octet-stream;
    sendfile on;
    keepalive_timeout 65;

    include /etc/nginx/conf.d/*.conf;
    include /etc/nginx/sites-enabled/*;
}
```

4.5.1-2-2 사이트 설정 (리버스 프록시 + ModSecurity)

/etc/nginx/sites-available/yanus.conf 를 생성하고 활성화한다. 80/TCP 로 들어온 요청은 ModSecurity 를 거친 뒤 WAS(10.0.10.100:8080) 로 전달된다. 클라이언트 IP, 호스트 헤더는 백엔드 로그·세션에서 사용되므로 프록시 헤더를 정확히 전달한다.

```
# /etc/nginx/sites-available/yanus.conf
server {
    listen 80;
    server_name yanus.com;

    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;

    client_max_body_size 20m;

    location / {
        proxy_pass http://10.0.10.100:8080;
        proxy_http_version 1.1;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
        proxy_read_timeout 60s;
    }
}
```

```
sudo ln -s /etc/nginx/sites-available/yanus.conf /etc/nginx/sites-enabled/
sudo rm -f /etc/nginx/sites-enabled/default
```

4.5.1-2-3 ModSecurity main.conf (엔진/감사로그/룰셋 포함)

/etc/nginx/modsec/main.conf 가 ModSecurity 엔진의 진입점이다. 권장 설정(modsecurity.conf), CRS 초기 설정(crs-setup.conf), CRS 룰 파일을 순차로 include 한다. 본 환경은 차단 모드(SecRuleEngine On) 로 운영하고, 차단·매칭 이벤트는 단일 감사 로그(/var/log/modsec_audit.log) 로 집중시켜 Splunk(10.0.200.201) 가 수집하도록 한다.

```
# /etc/nginx/modsec/main.conf
Include /etc/nginx/modsec/modsecurity.conf
Include /etc/nginx/modsec/coreruleset/crs-setup.conf
Include /etc/nginx/modsec/coreruleset/rules/*.conf
```

/etc/nginx/modsec/modsecurity.conf 에서 다음 항목을 조정한다.

항목	값	의미
----	---	----

`SecRuleEngine`	`On`	차단 모드 (탐지+차단)
`SecRequestBodyAccess`	`On`	POST 본문 검사
`SecResponseBodyAccess`	`On`	응답 본문 검사 (information leakage 룰용)
`SecAuditEngine`	`RelevantOnly`	매칭/차단 이벤트만 기록
`SecAuditLog`	`/var/log/modsec_audit.log`	감사 로그 파일
`SecAuditLogParts`	`ABCEFHJKZ`	요청/응답/룰 매칭 전체 컨텍스트
`SecAuditLogType`	`Serial`	단일 파일 직렬 기록 (Splunk 수집 용이)
`SecUnicodeMapFile`	`/etc/nginx/modsec/unicode.mapping 20127`	Unicode 매핑

```

sudo sed -i 's|^SecRuleEngine .*|SecRuleEngine On|' /etc/nginx/modsec/modsecurity.conf
sudo sed -i 's|^SecAuditLog .*|SecAuditLog /var/log/modsec_audit.log|' /etc/nginx/modsec/modsecurity.conf
sudo touch /var/log/modsec_audit.log
sudo chown www-data:www-data /var/log/modsec_audit.log

```

4.5.1-2-4 적용

설정을 검증한 뒤 nginx 를 재시작한다.

```

sudo nginx -t
sudo systemctl restart nginx
sudo systemctl enable nginx

```

4.5.1-2-5 구성 요약

항목	값
----	---

Listen	`10.0.10.2:80`
Server Name	`yanus.com`
Backend (proxy_pass)	`http://10.0.10.100:8080` (Tomcat 9)
WAF Engine	`SecRuleEngine On` (차단 모드)
Ruleset	OWASP CRS v3.3 (`/etc/nginx/modsec/coreruleset/rules/*.conf`)
감사 로그	`/var/log/modsec_audit.log` (Serial, Splunk 수집)

이 시점부터 외부에서 `http://yanus.com/` 으로 들어온 모든 요청은 WAF 가 1차 를 검사 → 통과 시 WAS 프록시 → 응답 반환 경로를 거친다. 다음 절(③ 확인) 에서 실제 SQLi 페이로드로 차단 동작과 감사 로그 기록을 검증한다.

[이미지 삽입]

③ 확인

4.5.1 WAF ③ 확인

WAF 가 정상적으로 (1) 모듈 로드 (2) 정책 적용 (3) 공격 차단 (4) 감사 로그 기록 의 네 단계를 모두 수행하는지 검증한다.

4.5.1-3-1 설정 문법 및 모듈 로드 확인

nginx 의 설정 검증 결과에 `syntax is ok, test is successful` 이 모두 출력되어야 한다. 모듈이 적재되지 않은 경우 `unknown directive "modsecurity"` 가 발생하므로 본 단계에서 검출된다.

```
sudo nginx -t
# nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
# nginx: configuration file /etc/nginx/nginx.conf test is successful
```

4.5.1-3-2 서비스 상태


```
sudo systemctl status nginx --no-pager
```

다음 항목을 확인한다.

항목	기대값
`Active`	`active (running)`
`Loaded`	`enabled` (부팅 시 자동 기동)
Listen	`0.0.0.0:80`
워커 프로세스	`nginx: worker process` 다수

4.5.1-3-3 공격 페이로드 차단 테스트 (SQLi)

공격자(kali_attacker, 10.44.44.44) 가 외부에서 들어오는 시나리오를 모사하기 위해, OWASP CRS 가 시그니처로 보유한 전형적인 SQL Injection 페이로드를 WAF 엔드포인트로 전송한다. 정상 동작 시 HTTP 403 Forbidden 이 반환된다.

```
curl -i "http://yanus.com/?id=1' OR 1=1"
```

응답 예시.

```
HTTP/1.1 403 Forbidden
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 03 Jun 2026 02:14:08 GMT
Content-Type: text/html
Connection: close
```

비교를 위해 정상 요청도 함께 보내어, 정상 트래픽은 백엔드 WAS 응답이 그대로 전달되는지 확인한다.

```
curl -I http://yanus.com/
# HTTP/1.1 200 OK
# Server: nginx/1.18.0 (Ubuntu)
```

4.5.1-3-4 감사 로그 매칭 확인

차단 이벤트는 /var/log/modsec_audit.log 에 직렬 형식(Serial) 으로 기록된다. CRS 의 SQL Injection 룰(942xxx 계열) 매칭이 보이면 정상이다.

```
sudo tail -n 50 /var/log/modsec_audit.log
```

핵심적으로 다음 키워드가 함께 등장한다.

키워드	의미
`ModSecurity: Warning.` / `Access denied`	룰 매칭 / 차단
`[id "942100"]` 또는 `942xxx` 대역	OWASP CRS SQL Injection 룰 ID
`[msg "SQL Injection Attack Detected ..."]`	룰 설명
`[severity "CRITICAL"]`	룰 심각도
`[tag "attack-sqli"]`	CRS 태깅
`[hostname "yanus.com"] [uri "/"`	대상 호스트/URI
`[unique_id "..."]`	이벤트 식별자

다음 grep 으로 SQLi 룰 매칭만 즉시 확인할 수 있다.

```
sudo grep -E 'attack-sqli|94210[0-9]' /var/log/modsec_audit.log | tail -n 5
```

4.5.1-3-5 검증 체크리스트

항목	명령	기대값
설정 문법	`nginx -t`	`successful`
모듈 로드	`nginx -V 2>&1   grep`	tr ' ' '\n' grep
서비스 상태	`systemctl status nginx`	`active (running)`
리스닝 포트	`ss -ltnp   grep`	grep :80`
정상 요청	`curl -I http://yanus.com/`	`200 OK`
공격 요청 차단	`curl -i "http://yanus.com/?id=1' OR 1=1"`	`403 Forbidden`
감사 로그 기록	`tail /var/log/modsec_audit.log`	CRS 942xxx 매칭

위 7개 항목이 충족되면 WAF 단독 구성은 검증 완료이다. 본 감사 로그는 Splunk Universal Forwarder 가 /var/log/modsec_audit.log 를 모니터링하도록 설정되어, SIEM(10.0.200.201) 의 waf 인덱스로 적재된다 (5.2 절 참조).

[이미지 삽입]

4.5.2 security onion (IDS)

① 설치

Security onion 초기 설치



언어 : English

지역 : Asia/Seoul

키보드 레이아웃 : English

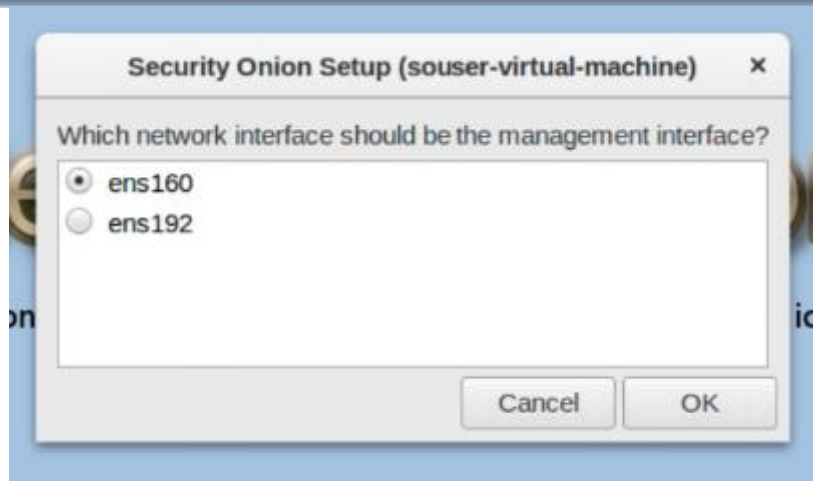
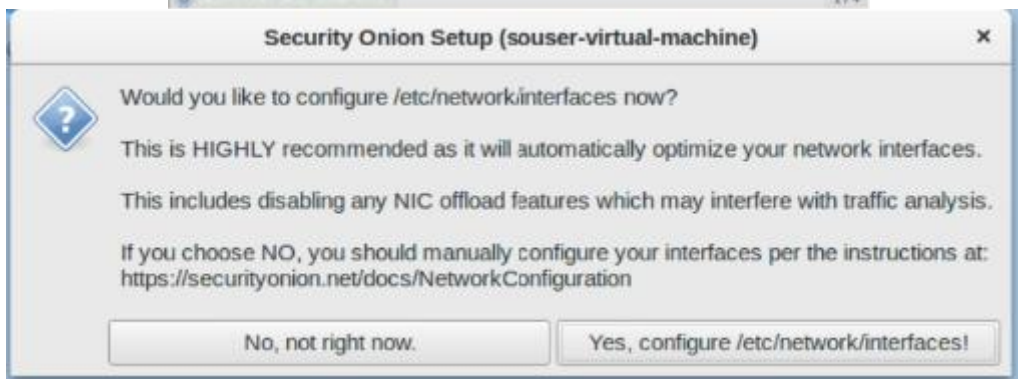
Name : souser

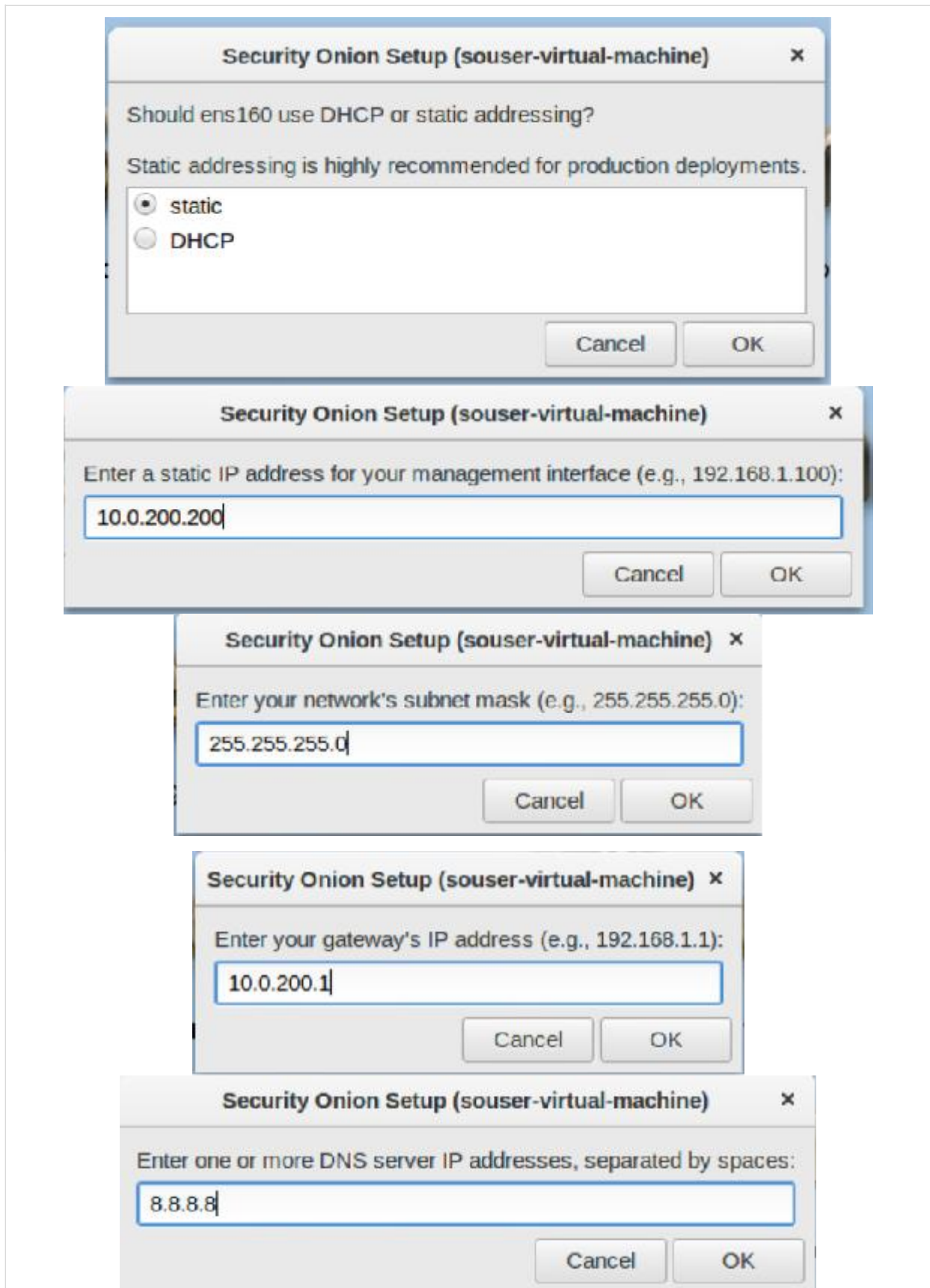
PW : rhkswp1234

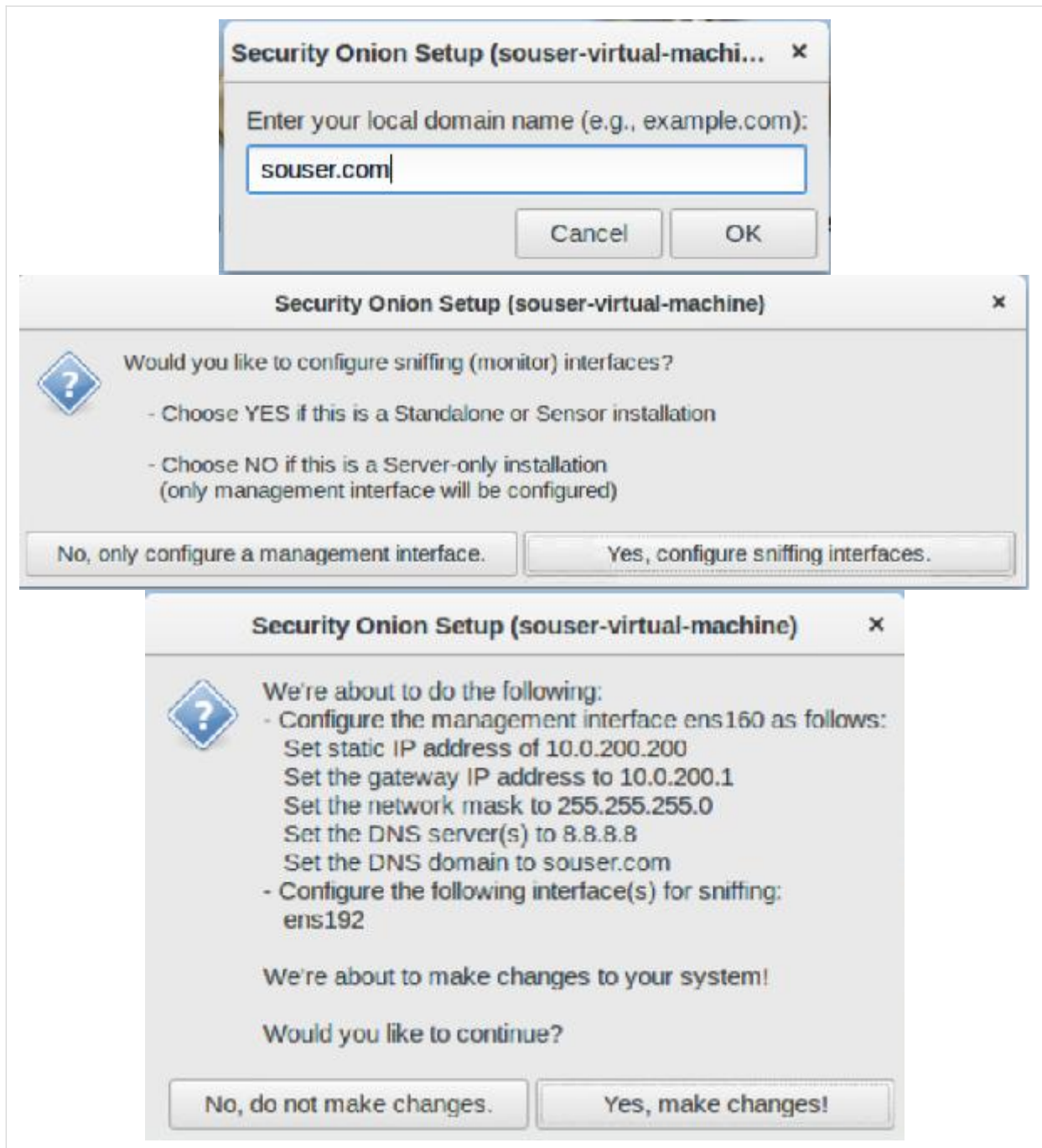
이 외의 설정은 continue 선택 자동으로 install 시작

완료되면 Restart Now 선택

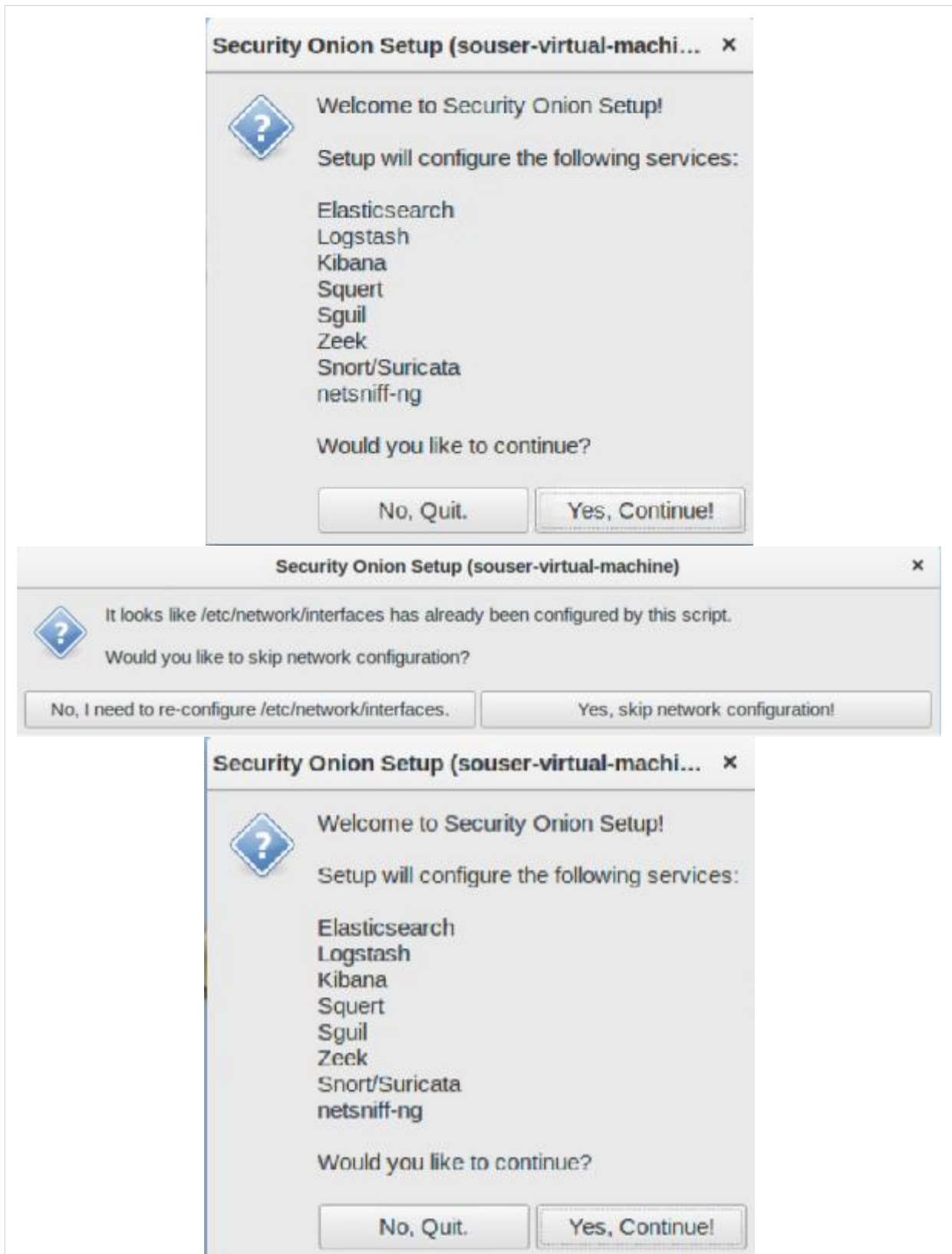
Security onion 설치 setup

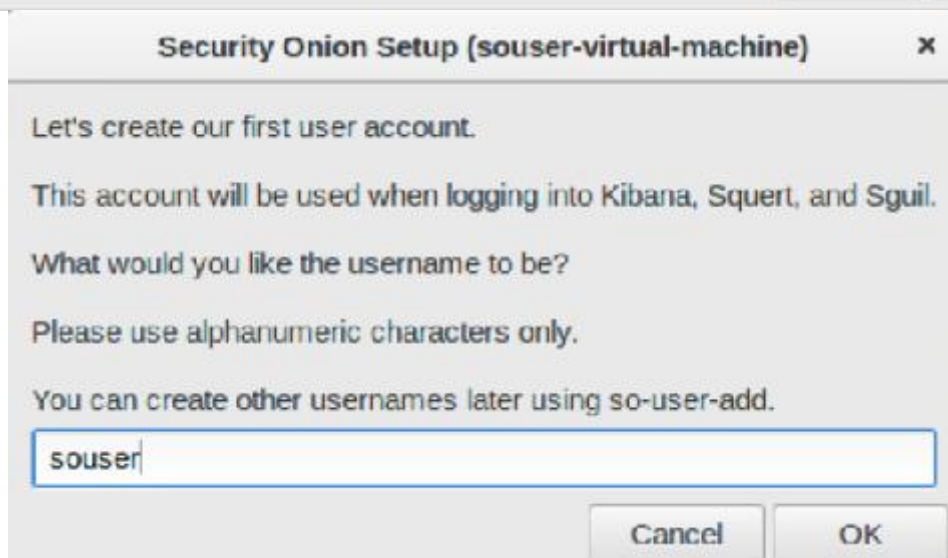
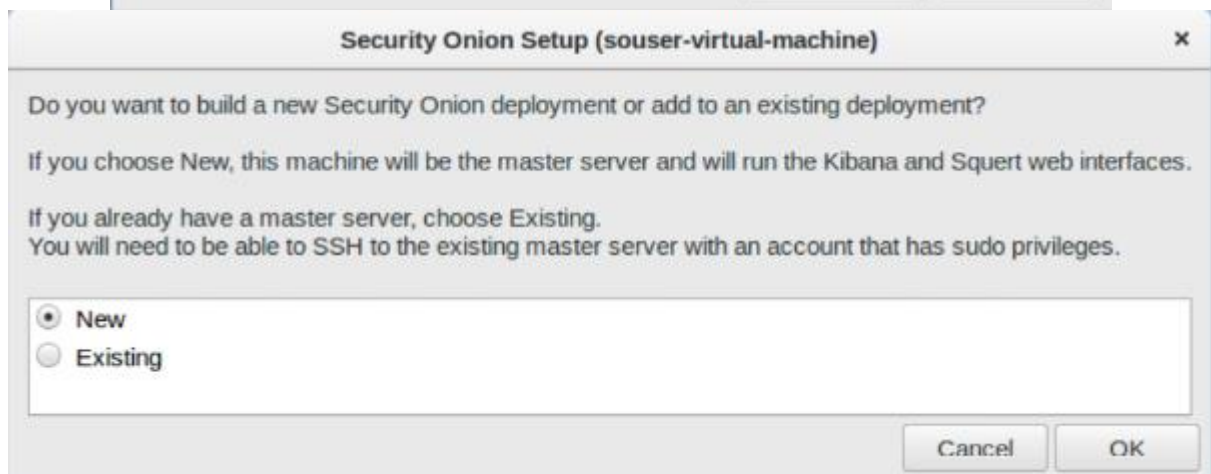
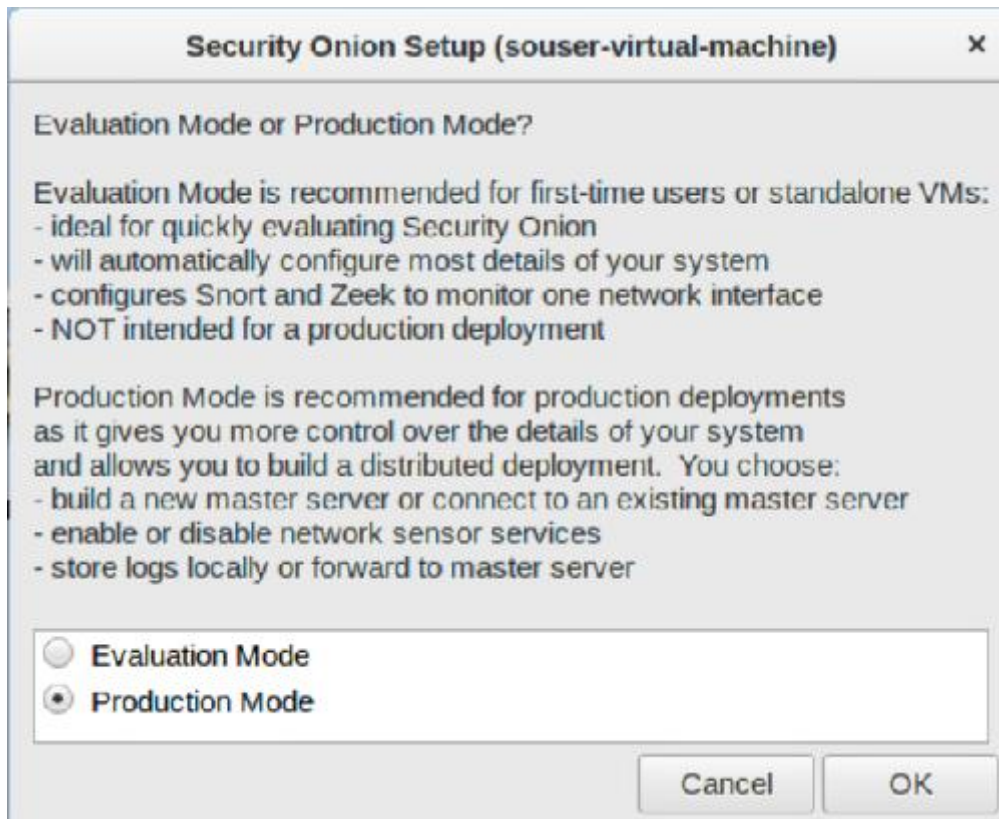


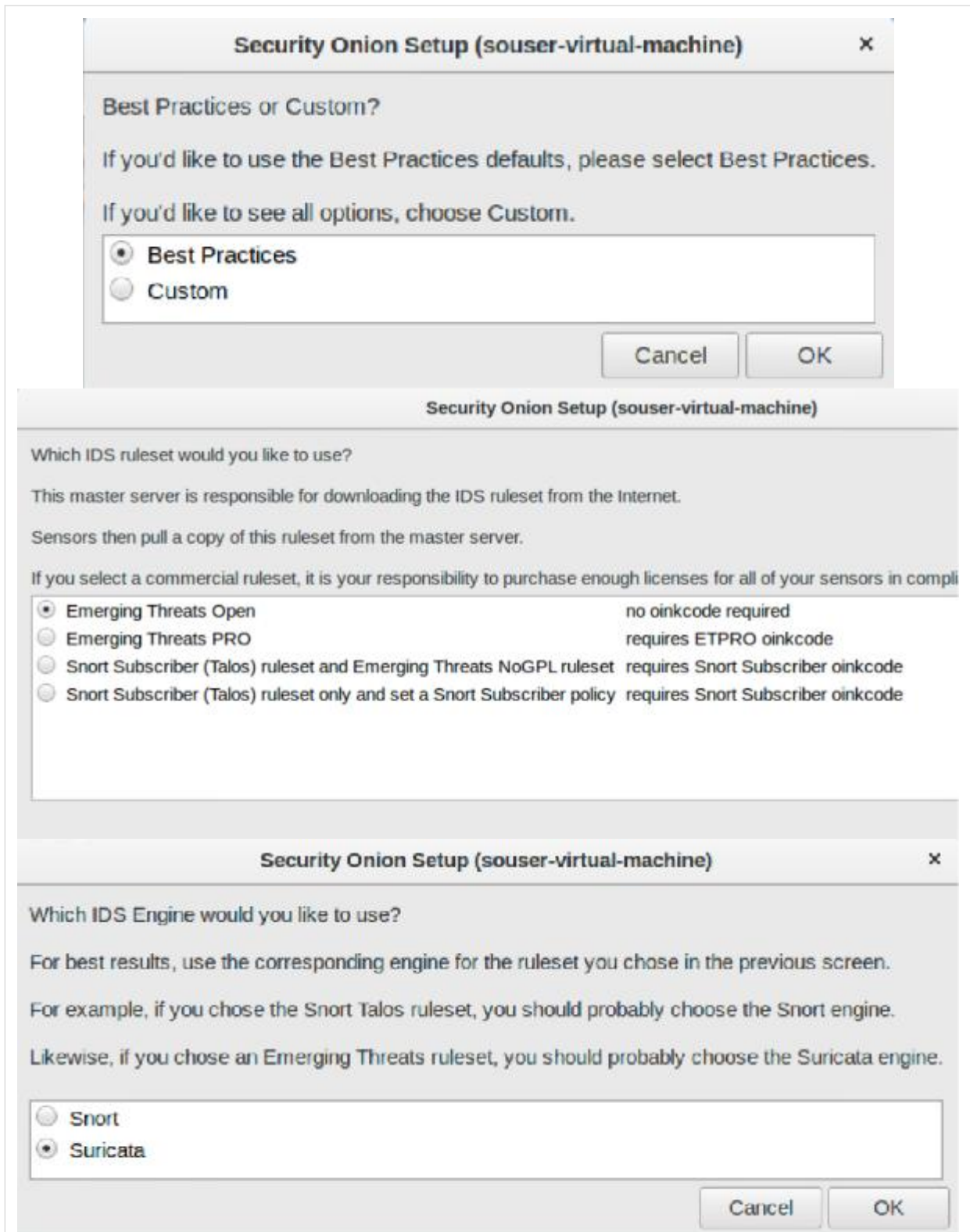


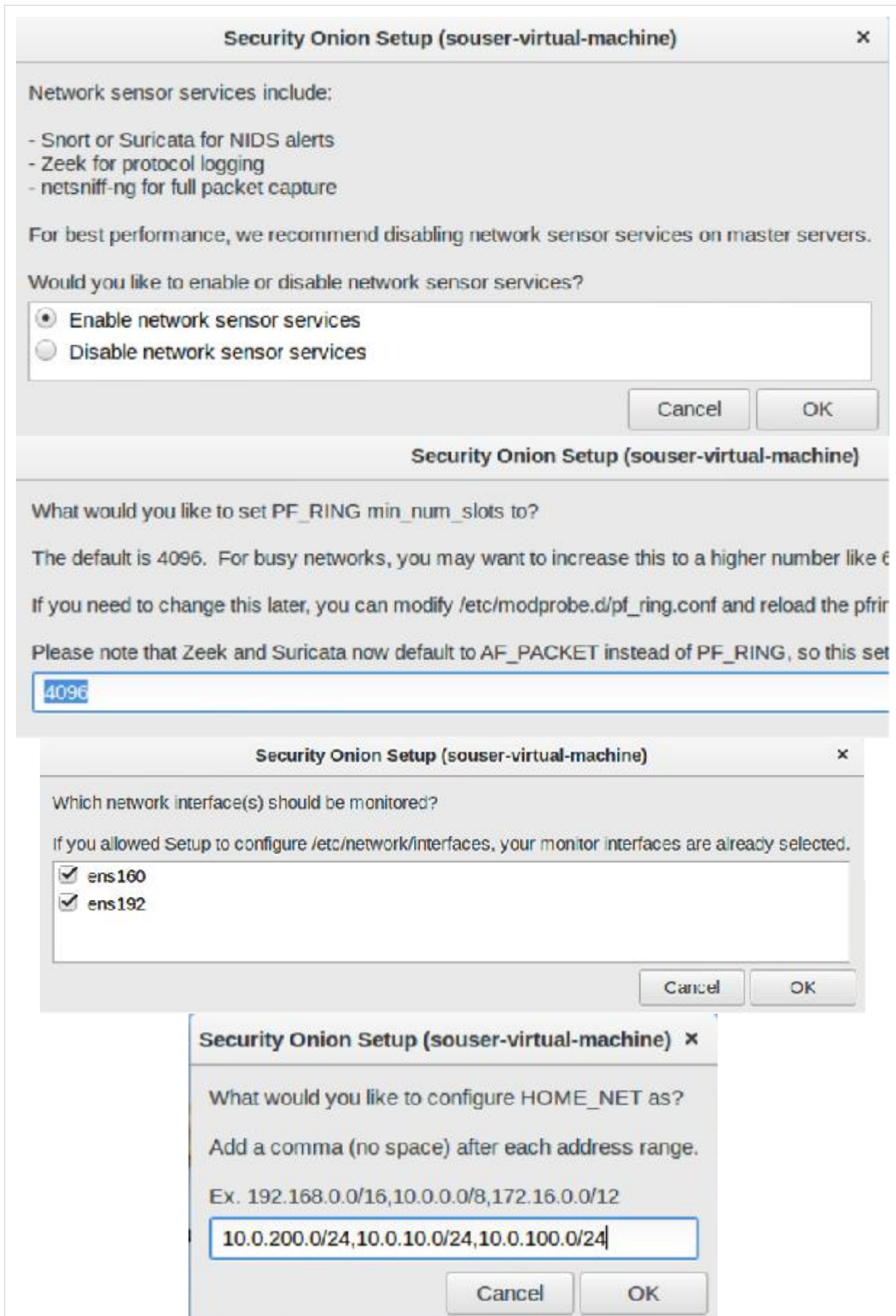


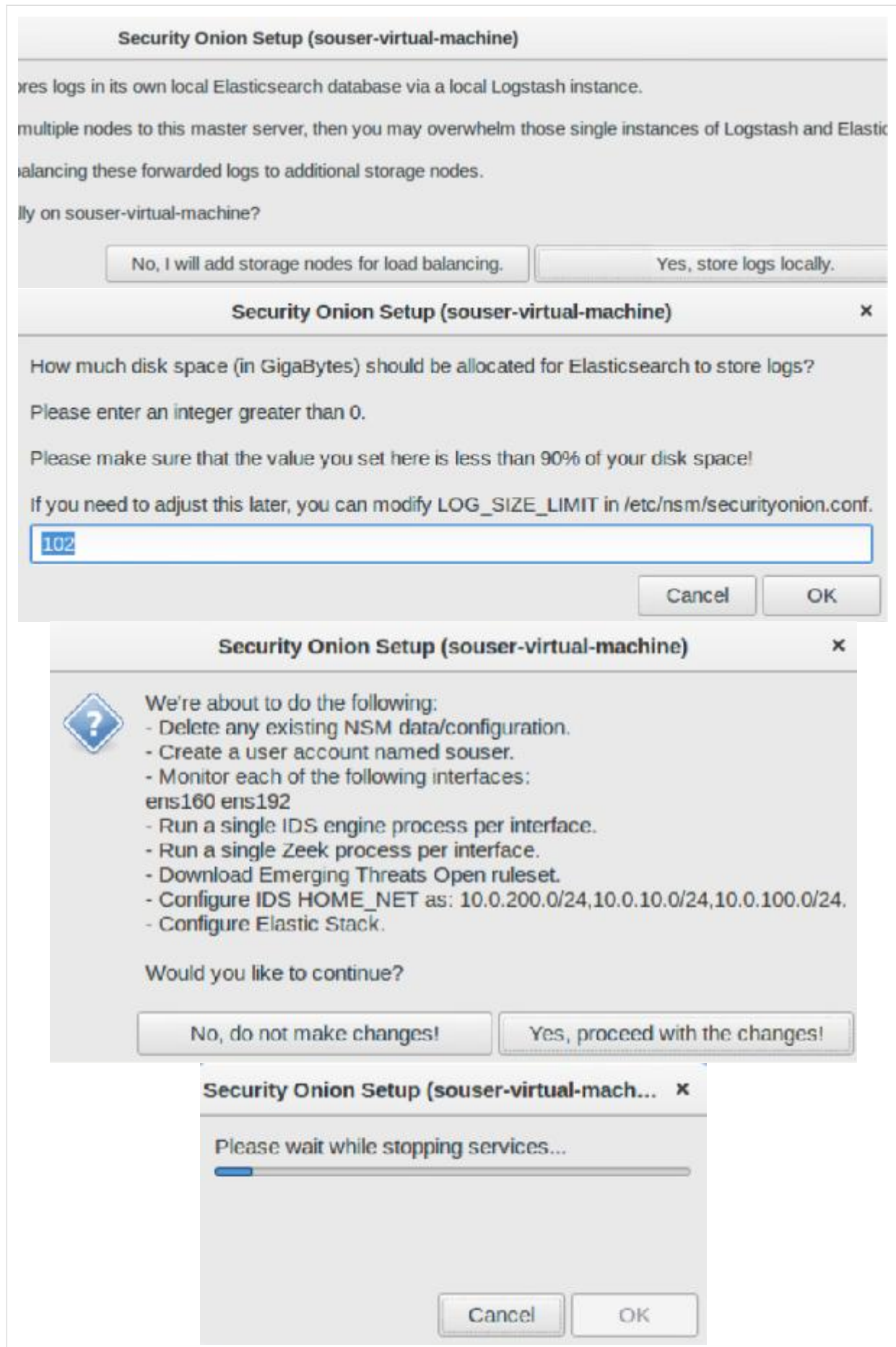
Security onion 설치 setup2











② 설정

SShd 서버 오픈

```
souuser@souuser-virtual-machine: ~
File Edit View Search Terminal Help

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Change to no to disable tunnelled clear text passwords
#PasswordAuthentication yes

# Kerberos options
#KerberosAuthentication no
#KerberosGetAFSToken no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes

X11Forwarding yes
X11DisplayOffset 10
PrintMotd no
PrintLastLog yes
TCPKeepAlive yes

73,1 71%
```

sshd설정확인

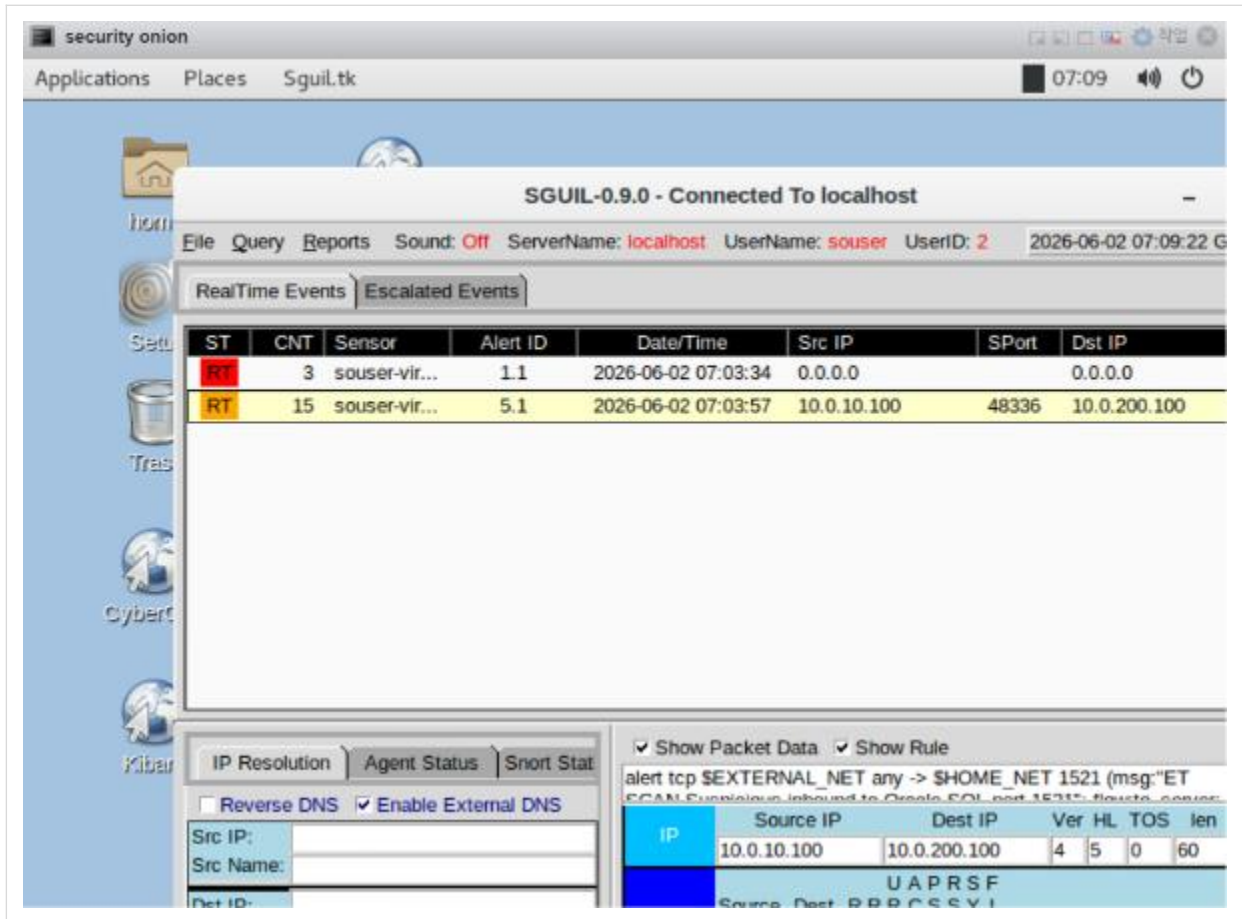
sudo vim /etc/ssh/sshd_config 포워딩 설정이 돼 있는지 확인

X11Forwarding yes

sshd서버재시작 service sshd restart

③ 확인

Sguil에 접속하여 패킷이 잘 잡히는지 확인



4.5.3 splunk (SIEM)

① 설치

4.5.3 splunk ① 설치

SIEM 역할을 담당하는 Splunk Enterprise 10.4.0을 intra-net 대역에 설치한다. 이 호스트는 pfSense, Snort/Suricata, ModSecurity(WAF), Tomcat(WAS), Oracle 감사 로그를 일괄 수집하는 중앙 집계 지점
이므로, 별도의 가상 머신에 단독 구성한다.

1) VM 사양

항목	값
VM 이름	splunk
OS	Ubuntu 20.04 LTS Server
vCPU / RAM	4 vCPU / 8 GB
디스크	80 GB (thin)
NIC	intra-net (vmxnet3)
IP	10.0.200.201/24
게이트웨이	10.0.200.1 (pfSense OPT3)
DNS	8.8.8.8

2) OS 기본 준비

Ubuntu 20.04 Server를 최소 설치 옵션으로 진행하며, 호스트네임은 splunk, 기본 사용자는 mupersei / rhkswp1234로 생성한다. 설치 후 패키지 목록을 갱신하고 Splunk 데몬 전용 계정을 분리한다.

```
sudo apt update && sudo apt -y upgrade
```

```
sudo useradd -r -m -d /opt/splunk -s /bin/bash splunk
sudo passwd splunk # rhkswp1234
```

3) Splunk Enterprise 패키지 설치

Splunk 공식 다운로드 페이지에서 splunk-10.4.0-x86_64.deb 파일을 받아 /tmp에 둔 뒤 dpkg로 설치한다. 설치 경로는 기본값 /opt/splunk를 유지한다.

```
cd /tmp
wget -O splunk-10.4.0-x86_64.deb \
  "https://download.splunk.com/products/splunk/releases/10.4.0/linux/splunk-10.4.0-x86_64.deb"
sudo dpkg -i splunk-10.4.0-x86_64.deb
sudo chown -R splunk:splunk /opt/splunk
```

4) 최초 기동 및 관리자 계정 생성

splunk 계정으로 최초 기동하여 라이선스에 동의하고, 관리자 자격증명을 admin / rhkswp1234로 지정한다.

```
sudo -u splunk /opt/splunk/bin/splunk start --accept-license
# Administrator username: admin
# Password: rhkswp1234
# Confirm password: rhkswp1234
```

첫 기동 시 Splunk Web(8000), splunkd(8089), KV Store가 순차적으로 올라오며 마지막에 The Splunk web interface is at http://splunk:8000 메시지가 출력되면 설치가 완료된 상태이다.

[이미지 삽입]

② 설정

4.5.3 splunk ② 설정

설치된 Splunk Enterprise를 운영 환경에 맞게 부팅 자동 기동, 수신 포트 9997, 수집 인덱스, 네트워크 고정 IP 순으로 구성한다.

1) 네트워크 고정 IP

Ubuntu 20.04의 Netplan으로 intra-net 대역 정적 IP를 부여한다. 파일 경로는 /etc/netplan/00-installer-config.yaml 이다.

```
network:
  version: 2
  renderer: networkd
  ethernets:
    ens160:
      dhcp4: no
      addresses: [10.0.200.201/24]
      gateway4: 10.0.200.1
      nameservers:
        addresses: [8.8.8.8, 8.8.4.4]
```

```
sudo netplan apply
ip -4 addr show ens160
```

2) 부팅 자동 기동 등록

splunk 사용자로 실행되는 systemd 유닛을 생성하여 호스트 재시작 시 자동으로 splunkd가 올라오도록 한다.

```
sudo /opt/splunk/bin/splunk enable boot-start -user splunk
sudo systemctl daemon-reload
sudo systemctl enable Splunkd
```

3) 수신 포트(Receiving) 활성화

Universal Forwarder가 보낼 데이터를 받기 위해 TCP 9997 포트를 연다. CLI와 Web 둘 중 어느 방법으로 진행해도 결과는 동일하다.

```
sudo -u splunk /opt/splunk/bin/splunk enable listen 9997 \
-auth admin:rhkswp1234
```

웹 UI에서 진행할 경우 다음 경로를 따른다.

경로	입력값
Settings → Forwarding and receiving	Configure receiving 선택
Configure receiving → New Receiving Port	9997
Save	활성 상태(Enabled)로 표시

4) 수집 인덱스 생성

각 보안 장비/애플리케이션별로 인덱스를 분리하여 보존 정책과 검색 권한을 독립 관리한다. 인덱스명은 소스 종류와 1:1로 매핑한다.

인덱스명	용도	주요 소스
`web_log`	웹 액세스 로그	nginx access/error
`pfsense`	방화벽 이벤트	pfSense filter log (syslog)
`snort`	NIDS 시그니처	Security Onion / Snort alert
`suricata`	NIDS eve.json	Suricata eve.json
`waf`	WAF 탐지	ModSecurity audit log
`was_app`	WAS 애플리케이션	Tomcat catalina.out, app log
`oracle_audit`	DB 감사	Oracle unified audit trail

CLI 일괄 생성:

```
for IDX in web_log pfsense snort suricata waf was_app oracle_audit; do
    sudo -u splunk /opt/splunk/bin/splunk add index "$IDX" \
        -auth admin:rhkswp1234
done
```

5) 설정 반영

인덱스/수신 포트 변경 후에는 splunkd를 재시작하여 설정을 적용한다.

```
sudo -u splunk /opt/splunk/bin/splunk restart
```

[이미지 삽입]

③ 확인

4.5.3 splunk ③ 확인

설치와 설정이 끝나면 데몬 상태, 웹 콘솔 접속, 수신 포트 동작, 인덱스 등록 여부를 순서대로 점검한다.

1) 프로세스 상태

```
/opt/splunk/bin/splunk status
# splunkd is running (PID: xxxx).
# splunk helpers are running (PIDs: xxxx).
sudo systemctl status Splunkd --no-pager
```

2) 웹 콘솔 로그인

동일 네트워크의 관제 PC(SOC-mint, 10.0.100.2)에서 브라우저로 접속한다.

항목	값
URL	http://10.0.200.201:8000
사용자	admin
비밀번호	rhkswp1234

로그인 후 상단 메뉴 Apps → Search & Reporting이 열리면 정상이다.

3) 수신 포트(9997) 청취 확인

Settings → Data inputs → Forwarded inputs / TCP 항목으로 이동하여 포트 9997이 Enabled 상태인지 확인한다. CLI에서도 동일하게 검증한다.

```
sudo ss -tlnp | grep 9997
# LISTEN 0 5 *:9997 *: users:(("splunkd",pid=xxxx,fd=xx))
```

4) 인덱스 등록 확인

Settings → Indexes 화면에서 7개 인덱스가 모두 표시되는지 확인한다. CLI에서는 다음과 같이 조회한다.

```
sudo -u splunk /opt/splunk/bin/splunk list index -auth admin:rhkswp1234 \
| egrep 'web_log|pfsense|snort|suricata|waf|was_app|oracle_audit'
```

5) 자체 로그로 수집 동작 검증

내부 인덱스 _internal에서 splunkd 자체 로그가 인덱싱되고 있는지 SPL로 즉시 확인한다.

```
index=_internal sourcetype=splunkd | head 20
```

이벤트가 실시간으로 출력되면 수집 파이프라인이 정상이며, 이후 단계에서 각 호스트의 Universal Forwarder를 9997로 향하게 하여 외부 로그를 받아들일 준비가 완료된 상태이다.

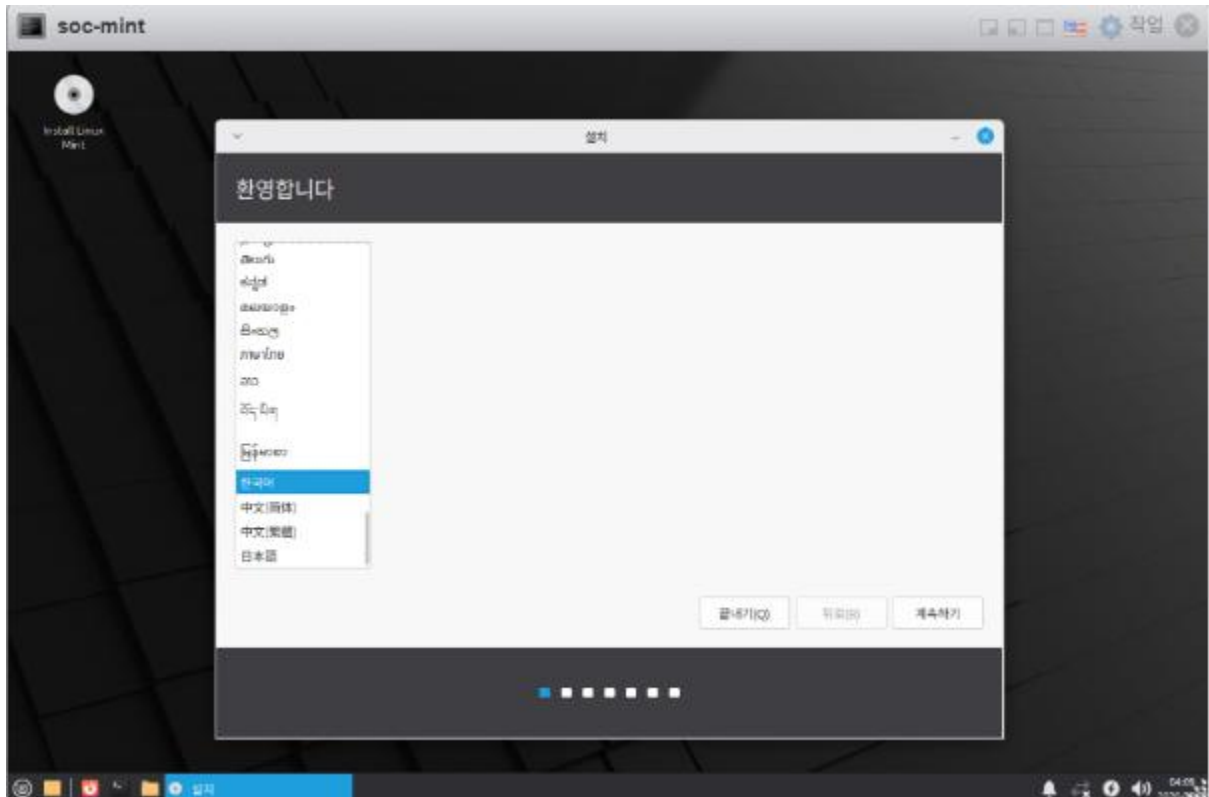
[이미지 삽입]

4.6 SOC · DEV · 공격자 PC

4.6.1 SOC-mint (SOC팀 PC)

① 설치

부팅 후 바탕화면 Install Linux Mint 실행



언어 : 한국어

키보드 레이아웃 : Korean

설치 형식 : 디스크를 지우고 Linux Mint 설치 -> 계속하기

시간대 : Seoul

이름 : soc (변경 가능)

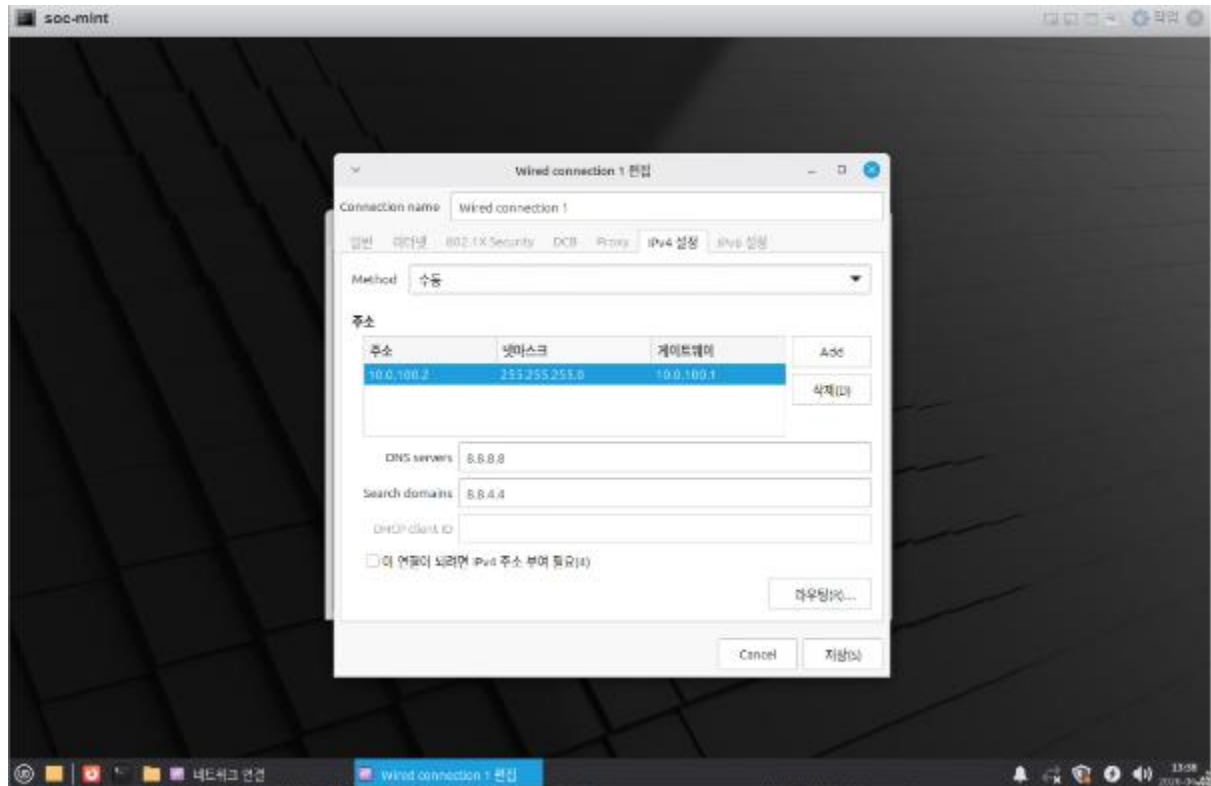
비밀번호 : rhkswp1234 (변경 가능)

약 10분 정도 설치 시간 소요

설치 완료 시 [지금 다시 시작] 선택

② 설정

네트워크 인터페이스 설정



시작 메뉴에서 Advanced Network Configuration 선택

Wired connection 1 선택 후 IPv4 설정 선택

Method : 수동(static)

주소 : 10.0.100.2 (SOC팀 PC의 주소)

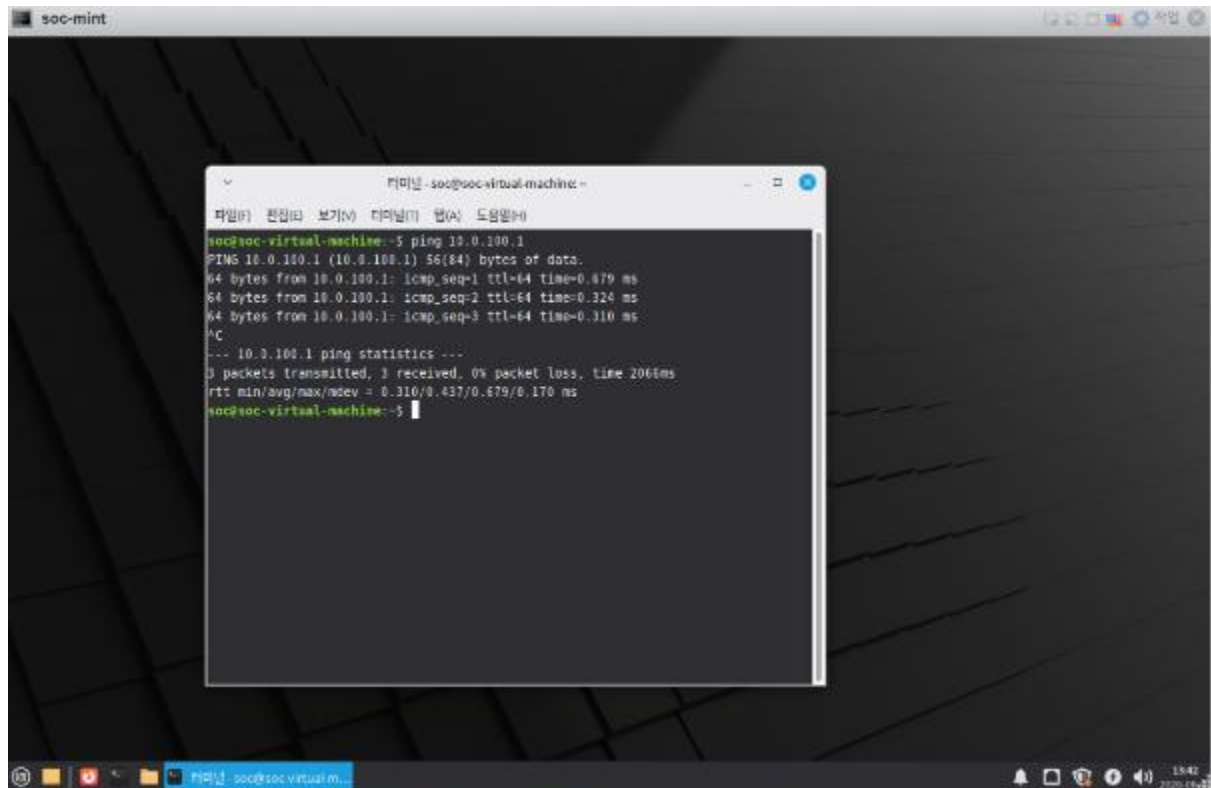
넷마스크 : 255.255.255.0

게이트웨이 : 10.0.100.1 (pfSense의 주소)

DNS servers : 8.8.8.8, 8.8.4.4

③ 확인

PfSense와 연결 확인



Pfsense의 IP주소 10.0.100.1 로 ping 테스트 진행

Ping 응답이 확인되면, 성공적으로 네트워크 인터페이스 설정이 끝난 것

4.6.2 DEV-mint (DEV팀 PC)

① 설치

4.6.2 DEV-mint ① 설치

개발팀 업무 PC로 사용할 DEV-mint VM을 dev-net 대역에 구성한다. Linux Mint 22.3 Xfce 에디션은 가벼우면서도 GUI 기반의 개발/테스트 환경에 적합하므로 개발팀 단말 표준으로 채택한다.

1) VM 사양

항목	값
VM 이름	DEV-mint
OS	Linux Mint 22.3 Xfce
vCPU / RAM	2 vCPU / 4 GB
디스크	40 GB (thin)
NIC	dev-net (vmxnet3)

2) ISO 부팅 및 인스톨러 진입

Linux Mint 22.3 Xfce ISO(linuxmint-22.3-xfce-64bit.iso)를 VM의 CD/DVD 드라이브에 마운트한 뒤 부팅하면 라이브 데스크톱이 뜬다. 바탕화면의 Install Linux Mint 아이콘을 더블 클릭하여 설치 마법사를 시작한다.

3) 설치 마법사 진행

각 단계의 선택값은 다음 표와 같이 통일한다.

단계	입력/선택값
Welcome	Language: 한국어
Keyboard layout	Korean / Korean
Multimedia codecs	Install third-party software (체크)
Installation type	Erase disk and install Linux Mint
Time zone	Asia/Seoul
Who are you? - Your name	dev
Your computer's name	DEV-mint
Pick a username	dev
Password	rhkswp1234
로그인 옵션	Require my password to log in

4) 설치 완료 및 재시작

파일 복사가 끝나면 Restart Now를 눌러 재시작한다. 부팅 직전 ISO를 분리하라는 안내가 나오면 가상 CD를 해제한 뒤 Enter를 입력한다. 재부팅 후 그래픽 로그인 화면에서 dev / rhkswp1234로 로그인하여 Xfce 데스크톱 진입을 확인한다.

```
lsb_release -a
# Distributor ID: Linuxmint
# Description:   Linux Mint 22.3
# Codename:      xia
uname -r
```

[이미지 삽입]

② 설정

4.6.2 DEV-mint ② 설정

dev-net 포트그룹에 연결된 인터페이스에 정적 IP를 부여하여 pfSense OPT1(10.0.150.1)을 게이트웨이로 사용하도록 구성한다. Linux Mint Xfce는 NetworkManager(nm-applet)를 기본 사용하므로 GUI 기반으로 진행한다.

1) IP 설계

항목	값
인터페이스	Wired connection 1 (ens33 / eth0)
IPv4 주소	10.0.150.2/24
게이트웨이	10.0.150.1 (pfSense OPT1)
DNS	8.8.8.8, 8.8.4.4
IPv6	Disabled

2) GUI 설정 (Advanced Network Configuration)

패널 우측 하단의 네트워크 아이콘 → Network Settings → Advanced Network Configuration 진입 후 Wired connection 1을 편집한다.

탭	항목	값
General	Connect automatically	체크
IPv4 Settings	Method	Manual
IPv4 Settings	Addresses → Address	10.0.150.2
IPv4 Settings	Addresses → Netmask	24
IPv4 Settings	Addresses → Gateway	10.0.150.1
IPv4 Settings	DNS servers	8.8.8.8, 8.8.4.4

IPv6 Settings	Method	Disabled
---------------	--------	----------

Save를 누른 뒤 같은 메뉴에서 해당 연결을 Disable → Enable로 토글하여 새 설정을 즉시 적용한다.

3) CLI 동등 명령

GUI 대신 터미널에서 동일하게 설정할 경우 다음 nmcli 명령을 사용한다.

```
nmcli con mod "Wired connection 1" \
    ipv4.method manual \
    ipv4.addresses 10.0.150.2/24 \
    ipv4.gateway 10.0.150.1 \
    ipv4.dns "8.8.8.8 8.8.4.4" \
    ipv6.method disabled \
    connection.autoconnect yes
nmcli con down "Wired connection 1"
nmcli con up "Wired connection 1"
```

4) 적용 결과 점검

```
ip -4 addr show
ip route
resolvectl status | grep -E 'DNS Servers|Current'
```

인터페이스에 10.0.150.2/24가 할당되고 기본 경로가 default via 10.0.150.1로 표시되면 설정이 정상 반영된 상태이다.

[이미지 삽입]

③ 확인

4.6.2 DEV-mint ③ 확인

개발 PC가 pfSense OPT1을 통해 DMZ 대역까지 정상적으로 도달하는지 L3 연결성과 L7 응답을 함께 확인한다.

1) 게이트웨이 도달성

```
ping -c 4 10.0.150.1
# 10.0.150.1 (pfSense OPT1) 응답 확인
```

2) DMZ 구간 도달성

pfSense 정책상 dev-net → dmz-net 방향 8080/TCP가 허용되어 있으므로 WAS(10.0.10.100)까지 ICMP 및 TCP 응답을 확인한다.

```
ping -c 4 10.0.10.100
curl -I http://10.0.10.100:8080/
```

기대되는 응답 헤더는 다음과 같다.

```
HTTP/1.1 200
Server: Apache-Coyote/1.1
Content-Type: text/html; charset=UTF-8
```

3) DNS / 외부 통신

외부 패키지 저장소 사용을 위해 DNS 정상 동작 여부도 함께 확인한다.

```
nslookup archive.ubuntu.com
ping -c 2 8.8.8.8
```

4) 점검 결과 요약 표

항목	명령	기대 결과
자기 IP	`ip -4 addr`	10.0.150.2/24
GW 도달	`ping 10.0.150.1`	0% loss
DMZ WAS L3	`ping 10.0.10.100`	0% loss
DMZ WAS L7	`curl -I http://10.0.10.100:8080/`	HTTP/1.1 200
DNS	`nslookup archive.ubuntu.com`	A 레코드 응답

위 다섯 항목이 모두 성공하면 dev-net ↔ dmz-net 구간 통신과 외부 인터넷 경로가 정상이며, DEV-mint는 개발팀 단말로 운영 가능한 상태이다.

[이미지 삽입]

4.6.3 kali_attacker (공격자 PC)

① 설치

4.6.3 kali_attacker ① 설치

route-att-net 대역에 위치한 외부 공격자 단말 kali_attacker를 구축한다. 이 VM은 VyOS 라우터 너머의 pfSense WAN(10.0.0.254)과 그 안쪽 DMZ에 노출된 서비스를 대상으로 침투/탐지 시나리오를 실행하는 용도이므로 풀버전 메타패키지를 설치한다.

1) VM 사양

항목	값
----	---

VM 이름	kali_attacker
OS	Kali Linux 2025.2 (Debian 12 base)
vCPU / RAM	2 vCPU / 4 GB
디스크	60 GB (thin)
NIC	route-att-net (vmxnet3)
호스트네임	kali

2) ISO 부팅 및 Graphical install

공식 사이트에서 받은 kali-linux-2025.2-installer-amd64.iso를 VM CD/DVD에 연결하고 부팅한다.
GRUB 메뉴에서 Graphical install을 선택한다.

3) 설치 마법사 진행

각 단계의 입력값은 다음 표와 같이 표준화한다.

단계	입력/선택값
Select a language	Korean - 한국어
위치 선택	대한민국
키맵	한국어
Hostname	kali
Domain name	(공란)
Full name	kali
Username	kali
Password	rhkswp1234

시간대	Asia/Seoul
Partition disks	Guided - use entire disk → All files in one partition
Write changes to disks	Yes
Software selection	Desktop environment: Xfce / Tools: kali-linux-default
GRUB	/dev/sda 에 설치

kali-linux-default 메타패키지는 Nmap, Metasploit, Burp Suite, Wireshark, Nikto, sqlmap 등 표준 공격 도구 셋을 포함하므로 별도 추가 설치 없이 시나리오 실습을 진행할 수 있다.

4) 첫 부팅 및 패키지 갱신

설치 완료 후 재부팅하고 kali / rhkswp1234로 로그인한다. 최신 시그니처/도구 반영을 위해 패키지 인덱스를 갱신한다.

```
sudo apt update
sudo apt -y full-upgrade
uname -a
cat /etc/os-release | grep PRETTY_NAME
# PRETTY_NAME="Kali GNU/Linux Rolling"
```

[이미지 삽입]

② 설정

4.6.3 kali_attacker ② 설정

Kali VM의 단일 NIC를 route-att-net에 고정 IP로 바인딩하여 VyOS 라우터(10.44.44.1)를 게이트웨이로 사용하도록 구성한다. Kali 2025.2는 기본적으로 NetworkManager가 활성화되어 있으므로 nmcli를 우선 사용한다.

1) IP 설계

항목	값
인터페이스	eth0
IPv4 주소	10.44.44.44/24
게이트웨이	10.44.44.1 (vyos-router)
DNS	8.8.8.8

2) NetworkManager(nmcli) 방식

새 연결 프로파일 attack을 생성하여 eth0에 부착한다.

```
sudo nmcli con add type ethernet con-name attack ifname eth0 \
    ip4 10.44.44.44/24 gw4 10.44.44.1
sudo nmcli con mod attack ipv4.dns "8.8.8.8" ipv4.method manual
sudo nmcli con mod attack connection.autoconnect yes
sudo nmcli con up attack
```

기존 자동 연결(Wired connection 1)이 있다면 충돌을 피하기 위해 비활성화한다.

```
sudo nmcli con down "Wired connection 1" 2>/dev/null
sudo nmcli con mod "Wired connection 1" connection.autoconnect no
```

3) /etc/network/interfaces 수동 방식(대안)

NetworkManager를 사용하지 않는 환경에서는 ifupdown으로 동일하게 구성할 수 있다.

```
sudo tee /etc/network/interfaces.d/eth0 > /dev/null <<'EOF'
```

```

        auto eth0
        iface eth0 inet static
        address 10.44.44.44
        netmask 255.255.255.0
        gateway 10.44.44.1
        dns-nameservers 8.8.8.8
        EOF
sudo systemctl restart networking

```

/etc/resolv.conf가 정적으로 관리되는 경우 다음 한 줄로 DNS를 보강한다.

```
echo "nameserver 8.8.8.8" | sudo tee /etc/resolv.conf
```

4) 적용 결과 점검

```

ip -4 addr show eth0
ip route
# default via 10.44.44.1 dev eth0
nmcli -t -f NAME,DEVICE,STATE con show --active

```

IP/게이트웨이/DNS가 위 표와 일치하면 공격자 단말의 네트워크 구성이 완료된 상태이다.

[이미지 삽입]

③ 확인

4.6.3 kali_attacker ③ 확인

Kali에서 VyOS → pfSense WAN까지의 경로가 정상인지, 그리고 공격 도구가 정상 작동하는지 단계 별로 검증한다.

1) 1-hop : VyOS 도달성

같은 L2 세그먼트인 VyOS 인터페이스에 대한 ICMP 응답을 확인한다.

```
ping -c 4 10.44.44.1
# 64 bytes from 10.44.44.1: icmp_seq=1 ttl=64 time=0.4 ms
```

2) 2-hop : pfSense WAN 도달성

VyOS의 라우팅 테이블을 거쳐 pfSense WAN(10.0.0.254)까지 도달하는지 확인한다.

```
ping -c 4 10.0.0.254
traceroute -n 10.0.0.254
# 1 10.44.44.1
# 2 10.0.0.254
```

2-hop 응답이 정상이라는 것은 VyOS의 정적 경로와 ICMP 허용 정책이 의도대로 동작한다는 의미이다.

3) 포트 스캐닝 동작 검증

DMZ에 노출된 WAF(10.0.10.2)에 대해 SYN 스캔을 수행하여 nmap이 정상 동작하는지, 그리고 외부 경계에서 80/443 노출이 의도와 일치하는지 확인한다.

```
sudo nmap -sS -p 80,443 10.0.10.2
```

기대 출력은 다음과 같은 형태이다.

```
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
```

4) 점검 결과 요약 표

항목	명령	기대 결과
자기 IP	`ip -4 addr show eth0`	10.44.44.44/24
기본 경로	`ip route`	default via 10.44.44.1
1-hop	`ping 10.44.44.1`	0% loss
2-hop	`ping 10.0.0.254`	0% loss
경로 추적	`traceroute -n 10.0.0.254`	10.44.44.1 → 10.0.0.254
공격 도구	`nmap -sS -p 80,443 10.0.10.2`	80/443 open

위 항목이 모두 통과하면 kali_attacker는 외부 공격자 시나리오(WAF 우회, WAS/DB 공격, IDS 탐지 유발)를 수행할 준비가 완료된 상태이다.

[이미지 삽입]

5. 티켓팅 웹 서비스 구축

관제 대상이 되는 티켓팅/예약 플랫폼의 구성과 배포 과정을 기술한다.

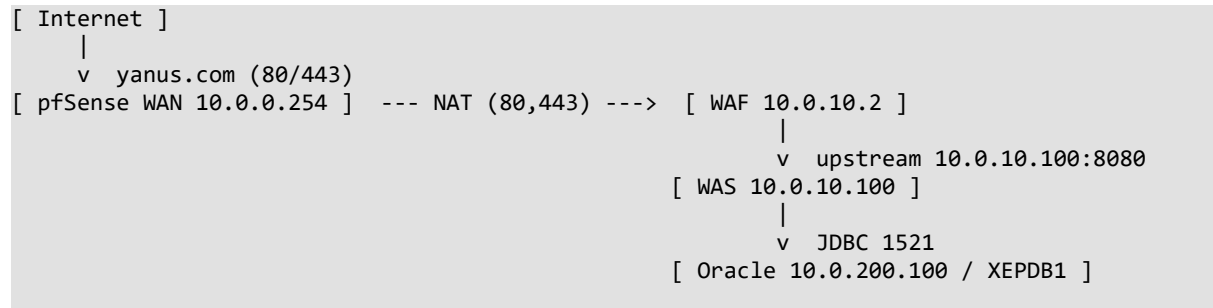
5.1 Web / WAS / DB 구성

본 절은 티켓팅 서비스의 3-tier 아키텍처를 정의하고, 외부 사용자 요청이 어떤 경로를 통해 애플리케이션과 데이터베이스에 도달하는지 설명한다. 모든 구간은 사설 대역으로 분리되어 있으며, 외부 공개 진입점은 pfSense WAN의 80/443 포트로 한정한다.

5.1.1 아키텍처 개요

외부 클라이언트는 도메인 `yanus.com`을 통해 진입하고, pfSense WAN에서 NAT 처리되어 DMZ 구간의 WAF로 전달된다. WAF는 nginx 리버스 프록시 앞단에서 ModSecurity로 검사한 후 정상

트래픽만 WAS로 전달하며, WAS는 비즈니스 로직을 처리하면서 내부망(INTRA)의 Oracle DB로 JDBC 호출을 수행한다.



5.1.2 계층별 사용 스택

계층	호스트	OS	구성 요소	버전 / 비교
Web (Reverse Proxy / WAF)	WAF (10.0.10.2)	Ubuntu 20.04 LTS	nginx + ModSecurity- nginx, libmodsecurity3, OWASP CRS	1.0.4 / 3.0.15
WAS	Ticketing platform (10.0.10.100)	Ubuntu 20.04 LTS	Tomcat 9, Spring MVC, MyBatis, ojdbc8	Tomcat 9.x, ojdbc8 21.5.0.0
DB	oracle-db (10.0.200.100)	Oracle Linux 8.10	Oracle Database XE	21c (CDB=XE, PDB=XEPDB1)
네트워크 경계	pfsense	FreeBSD 11	WAN/LAN/OPT NAT 및 정책 라우 팅	2.7.2

5.1.3 트래픽 경로 및 포트

출발지	도착지	프로토콜	포트	용도
Internet	pfSense WAN (10.0.0.254)	TCP	80, 443	공개 HTTP/HTTPS
pfSense WAN	WAF (10.0.10.2)	TCP	80, 443	NAT 포워딩
WAF (10.0.10.2)	WAS (10.0.10.100)	TCP	8080	nginx upstream → Tomcat

WAS (10.0.10.100)	Oracle (10.0.200.100)	TCP	1521	JDBC Thin
----------------------	--------------------------	-----	------	-----------

5.1.4 WAS 구성

Tomcat 9는 /home/was/tomcat 경로에 설치하며, 배포 산출물은 webapps/ROOT.war 형태로 배치하여 컨텍스트 패스를 /로 사용한다. Spring MVC 기반의 stu 프로젝트는 MyBatis를 통해 DAO 계층을 구성하고, JDBC 드라이버로 ojdbc8 21.5.0.0을 사용한다.

web.xml의 인코딩 필터는 다음과 같이 UTF-8을 강제하여 한글 콘서트명, 멤버명 등의 문자 깨짐을 방지한다.

```
<filter>
  <filter-name>characterEncodingFilter</filter-name>
  <filter-class>org.springframework.web.filter.CharacterEncodingFilter</filter-class>
  <init-param>
    <param-name>encoding</param-name>
    <param-value>UTF-8</param-value>
  </init-param>
  <init-param>
    <param-name>forceEncoding</param-name>
    <param-value>true</param-value>
  </init-param>
</filter>
<filter-mapping>
  <filter-name>characterEncodingFilter</filter-name>
  <url-pattern>/*</url-pattern>
</filter-mapping>
```

5.1.5 DB 연결 구성

DB 접근은 Oracle XE 21c의 PDB인 XEPDB1을 대상으로 한다. 애플리케이션 전용 계정은 ticket_app / ticket_app_2026을 사용한다.

```
# jdbc.properties
jdbc.driver=oracle.jdbc.OracleDriver
jdbc.url=jdbc:oracle:thin:@10.0.200.100:1521/XEPDB1
jdbc.username=ticket_app
jdbc.password=ticket_app_2026
```

5.1.6 도메인 모델 (14개 테이블)

티케팅 서비스의 데이터 모델은 회원, 콘서트, 좌석, 예매, 결제 영역으로 구분된 14개 테이블로 구성된다.

분류	테이블	설명
회원	members	일반 회원 정보 (BCrypt 해시 비밀번호)
회원	admins	관리자 계정 (admin / rhkswp1234)
콘서트	concerts	공연 메타 정보
콘서트	concert_schedules	회차/일정
콘서트	venues	공연장
좌석	seats	좌석 마스터
좌석	seat_grades	좌석 등급/가격
좌석	seat_holds	좌석 임시 점유
예매	reservations	예매 헤더
예매	reservation_items	예매 좌석 라인
결제	payments	결제 트랜잭션
결제	refunds	환불 내역
부가	notices	공지사항
부가	login_history	로그인 이력

5.1.7 MyBatis 매퍼

매퍼 XML은 src/main/resources/mapper/ 하위에 도메인별로 분리하여 배치하며, sqlSessionFactory가 클래스패스 스캐닝으로 로드한다.

```
<bean id="sqlSessionFactory" class="org.mybatis.spring.SqlSessionFactoryBean">
  <property name="dataSource" ref="dataSource"/>
  <property name="mapperLocations" value="classpath:mapper/**/*.xml"/>
  <property name="typeAliasesPackage" value="com.stu.vo"/>
</bean>
```

5.2 서비스 배포 및 동작 확인

본 절은 WAS(10.0.10.100)에 빌드 산출물을 배포하고 정상 동작 여부를 점검하는 절차를 기술한다. 모든 작업은 was 계정으로 수행한다.

5.2.1 빌드

프로젝트 루트에서 Maven 패키징을 수행하여 target/stu.war를 생성한다.

```
cd ~/stu
mvn clean package -DskipTests
ls -lh target/stu.war
```

빌드 결과물의 위치와 크기는 다음과 같이 확인한다.

항목	값
산출물	`target/stu.war`
컨텍스트	`/` (ROOT 배포)
패키징 형식	WAR (Servlet 3.1)

5.2.2 배포

Tomcat을 정지한 뒤 기존 ROOT 컨텍스트를 제거하고, 새 산출물을 ROOT.war로 복사한다. 디렉터리 권한은 was:was로 유지한다.

```
sudo systemctl stop tomcat

cd /home/was/tomcat/webapps
sudo rm -rf ROOT ROOT.war

sudo cp ~/stu/target/stu.war /home/was/tomcat/webapps/ROOT.war
sudo chown was:was /home/was/tomcat/webapps/ROOT.war

sudo systemctl start tomcat
sudo systemctl status tomcat --no-pager
```

기동 로그는 catalina.out에서 확인한다.


```
tail -f /home/was/tomcat/logs/catalina.out
```

5.2.3 동작 검증

로컬 루프백 기준으로 핵심 엔드포인트가 정상 응답하는지 확인한다.

검증 항목	요청	기대 결과
메인 페이지	`GET /main.do`	HTTP 200
콘서트 목록	`GET /concert/list.do`	200, 한글 (BTS / AURORA / 잠비나이) 정상 표시
관리자 로그인	`POST /loginAction.do` (admin / rhkswp1234)	302 Redirect + `JSESSIONID` Set-Cookie

메인 페이지

```
curl -s -o /dev/null -w "HTTP %{http_code}\n" http://localhost:8080/main.do
# HTTP 200
```

콘서트 목록 (한글 인코딩 확인)

```
curl -s http://localhost:8080/concert/list.do | grep -E "BTS|AURORA|잠비나이"
```

응답 본문에 BTS, AURORA, 잠비나이가 깨짐 없이 표시되면 CharacterEncodingFilter와 DB의 NLS 설정이 정상으로 연동된 것이다.

관리자 로그인 (세션 발급 확인)

```
curl -s -i -X POST \
-d "userId=admin&userPw=rhkswp1234" \
```

```
http://localhost:8080/loginAction.do
```

응답 헤더에서 다음 두 항목을 확인한다.

헤더	값
`HTTP/1.1`	`302 Found`
`Set-Cookie`	`JSESSIONID=...; Path=/; HttpOnly`

5.2.4 외부 진입 검증

WAF(10.0.10.2)와 pfSense NAT를 거친 외부 진입 경로도 함께 점검한다.

```
# WAF → WAS
curl -s -o /dev/null -w "HTTP %{http_code}\n" http://10.0.10.2/main.do

# 도메인 진입
curl -s -o /dev/null -w "HTTP %{http_code}\n" -H "Host: yanus.com" http://yanus.com/main.do
```

모든 단계에서 HTTP 200이 반환되어야 정상 배포가 완료된 것으로 간주한다.

6. 네트워크 및 방화벽 보안

외부 위협으로부터 서비스를 보호하기 위한 네트워크 보안 구성을 정리한다.

6.1 네트워크 분리 (세그멘테이션)

본 절은 ESXi 가상 스위치 기반의 네트워크 구간 분리 정책을 정의한다. 외부 공격면을 최소화하기 위해 공개 서비스 구간(DMZ)과 내부 데이터·관제 구간(INTRA)을 분리하고, 사용자 워크스테이션 구간(SOC/DEV)을 별도로 두어 직무 기반 접근 통제를 강제한다.

6.1.1 분리 원칙

- 모든 내부 구간은 RFC1918 사설 대역만 사용한다.

- 내부 포트그룹은 ESXi vSwitch 업링크를 0으로 설정하여 물리 NIC에서 직접 격리한다.
- 외부 진입은 vSwitch0(관리·외부)와 route-att-net만 허용한다.
- 구간 간 통신은 pfSense를 단일 게이트웨이로 강제하여 ACL과 NAT를 단일 지점에서 적용한다.
- 관제(SOC)와 개발(DEV)은 운영망(INTRA)과 별도의 세그먼트로 분리하여 PC 감염 시 측면 이동을 차단한다.

6.1.2 구간 정의

구간	대역	포트그룹	업링크	용도	대표 호스트
WAN (외부)	10.0.0.0/24	route-fw-net	0 (라우터 경유)	pfSense WAN, 외부 진입	pfSense WAN 10.0.0.254
공격자망	10.44.44.0/24	route-att-net	0	모의 공격 환경	kali_attacker 10.44.44.44
DMZ	10.0.10.0/24	dmz-net	0	공개 서비스 (WAF, WAS)	WAF 10.0.10.2, WAS 10.0.10.100
INTRA	10.0.200.0/24	intra-net	0	내부 데이터·관제	Oracle 10.0.200.100, Splunk 10.0.200.201, SecurityOnion 10.0.200.200
SOC	10.0.100.0/24	soc-net	0	관제 워크스테이션	SOC-mint 10.0.100.2
DEV	10.0.150.0/24	dev-net	0	개발 워크스테이션	DEV-mint 10.0.150.2
관리	192.168.126.0/24	vSwitch0	1 (물리)	ESXi 관리 / 라우터 업링크	ESXi 192.168.126.130

6.1.3 vSwitch 구성

ESXi 상에서 내부 포트그룹의 업링크를 제거하여 물리 네트워크와 격리된 가상 LAN을 구성한다.

vSwitch / 포트그룹	업링크	보안 정책	VLAN
vSwitch0 / Management Network	vmnic0	Promiscuous: Reject	0
route-att-net	(없음)	Promiscuous: Reject	0
route-fw-net	(없음)	Promiscuous: Reject	0
dmz-net	(없음)	Promiscuous: Reject	0
intra-net	(없음)	Promiscuous: Accept (IDS 미러 대상)	0
soc-net	(없음)	Promiscuous: Reject	0
dev-net	(없음)	Promiscuous: Reject	0

intra-net은 Security Onion이 미러링된 트래픽을 수집할 수 있도록 Promiscuous Mode를 Accept로 설정한다.

6.1.4 구간 간 데이터 흐름

구간 간 통신은 pfSense에서 명시적으로 허용된 흐름만 통과한다.

출발지	도착지	프로토콜	포트	용도	허용 여부
WAN	DMZ (WAF)	TCP	80, 443	공개 서비스 진입	허용 (NAT)
DMZ (WAF)	DMZ (WAS)	TCP	8080	리버스 프록시	허용
DMZ (WAS)	INTRA (Oracle)	TCP	1521	JDBC	허용
DMZ	INTRA (Splunk UF 수신)	TCP	9997	로그 포워딩	허용
INTRA (IDS/SIEM)	DMZ	-	-	미러 트래픽 수집	허용 (단방향 미러)
SOC	INTRA (Splunk Web)	TCP	8000	관제 콘솔	허용
SOC	INTRA (Oracle SQL*Plus)	TCP	1521	DBA 조회	허용
DEV	DMZ (WAS SSH/배포)	TCP	22, 8080	개발/배포	허용
DEV	INTRA	-	-	운영 DB 직결	차단

WAN	INTRA	-	-	외부 → 내부 직접	차단
WAN	SOC / DEV	-	-	외부 → 워크 스테이션	차단
INTRA	WAN	TCP	80, 443	업데이트(아웃 바운드)	허용

6.1.5 게이트웨이 매핑

각 세그먼트의 디폴트 게이트웨이는 pfSense의 해당 인터페이스로 지정한다.

구간	게이트웨이	pfSense 인터페이스
DMZ (10.0.10.0/24)	10.0.10.1	OPT2
INTRA (10.0.200.0/24)	10.0.200.1	OPT3
SOC (10.0.100.0/24)	10.0.100.1	LAN
DEV (10.0.150.0/24)	10.0.150.1	OPT1
WAN (10.0.0.0/24)	10.0.0.1 (VyOS)	WAN

이러한 분리 구조를 통해 외부 진입은 WAN→DMZ 경계에 집중되고, 데이터 자산(Oracle, Splunk)은 INTRA에 격납되어 직접적인 외부 접근이 불가능하다.

6.2 방화벽 정책

pfSense의 방화벽 룰은 각 인터페이스로 "들어오는(inbound)" 트래픽을 위에서 아래로 순차 평가하며, 가장 먼저 일치하는 룰이 적용된다. 명시적으로 허용(Pass)되지 않은 트래픽은 기본적으로 모두 차단(default deny)되므로, 필요한 통신만 인터페이스별로 허용하는 화이트리스트 방식으로 정책을 구성한다.

룰은 Firewall → Rules의 각 인터페이스(WAN / LAN / OPT1 / OPT2 / OPT3) 탭에서 생성하며, 반복 사용되는 호스트·네트워크·포트는 Firewall → Aliases에 별칭으로 등록해 룰을 간결하게 유지한다.

※ 사전 조건 – WAN의 사설망 차단 해제

pfSense는 기본적으로 WAN 인터페이스에서 사설 대역(RFC1918)과 Bogon을 차단한다. 본 환경은 WAN 측(route-fw-net)이 사설 IP(10.0.0.0/24)이므로, Interfaces → WAN에서 "Block private networks"와 "Block bogon networks" 체크를 반드시 해제해야 VyOS ↔ pfSense 라우팅이 정상 동작한다. (4.3.2의 Reserved Networks 해제와 동일 맥락)

구간(인터페이스) 요약

인터페이스	구간(포트그룹)	대역	주요 호스트
WAN	route-fw-net	10.0.0.0/24	VyOS(10.0.0.1), pfSense(10.0.0.254)
LAN (SOC)	soc-net	10.0.100.0/24	SOC-mint(10.0.100.2)
OPT1 (DEV)	dev-net	10.0.150.0/24	DEV-mint
OPT2 (DMZ)	dmz-net	10.0.10.0/24	WAF, Ticketing(WAS)
OPT3 (INTRA)	intra-net	10.0.200.0/24	oracle-db, splunk, security onion

아래 정책표의 호스트 IP는 5장에서 확정하는 값을 사용하며, 본 문서에서는 별칭 기준으로 표기한다. (예: WEB_SVR = DMZ 웹·WAS, DB_SVR = oracle-db:1521, SPLUNK = splunk:9997/8000, SOC_PC = SOC-mint)

인터페이스별 방화벽 정책

인터페이스	Action	Source	Destination	서비스(포트)	목적
WAN	Pass	any	WEB_SVR (DMZ)	TCP 80, 443	외부 사용자·공격 시뮬레이션의 웹/티켓팅 접속 허용
WAN	(기본)	any	any	—	그 외 인입 전면 차단. WAN에서 GUI/SSH 관리 접근은 절대 허용하지 않음
LAN (SOC)	Pass	SOC_PC	This Firewall	TCP 443, 22	관제팀의 pfSense 웹 GUI·SSH 관리
LAN (SOC)	Pass	SOC_PC	SPLUNK	TCP 8000	Splunk 웹 콘솔 접속
LAN (SOC)	Pass	SOC_PC	INTRA, DMZ 대역	any	관제·조사 목적 내부 접근 허용
LAN (SOC)	Pass	SOC_PC	any	TCP 80, 443	업데이트·외부 조회
OPT1 (DEV)	Pass	DEV_PC	WEB_SVR (DMZ)	TCP 80,443,8080	개발·테스트 접근
OPT1 (DEV)	Block	DEV_PC	SOC 대역 (10.0.100.0/24)	any	개발망 → 관제망 접근 차단
OPT1 (DEV)	Pass	DEV_PC	any	TCP 80, 443	패키지 다운로드 등 외부 접근

인터페이스	Action	Source	Destination	서비스(포트)	목적
OPT2 (DMZ)	Pass	WEB_SVR(WAS)	DB_SVR (INTRA)	TCP 1521	애플리케이션 → Oracle DB 접속
OPT2 (DMZ)	Pass	DMZ 호스트	SPLUNK (INTRA)	TCP 9997	Universal Forwarder 로그 전송
OPT2 (DMZ)	Block	DMZ 대역	SOC, DEV 대역	any	DMZ 침해 시 내부 측면 이동(lateral) 차단 — 핵심
OPT2 (DMZ)	(기본)	DMZ 대역	any	—	그 외 내부 임의 접근 차단(외부 업데이트는 필요 시 한정 허용)
OPT3 (INTRA)	Pass	SPLUNK	any	TCP 80, 443	Splunk 업데이트·위협 인텔(선택)
OPT3 (INTRA)	Block	INTRA 대역	DMZ 대역	any	내부 → DMZ 역방향 불필요 접근 차단
OPT3 (INTRA)	(기본)	INTRA 대역	any	—	oracle-db 등은 능동 아웃바운드 불필요 → 기본 차단

각 룰 편집 화면에서 "Log packets that are handled by this rule"를 활성화하면 Status → System Logs → Firewall에 기록된다. 이 방화벽 로그는 7장에서 Splunk로 전송하고, 9장에서 비정상 접근·스캔 탐지 SPL과 대시보드의 입력으로 활용한다.

6.3 IDS/IPS (pfSense Snort)

경계 지점인 pfSense에 Snort를 설치하여 시그니처 기반 침입 탐지·차단을 수행한다. DMZ 미리 트래픽을 심층 분석하는 Security Onion(Suricata)과 역할을 명확히 구분한다: Snort는 경계 유입(WAN·DMZ) 트래픽에 대한 인라인 탐지·차단을 담당하고, Security Onion(Suricata)은 dmz-net 미리 기반의 심층 분석을 담당한다. 두 엔진의 적용 지점을 분리하여 룰 중복·상충과 불필요한 자원 소모를 방지한다.

① 설치

System → Package Manager → Available Packages에서 "snort" 검색 → Install → Confirm
설치 완료 후 Services → Snort 메뉴가 생성되었는지 확인

② 설정 - 룰 소스(Global Settings)

Services → Snort → Global Settings에서 사용할 룰 소스를 활성화한다.

룰 소스	비용/조건	권장
Snort Subscriber Rules (VRT)	무료 등록 시 Oinkcode 필요(등록 사용자, 30일 지연)	계정 있으면 사용
Snort GPLv2 Community Rules	무료, 등록 불필요	활성화
Emerging Threats (ET) Open	무료, 등록 불필요	활성화(우선)

ET Open과 Snort GPLv2 Community를 활성화하고(구독 코드가 있으면 Oinkmaster code 입력 후 VRT도 활성화), Rules Update Interval을 1 day로 설정한 뒤 Save → Updates 탭 → Update Rules로 최초 룰셋을 내려받는다.

② 설정 - 인터페이스 적용

Services → Snort → Snort Interfaces → Add로 탐지 대상 인터페이스를 추가한다. 외부 유입 탐지를 위해 WAN, 공개 서비스 보호를 위해 OPT2(DMZ)를 권장한다.

- Enable / Description 지정, Send Alerts to System Log 체크(Splunk 연동 시 유리)
- Search Method: AC-BNFA (메모리 효율) 선택
- Block Offenders 체크 시 IPS 동작 — 탐지된 공격 IP를 pf 테이블에 등록해 차단 / Which IP to Block: BOTH(또는 SRC) / Kill states 체크
- 초기에는 Block Offenders를 끈 탐지(IDS) 모드로 운영하며 오탐을 튜닝한 뒤, 안정화되면 차단(IPS) 모드로 전환 권장

② 설정 - 룰 카테고리 / 변수

Categories 탭: 간편 구성은 "Use IPS Policy" → Policy를 Connectivity / Balanced / Security / Max-Detect 중 선택(초기 Balanced 권장). 수동 구성 시 웹 서비스 환경 특성상 web-application, sql-injection, exploit, scan, policy 관련 카테고리를 우선 활성화한다.

Variables(HOME_NET / EXTERNAL_NET): HOME_NET을 내부 대역(정의한 세그먼트 또는 10.0.0.0/8)으로, EXTERNAL_NET을 !HOME_NET으로 설정하면 오탐을 크게 줄일 수 있다.

③ 확인

Snort Interfaces 탭에서 해당 인터페이스 좌측 ▶(Start) 클릭 → 상태 아이콘이 녹색이면 정상 기동

kali_attacker에서 nmap 포트스캔·sqlmap 등을 실행한 뒤 Alerts 탭에 탐지 이벤트가 기록되는지, Block Offenders 사용 시 Blocked 탭에 차단 IP가 올라오는지 검증

※ 운영 주의사항 / 로그 연계

Snort는 룰 로딩 시 메모리 사용량이 크다. pfSense VM(2GB)에서는 카테고리를 과다 선택

하면 메모리가 부족할 수 있으므로 필요한 카테고리만 활성화한다.

Snort alert 로그는 7장에서 Splunk로 전송(syslog 또는 Universal Forwarder)하고, 9장에서 시그니처 기반 탐지 룰(SPL)-대시보드와 연계한다.

6.4 콘텐츠 필터링 / 프록시 (pfSense SquidGuard)

SquidGuard는 Squid 프록시 위에서 동작하는 URL 필터로, 본 환경에서는 외부 인입 방어가 아니라 "내부 사용자가 외부로 나가는" 웹 접근을 통제하는 용도로 사용한다. 즉 SOC·DEV PC 등 내부 구간(LAN / OPT1)에서의 비인가·악성 사이트 접근을 카테고리·블랙리스트 기준으로 차단하고, 정책 위반 접근 로그를 확보해 내부 통제·감사에 활용한다. DMZ 서버 구간에는 적용하지 않는다.

① 설치 (Squid → SquidGuard 순서)

System → Package Manager → Available Packages에서 "squid" Install

이어서 "squidGuard" Install (Squid 설치가 선행되어야 함)

설치 후 Services에 Squid Proxy Server, SquidGuard Proxy Filter 메뉴 생성 확인

② 설정 – Squid 프록시

Services → Squid Proxy Server → Local Cache 탭: 캐시 크기 등은 기본값으로 먼저 Save(저장해야 General 활성화 가능)

General 탭: Enable Squid Proxy 체크, Proxy Interface로 내부망 인터페이스(LAN/OPT1) 선택, Save

Transparent HTTP Proxy를 체크하고 대상 인터페이스를 지정하면 클라이언트의 프록시 설정 없이 80번 포트를 가로챈다. 단, HTTPS(443)는 투명 가로채기가 불가능하여 SSL/MITM(CA 인증서 배포)이 필요하므로, 실습 범위에서는 HTTP 위주로 운영하거나 SSL Filtering을 별도 구성한다.

② 설정 – SquidGuard 필터

Services → SquidGuard Proxy Filter → General Settings: Enable 체크, Blacklist 옵션 활성화 후 Blacklist URL(공개 블랙리스트 아카이브 주소) 입력 → Save

Blacklist 탭: Download 실행 → 블랙리스트 다운로드·적용

Target Categories: 사내 금지 도메인 등 커스텀 카테고리 생성(선택)

Common ACL 탭: Target Rules List에서 카테고리별 access를 allow / deny / whitelist로 설정하고 Default access를 결정

- 화이트리스트 방식: Default access = deny + 허용 도메인만 allow (통제 강함)

- 블랙리스트 방식: Default access = allow + 특정 카테고리만 deny (운영 편의)

설정 변경 후 General Settings에서 Apply를 눌러야 적용된다(SquidGuard는 Squid의 redirector로 연계되어 동작)

③ 확인

내부 PC(SOC/DEV)에서 차단 카테고리에 속한 사이트 접속 시 차단 페이지가 표시되는지 확인

정상 사이트는 프록시를 경유해 접속되는지, Squid access.log에 기록이 남는지 확인

※ 운영 주의사항 / 로그 연계

HTTPS 트래픽은 SSL MITM을 적용하지 않으면 도메인(SNI) 기반의 부분 제어만 가능하다. 캐시·블랙리스트로 디스크·메모리 사용이 늘어나므로 pfSense VM 자원을 고려한다.

Squid access 로그·SquidGuard 차단 로그는 7장에서 Splunk로 전송하고, 9장에서 내부 비인가 접근·정책 위반 탐지에 활용한다.

6.5 WAF 및 웹 보안

본 절은 DMZ 경계의 WAF(10.0.10.2)에 적용된 웹 애플리케이션 방어 정책을 설명한다. nginx 리버스 프록시 앞단에 ModSecurity-nginx 커넥터를 결합하고, OWASP CRS(Core Rule Set)를 탑재하여 OWASP Top 10을 차단한다.

6.5.1 구성 요소

구성	버전	경로
nginx	1.18+ (Ubuntu 20.04)	`/etc/nginx/`
ModSecurity-nginx 커넥터	v1.0.4	`/usr/share/nginx/modules/nginx_http_modsecurity_module.so`
libmodsecurity3	v3.0.15	`/usr/local/modsecurity/lib/`
OWASP CRS	3.x	`/etc/nginx/modsec/coreruleset/`
메인 룰 진입점	-	`/etc/nginx/modsec/main.conf`
감사 로그	-	`/var/log/modsec_audit.log`

6.5.2 동작 모드

ModSecurity는 Anomaly Scoring 방식으로 동작한다. 각 룰은 위반 시 점수를 누적하고, 임계값을 초과하면 차단한다. Paranoia Level은 운영 초기 단계에서 오탐을 최소화하기 위해 PL1로 설정한다.

항목	값	설명
`SecRuleEngine`	On	차단 모드 (DetectionOnly 아님)
`SecRequestBodyAccess`	On	요청 본문 검사 활성화
`SecResponseBodyAccess`	On	응답 본문 검사 활성화 (text/html, application/json)
`tx.paranoia_level`	1	표준 룰만 활성화
`tx.inbound_anomaly_score_threshold`	5	인바운드 차단 임계
`tx.outbound_anomaly_score_threshold`	4	아웃바운드 차단 임계
`SecAuditEngine`	RelevantOnly	차단/경고 트랜잭션만 기록
`SecAuditLog`	`/var/log/modsec_audit.log`	감사 로그 경로

6.5.3 적용 룰셋

OWASP CRS의 핵심 룰셋을 활성화하여 주요 웹 공격을 차단한다.

룰 파일	차단 대상	매핑 OWASP Top 10
REQUEST-901-INITIALIZATION	변수 초기화, 상태 머신	-
REQUEST-905-COMMON-EXCEPTIONS	일반 예외 처리	-
REQUEST-920-PROTOCOL-ENFORCEMENT	HTTP 프로토콜 위반	A05 보안 설정 오류
REQUEST-930-APPLICATION-ATTACK-LFI	Local File Inclusion	A03 인젝션
REQUEST-931-APPLICATION-ATTACK-RFI	Remote File Inclusion	A03 인젝션
REQUEST-932-APPLICATION-ATTACK-RCE	원격 코드 실행 (944 보강)	A03 인젝션
REQUEST-941-APPLICATION-ATTACK-XSS	Cross-Site Scripting	A03 인젝션
REQUEST-942-APPLICATION-ATTACK-SQLI	SQL Injection	A03 인젝션

REQUEST-943-APPLICATION-ATTACK-SESSION-FIXATION	세션 고정 공격	A07 인증·세션
REQUEST-944-APPLICATION-ATTACK-JAVA	Java 기반 RCE / Deserialization	A08 무결성
RESPONSE-950~959	데이터 유출, 에러 누설	A04 안전하지 않은 설계

6.5.4 nginx 통합 설정

nginx에서 ModSecurity 모듈을 로드하고, 가상 호스트 단위로 룰을 활성화한다. upstream으로는 WAS(10.0.10.100:8080)를 지정한다.

```
# /etc/nginx/nginx.conf 상단
load_module modules/nginx_http_modsecurity_module.so;

# /etc/nginx/sites-available/yanus.com
upstream tomcat_was {
    server 10.0.10.100:8080;
    keepalive 32;
}

server {
    listen 80;
    server_name yanus.com;

    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;

    location / {
        proxy_pass          http://tomcat_was;
        proxy_http_version 1.1;
        proxy_set_header    Host          $host;
        proxy_set_header    X-Real-IP     $remote_addr;
        proxy_set_header    X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header    X-Forwarded-Proto $scheme;
        proxy_read_timeout  60s;
    }
}
```

/etc/nginx/modsec/main.conf는 ModSecurity 기본 설정과 CRS를 순서대로 포함한다.

```
Include /etc/nginx/modsec/modsecurity.conf
Include /etc/nginx/modsec/coreruleset/crs-setup.conf
Include /etc/nginx/modsec/coreruleset/rules/*.conf
```

6.5.5 화이트리스트 (False Positive 완화)

관리자 페이지와 같이 정당한 사유로 CRS 룰에 걸리는 요청은 before 단계 룰 파일(REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf)에 화이트리스트를 추가하여 운영 영향을 제거한다.

```
# /etc/nginx/modsec/coreruleset/rules/REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf

# 관리자 페이지: 콘서트 등록 시 HTML 에디터 본문이 XSS 룰 941에 걸리는 경우
SecRule REQUEST_URI "@beginsWith /admin/concert/save.do" \
    "id:1000001,phase:1,pass,nolog,\
    ctl:ruleRemoveTargetById=941100;ARGS:content,\
    ctl:ruleRemoveTargetById=941160;ARGS:content"

# 관리자 로그인: 일부 파라미터가 SQLi 룰 942에 오탐되는 경우
SecRule REQUEST_URI "@streq /loginAction.do" \
    "id:1000002,phase:1,pass,nolog,\
    ctl:ruleRemoveTargetById=942100;ARGS:userPw"
```

6.5.6 로깅 및 모니터링

감사 로그는 JSON 또는 Serial 포맷으로 적재하며, Splunk Universal Forwarder를 통해 SIEM(10.0.200.201)으로 전달한다.

로그	경로	용도
ModSecurity Audit	`/var/log/modsec_audit.log`	차단/경고 트랜잭션 상세
nginx access	`/var/log/nginx/access.log`	요청 통계
nginx error	`/var/log/nginx/error.log`	nginx/ModSecurity 동작 오류

6.5.7 검증

간단한 페이로드를 룰 동작을 점검한다.

```
# 942 SQLi 차단 확인 (403 기대)
curl -s -o /dev/null -w "HTTP %{http_code}\n" \
    "http://yanus.com/concert/list.do?id=1' OR '1'='1"

# 941 XSS 차단 확인 (403 기대)
curl -s -o /dev/null -w "HTTP %{http_code}\n" \
```

```
--data-urlencode "q=<script>alert(1)</script>" \
http://yanus.com/search.do

# 정상 요청 (200 기대)
curl -s -o /dev/null -w "HTTP %{http_code}\n" http://yanus.com/main.do
```

공격 페이로드에 대해 HTTP 403이 반환되고 /var/log/modsec_audit.log에 해당 룰 ID(941xxx, 942xxx)가 기록되면 WAF가 정상 동작하는 것이다.

7. 로그 수집 및 전송 체계

관제의 기반이 되는 로그를 어디서, 어떻게 모아 Splunk로 보낼지 정의한다.

7.1 수집 대상 로그

- 웹/WAS 접근 로그, 애플리케이션 로그
- OS / 인증 / 시스템 로그
- 방화벽·WAF·보안 장비 로그

7.2 로그 전송 구조

각 보안 장비 및 서버에서 발생하는 로그는 SIEM 서버(splunk VM, 10.0.200.201)로 집중 수집한다. 수집 방식은 두 가지로 구분한다.

- Linux 계열 서버(WAF, WAS, IDS, DB): Splunk Universal Forwarder(UF) 10.4.0을 설치하여 TCP 9997 포트로 전송한다.

- pfSense 방화벽: 자체 syslog 기능을 통해 UDP 514 포트로 원격 전송한다.

7.2.1 전송 대상 및 인덱스 매핑

발생 서버	로그 경로	sourcetype	index	전송 방식
WAF (10.0.10.2)	/var/log/nginx/access.log	waf_access	waf	UF → 9997
WAF (10.0.10.2)	/var/log/nginx/error.log	waf_error	waf	UF → 9997
WAF (10.0.10.2)	/var/log/modsec	waf_audit	waf	UF → 9997

	_audit.log`			
WAS (10.0.10.100)	`/home/was/tomcat/logs/catalina.out`	`was_app`	`was_app`	UF → 9997
WAS (10.0.10.100)	`/home/was/tomcat/logs/localhost_access_log.*.txt`	`was_access`	`web_log`	UF → 9997
Security Onion (10.0.200.200)	`/var/log/snort/alert`	`snort_alert`	`snort`	UF → 9997
Security Onion (10.0.200.200)	`/nsm/server_data/securityonion/logs/suricata/eve.json`	`suricata_eve`	`suricata`	UF → 9997
Oracle DB (10.0.200.100)	`/opt/oracle/admin/XE/adump/*.aud`	`oracle_audit`	`oracle_audit`	UF → 9997
전 리눅스 VM	`/var/log/auth.log`	`linux_secure`	`auth`	UF → 9997
pfSense (10.0.10.1 등)	filterlog	`pfsense:filterlog`	`pfsense`	Syslog → 514

7.2.2 Universal Forwarder 설치 (WAF 예시)

UF 패키지는 /opt/splunkforwarder 경로에 설치하며, 동일한 절차를 WAS · IDS · DB · 기타 서버에 반복 수행한다.

```
# 1) 패키지 설치
sudo dpkg -i splunkforwarder-10.4.0-linux-amd64.deb
sudo /opt/splunkforwarder/bin/splunk start --accept-license --answer-yes \
  --seed-passwd rhkswp1234

# 2) 부팅 시 자동 시작
sudo /opt/splunkforwarder/bin/splunk enable boot-start -user splunk

# 3) 인덱서 등록
sudo /opt/splunkforwarder/bin/splunk add forward-server 10.0.200.201:9997 \
  -auth admin:rhkswp1234
```

7.2.3 outputs.conf

수집된 데이터를 SIEM 서버로 보내는 출력 설정이다. 경로는 /opt/splunkforwarder/etc/system/local/outputs.conf이다.

```
[tcpout]
defaultGroup = soc_indexer

[tcpout:soc_indexer]
server = 10.0.200.201:9997
useACK = true

[tcpout-server://10.0.200.201:9997]
```

7.2.4 inputs.conf

파일 모니터링 대상을 정의한다. 경로는 /opt/splunkforwarder/etc/system/local/inputs.conf이며, 서버 역할별로 아래 블록을 분리 적용한다.

```
# WAF (nginx + ModSecurity)
[monitor:///var/log/nginx/access.log]
index = waf
sourcetype = waf_access

[monitor:///var/log/nginx/error.log]
index = waf
sourcetype = waf_error

[monitor:///var/log/modsec_audit.log]
index = waf
sourcetype = waf_audit

# WAS (Tomcat)
[monitor:///home/was/tomcat/logs/catalina.out]
index = was_app
sourcetype = was_app

[monitor:///home/was/tomcat/logs/localhost_access_log.*.txt]
index = web_log
sourcetype = was_access

# Security Onion (Snort)
[monitor:///var/log/snort/alert]
index = snort
sourcetype = snort_alert

# 공통 인증 로그
[monitor:///var/log/auth.log]
index = auth
sourcetype = linux_secure
```


설정 적용은 다음과 같이 수행한다.

```
sudo /opt/splunkforwarder/bin/splunk restart
sudo /opt/splunkforwarder/bin/splunk list forward-server -auth admin:rhkswp1234
```

7.2.5 pfSense Remote Logging

pfSense는 자체 GUI에서 원격 syslog를 활성화한다. 경로는 다음과 같다.

Status → System Logs → Settings → Remote Logging Options

항목	값
Enable Remote Logging	체크
Source Address	OPT3 (intra)
IP Protocol	IPv4
Remote log servers	`10.0.200.201:514`
Remote Syslog Contents	Firewall events, System events, DHCP events

Splunk 측에서는 UDP 514 입력을 별도 인덱스(pfsense)로 수신하도록 구성한다.

7.2.6 props.conf / transforms.conf

인덱서 측 /opt/splunk/etc/system/local/props.conf에 시간 파싱 규칙을 정의한다.

```
[waf_audit]
TIME_PREFIX = \[
TIME_FORMAT = %d/%b/%Y:%H:%M:%S %z
MAX_TIMESTAMP_LOOKAHEAD = 30
SHOULD_LINEMERGE = false
TRANSFORMS-waf = waf_extract_attack

[snort_alert]
TIME_PREFIX = ^
TIME_FORMAT = %m/%d-%H:%M:%S.%6N
SHOULD_LINEMERGE = false
```

```
[pfsense:filterlog]
TIME_FORMAT = %b %d %H:%M:%S
SHOULD_LINEMERGE = false
```

/opt/splunk/etc/system/local/transforms.conf에서 필드를 추출한다.

```
[waf_extract_attack]
REGEX = \[id\s"(?<rule_id>\d+)\".*\[msg\s"(?<attack_msg>[^\"]+)\"]
FORMAT = rule_id::$1 attack_msg::$2

[pfsense_filterlog]
REGEX = filterlog:\s\d+,,(?<rule>\d+),\S+,\d+,\S+,(?<action>pass|block),
FORMAT = rule::$1 action::$2
```

설정 변경 후 인덱서에서 splunk restart를 수행하면 sourcetype별 필드 추출이 적용된다.

8. Splunk 구축 및 연동

로그를 적재·검색·시각화하는 Splunk 환경 구축과 데이터 연동을 다룬다.

8.1 Splunk 설치 및 기본 구성

SIEM 서버는 내부 관제 세그먼트(intra-net)에 위치한 splunk VM(Ubuntu 20.04 LTS, 10.0.200.201)에 구축한다. Splunk Enterprise 10.4.0 .deb 패키지를 사용하며, 설치 경로는 /opt/splunk이다.

8.1.1 설치

```
# 패키지 설치
sudo dpkg -i splunk-10.4.0-linux-amd64.deb

# 첫 실행 (라이선스 동의 + admin 계정 시드)
sudo /opt/splunk/bin/splunk start --accept-license --answer-yes \
  --seed-passwd rhkswp1234

# systemd 자동 시작 등록
sudo /opt/splunk/bin/splunk enable boot-start -user splunk -systemd-managed 1
sudo systemctl status Splunkd
```

초기 관리자 계정은 다음과 같다.

항목	값
관리자 ID	`admin`
비밀번호	`rhkswp1234`
웹 접속 URL	`http://10.0.200.201:8000`

8.1.2 라이선스 전환

기본 설치 시 60일 Enterprise 평가 라이선스가 활성화된다. 본 환경은 학습·실습 목적이므로 평가 기간 만료 후 Free 라이선스(500MB/day) 로 전환한다.

전환 경로는 다음과 같다.

Settings → Licensing → Change license group → Free license → Save

전환 이후 인증·역할 기능 일부가 비활성화되지만, 단일 인스턴스 운영 및 인덱싱에는 영향을 미치지 않는다.

8.1.3 포트 정리

Splunk가 사용하는 포트를 정리하면 다음과 같다.

포트	용도	설정 위치
8000/tcp	Splunk Web UI	`web.conf [settings] httpport`
8089/tcp	관리(REST/CLI)	`server.conf [httpServer] mgmtHostPort`
9997/tcp	UF 데이터 수신	`inputs.conf [splunktcp://9997]`
514/udp	pfSense syslog 수신	`inputs.conf [udp://514]`

수신 포트는 GUI에서 다음 경로로 활성화한다.

Settings → Forwarding and receiving → Configure receiving → New Receiving Port → 9997

CLI 명령어로도 동일하게 구성 가능하다.

```
sudo /opt/splunk/bin/splunk enable listen 9997 -auth admin:rhkswp1234
sudo /opt/splunk/bin/splunk add udp 514 -sourcetype pfsense:filterlog \
  -index pfsense -auth admin:rhkswp1234
```

8.1.4 인덱스 생성

로그 종류별로 분리된 인덱스를 생성하여 수집·보존·검색 정책을 독립적으로 관리한다.

인덱스명	수집 대상	보존 기간
`web_log`	Tomcat access log	30일
`was_app`	Tomcat application log (catalina.out)	30일
`waf`	nginx + ModSecurity audit	60일
`pfsense`	pfSense filterlog (UDP 514)	30일
`snort`	Snort alert	60일
`suricata`	Suricata eve.json	60일
`oracle_audit`	Oracle XE 감사로그	90일
`auth`	Linux `/var/log/auth.log`	30일

인덱스 생성은 GUI(Settings → Indexes → New Index)에서 수행하거나, indexes.conf를 직접 편집한다.

```
# /opt/splunk/etc/system/local/indexes.conf
[waf]
homePath    = $SPLUNK_DB/waf/db
coldPath    = $SPLUNK_DB/waf/colddb
thawedPath  = $SPLUNK_DB/waf/thaweddb
frozenTimePeriodInSecs = 5184000

[pfsense]
homePath    = $SPLUNK_DB/pfsense/db
coldPath    = $SPLUNK_DB/pfsense/colddb
thawedPath  = $SPLUNK_DB/pfsense/thaweddb
```

```
frozenTimePeriodInSecs = 2592000
```

설정 적용 후 다음과 같이 재시작한다.

```
sudo /opt/splunk/bin/splunk restart
```

8.2 데이터 입력 (Index / Sourcetype)

인덱스 정의가 완료되면 외부에서 들어오는 로그를 올바른 sourcetype으로 파싱하여 해당 인덱스에 적재되도록 입력(Input) 설정을 구성한다.

8.2.1 수신 입력 활성화

웹 콘솔(<http://10.0.200.201:8000>)에서 아래 경로로 진입한다.

Settings → Data inputs

입력 종류	포트	사용 목적
TCP	9997	Universal Forwarder 데이터 수신
UDP	514	pfSense syslog 수신
Files & Directories	-	로컬 테스트 로그 수집

TCP 9997 입력은 Forwarded inputs에서 Receiving Port로 등록되고, UDP 514 입력은 UDP → New Local UDP에서 다음과 같이 설정한다.

항목	값
Port	514
Source name override	`pfsense`
Source type	`pfsense:filterlog`
Index	`pfsense`

8.2.2 sourcetype ↔ index 매핑

수집되는 로그는 sourcetype 단위로 파싱 규칙이 적용되며, 인덱스와 1:N 관계로 매핑된다.

sourcetype	발생 서버	index	비고
`waf_access`	WAF (10.0.10.2)	`waf`	nginx access log
`waf_error`	WAF	`waf`	nginx error log
`waf_audit`	WAF	`waf`	ModSecurity audit
`was_access`	WAS (10.0.10.100)	`web_log`	Tomcat access
`was_app`	WAS	`was_app`	Tomcat application
`snort_alert`	Security Onion	`snort`	Snort alert
`suricata_eve`	Security Onion	`suricata`	Suricata JSON
`pfsense:filterlog`	pfSense	`pfsense`	filterlog syslog
`oracle_audit`	oracle-db (10.0.200.100)	`oracle_audit`	Oracle .aud
`linux_secure`	전 리눅스 VM	`auth`	/var/log/auth.log

8.2.3 props.conf — 시간·라인 파싱

sourcetype별로 타임스탬프 위치, 라인 병합 여부 등을 정의한다. 경로는 /opt/splunk/etc/system/local/props.conf이다.

```
[waf_access]
TIME_PREFIX = \[
TIME_FORMAT = %d/%b/%Y:%H:%M:%S %z
MAX_TIMESTAMP_LOOKAHEAD = 30
SHOULD_LINEMERGE = false
TRANSFORMS-waf = waf_access_fields

[waf_audit]
TIME_PREFIX = \[
TIME_FORMAT = %d/%b/%Y:%H:%M:%S %z
MAX_TIMESTAMP_LOOKAHEAD = 30
SHOULD_LINEMERGE = false
TRANSFORMS-waf = waf_audit_fields

[was_app]
TIME_PREFIX = ^
TIME_FORMAT = %d-%b-%Y %H:%M:%S.%3N
SHOULD_LINEMERGE = true
BREAK_ONLY_BEFORE = ^\d{2}-\w{3}-\d{4}

[pfsense:filterlog]
TIME_FORMAT = %b %d %H:%M:%S
```

```

SHOULD_LINEMERGE = false
TRANSFORMS-pf = pf_filterlog_fields

[snort_alert]
TIME_PREFIX = ^
TIME_FORMAT = %m/%d-%H:%M:%S.%6N
SHOULD_LINEMERGE = false
TRANSFORMS-snort = snort_alert_fields

[linux_secure]
TIME_FORMAT = %b %d %H:%M:%S
SHOULD_LINEMERGE = false
TRANSFORMS-auth = auth_fail_fields

```

8.2.4 transforms.conf — 필드 추출

공격 분류·차단 액션·소스 IP 등 분석에 필수적인 필드를 정규식으로 추출한다. 경로는 /opt/splunk/etc/system/local/transforms.conf이다.

```

[waf_access_fields]
REGEX =
^(?<src_ip>\S+)\s\S+\s\S+\s\S+\[ [^\]]+\]\s"(?<method>\S+)\s(?<uri>\S+)\s\S+"\s(?<status>\d+)\s(?<bytes>\d+)

[waf_audit_fields]
REGEX = \[id\s"(?<rule_id>\d+)"\].*?\[msg\s"(?<attack_msg>[^\"]+)\]\. *?\[tag\s"attack-(?<attack_category>[A-Za-z0-9_-]+)"\]
FORMAT = rule_id::$1 attack_msg::$2 attack_category::$3

[pf_filterlog_fields]
REGEX =
filterlog:\s\d+, , (?<rule>\d+), \S+, \d+, \S+, (?<action>pass|block), \d+, \S+, \d+, \S+, \S+, \S+, \S+, \S+, (?<src_ip>\d+\.\d+\.\d+\.\d+), (?<dest_ip>\d+\.\d+\.\d+\.\d+), (?<src_port>\d+), (?<dest_port>\d+)

[snort_alert_fields]
REGEX =
\[ \* \* \] \s [ \d+ : ( ? < sid > \d+ ) : \d+ \] \s ( ? < alert_msg > [ ^ \[ ] + ) . * ? \{ ( ? < proto > \w+ ) \} \s ( ? < src_ip > \d+ \. \d+ \. \d+ \. \d+ ) : ( ? < src_port > \d+ ) \s - > \s ( ? < dest_ip > \d+ \. \d+ \. \d+ \. \d+ ) : ( ? < dest_port > \d+ )

[auth_fail_fields]
REGEX = Failed password for (invalid user\s)?(?<user>\S+) from (?<src_ip>\d+\.\d+\.\d+\.\d+)
FORMAT = result::FAIL user::$2 src_ip::$3

```

8.2.5 입력 검증

설정 반영 후 splunk restart를 수행하고 다음 SPL로 적재 상태를 확인한다.

```
| metadata type=sourcetypes index=*
| eval lastTime=strftime(lastTime,"%Y-%m-%d %H:%M:%S")
| table sourcetype totalCount lastTime
```

모든 sourcetype의 lastTime이 현재 시각 근방으로 유지되면 입력이 정상 동작한다.

8.3 대시보드 구성

관제팀(SOC-mint, 10.0.100.2)이 단일 화면으로 전 구간 보안 이벤트를 조망할 수 있도록 SOC 통합 대시보드를 Simple XML 기반으로 구성한다. 대시보드는 상단의 Device 배너 탭(WAF / pfSense / IDS / WAS / DB) 과 그 아래의 Attack-type 서브탭(SQLi / XSS / BruteForce / Scan) 으로 이원화한다.

8.3.1 검색 매크로 정의

동일한 검색 패턴이 여러 패널에서 반복되므로 매크로(macros.conf)를 활용한다.

```
# /opt/splunk/etc/system/local/macros.conf
[soc_base]
definition = index=waf OR index=pfsense OR index=snort OR index=auth OR index=was_app
iseval = 0

[soc_attack_waf]
definition = index=waf sourcetype=waf_audit attack_category=*
iseval = 0

[soc_block_pf]
definition = index=pfsense action=block
iseval = 0
```

8.3.2 핵심 패널

#	패널명	인덱스	시각화
1	Top 10 공격 IP (SQLi+XSS)	`waf`	Bar chart
2	차단/탐지 추이 (시간 대별)	`waf`, `pfsense`, `snort`	timechart line
3	실패 로그인 추이	`auth`	timechart column
4	pfSense Block 통계 (률)	`pfsense`	pie chart

	별)		
5	Snort severity 분포	`snort`	column chart

8.3.3 패널별 SPL

(1) Top 10 공격 IP

```
`soc_attack_waf` (attack_category=SQLi OR attack_category=XSS)
| stats count by src_ip, attack_category
| sort - count
| head 10
```

(2) 차단·탐지 추이 (1시간 단위)

```
`soc_base`
| eval source_kind=case(
    index=="waf",      "WAF",
    index=="pfsense",  "pfSense",
    index=="snort",    "Snort")
| timechart span=1h count by source_kind
```

(3) 실패 로그인 추이

```
index=auth result=FAIL
| timechart span=15m count by user useother=f limit=5
```

(4) pfSense Block 통계

```
`soc_block_pf`
| stats count by rule
| sort - count
| head 10
```

(5) Snort severity 분포

```
index=snort sourcetype=snort_alert
| rex "\[Priority:\s(?<priority>\d+)\]"
| eval severity=case(priority=="1","High",priority=="2","Medium",priority=="3","Low")
| stats count by severity
```

8.3.4 Simple XML 골격

Dashboard Studio 이전 버전과의 호환을 위해 Simple XML로 작성한다.

```
<form theme="dark">
  <label>SOC Integrated Dashboard</label>
  <fieldset submitButton="false" autoRun="true">
    <input type="time" token="tr"><default>
      <earliest>-24h</earliest><latest>now</latest>
    </default></input>
  </fieldset>

  <row>
    <panel>
      <title>Top 10 공격 IP (SQLi + XSS)</title>
      <chart>
        <search>
          <query>`soc_attack_waf` (attack_category=SQLi OR attack_category=XSS)
            | stats count by src_ip, attack_category
            | sort - count | head 10</query>
          <earliest>${tr.earliest}</earliest>
          <latest>${tr.latest}</latest>
        </search>
        <option name="charting.chart">bar</option>
      </chart>
    </panel>
    <panel>
      <title>차단/탐지 추이</title>
      <chart>
        <search>
          <query>`soc_base`
            | eval
source_kind=case(index=="waf","WAF",index=="pfsense","pfSense",index=="snort","Snort")
            | timechart span=1h count by source_kind</query>
          <earliest>${tr.earliest}</earliest>
          <latest>${tr.latest}</latest>
        </search>
        <option name="charting.chart">line</option>
      </chart>
    </panel>
  </row>

  <row>
    <panel><title>실패 로그인 추이</title>
    <chart><search><query>index=auth result=FAIL
```

```

    | timechart span=15m count by user useother=f limit=5</query>
    <earliest>$tr.earliest$</earliest><latest>$tr.latest$</latest>
  </search>
  <option name="charting.chart">column</option></chart>
</panel>
<panel><title>pfSense Block Top Rules</title>
  <chart><search><query>`soc_block_pf`
    | stats count by rule | sort - count | head 10</query>
    <earliest>$tr.earliest$</earliest><latest>$tr.latest$</latest>
  </search>
  <option name="charting.chart">pie</option></chart>
</panel>
<panel><title>Snort Severity</title>
  <chart><search><query>index=snort sourcetype=snort_alert
    | rex "[Priority:\s(?<priority>\d+)\]"
    | eval
severity=case(priority=="1","High",priority=="2","Medium",priority=="3","Low")
    | stats count by severity</query>
    <earliest>$tr.earliest$</earliest><latest>$tr.latest$</latest>
  </search>
  <option name="charting.chart">column</option></chart>
</panel>
</row>
</form>

```

8.3.5 탭 구조

Device 배너 탭과 Attack-type 서브탭은 다음과 같이 구성한다.

Device 탭	주요 내용	사용 인덱스
WAF	ModSecurity 차단 · 공격 분류 Top	`waf`
pfSense	차단 룰 · 포트스캔 추이	`pfsense`
IDS	Snort/Suricata severity · sid 분포	`snort`, `suricata`
WAS	5xx 오류 · 예매 요청 RPS	`web_log`, `was_app`
DB	Oracle 감사 이벤트 · 실패 로그인	`oracle_audit`

Attack-type 서브탭	핵심 SPL 키	인덱스
SQLi	`attack_category=SQLi`	`waf`
XSS	`attack_category=XSS`	`waf`
BruteForce	`result=FAIL` + dc(user)	`auth`
Scan	dc(dest_port) ≥ 10	`pfsense`

대시보드 권한은 Permissions → App: search → Read: soc_team으로 설정하여 SOC 사용자에게만 노출한다.

9. 보안 관제 시나리오 및 탐지 룰

티켓팅 플랫폼 특성을 반영한 위협 시나리오와 탐지 룰(SPL)을 정의한다.

9.1 주요 위협 시나리오

- 매크로/봇을 이용한 비정상 예매(스캘핑)
- 계정 탈취·크리덴셜 스테핑·무차별 대입
- 웹 취약점 공격 및 비정상 트래픽

9.2 탐지 룰 (SPL) 정의

9.1에서 정의한 위협 시나리오를 기반으로, Splunk SPL로 구현된 탐지 룰을 시나리오별로 정의한다. 모든 룰은 Search & Reporting 앱의 Saved Searches로 저장하여 9.3의 Alert 트리거에 사용한다.

9.2.1 매크로 봇 예매 (Booking Flood)

동일 IP에서 1분 내 50건 이상 예매 POST가 발생하는 패턴을 탐지한다.

```
index=web_log sourcetype=was_access uri_path="/booking*" status=200
| bin _time span=1m
| stats count by src_ip, _time
| where count > 50
| sort - count
```

항목	값
임계치 근거	정상 사용자의 좌석 선택 → 결제 흐름은 분당 최대 5~10건. 50건은 정상 분포의 5σ 이상으로 봇 활동으로 판정
대응 등급	High
후속 조치	WAF 차단 IP 등록 + pfSense 임시 block

9.2.2 크리덴셜 스테핑 (Credential Stuffing)

한 IP가 다수의 계정을 시도하거나, 동일 IP에서 단시간 다회 실패가 누적되는 패턴을 탐지한다.

```
index=auth result=FAIL
| bin _time span=5m
| stats dc(user) AS users, count AS attempts by src_ip, _time
| where users >= 5 OR attempts >= 20
| sort - attempts
```

항목	값
임계치 근거	정상 오타 사용자는 5분 내 동일 계정 3회 이내. `users >= 5`는 명백한 계정 사전 공격, `attempts >= 20`은 동일 계정 무차별 대입
대응 등급	Critical
후속 조치	해당 계정 잠금 + src_ip pfSense 차단

동일 패턴을 WAS 애플리케이션 로그(was_app)에서 탐지할 수도 있다.

```
index=was_app "Authentication failed"
| rex "user=(?<user>\S+).*ip=(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| bin _time span=5m
| stats dc(user) AS users, count AS attempts by src_ip, _time
| where users >= 5 OR attempts >= 20
```

9.2.3 SQLi 시도 다발 (WAF)

ModSecurity 감사 로그에서 동일 IP가 단시간에 다수의 SQL Injection 룰에 매칭되는 경우를 탐지한다.

```
index=waf sourcetype=waf_audit attack_category=SQLi
| bin _time span=10m
| stats count, values(rule_id) AS rules, values(uri) AS uris by src_ip, _time
| where count >= 10
| sort - count
```

항목	값
임계치 근거	CRS Paranoia Level 1 기준 정상 트래픽의 SQLi

	false positive는 시간당 1~2건 이하. 10분 내 10건은 명확한 자동화 시도
대응 등급	High
후속 조치	nginx ModSecurity `SecRuleEngine On` 유지, src_ip 차단

XSS 탐지도 동일한 구조로 적용한다.

```
index=waf sourcetype=waf_audit attack_category=XSS
| stats count by src_ip
| where count >= 10
```

9.2.4 pfSense 포트스캔

동일 출발지 IP가 10분 내에 10개 이상의 서로 다른 목적지 포트를 차단당한 경우를 포트스캔으로 분류한다.

```
index=pfsense sourcetype="pfsense:filterlog" action=block
| bin _time span=10m
| stats dc(dest_port) AS ports, dc(dest_ip) AS targets, count by src_ip, _time
| where ports >= 10
| sort - ports
```

항목	값
임계치 근거	nmap 기본 스캔은 1000+ 포트를 수초 내 시도. 10분 10포트는 저속 스캔(`-T1`)까지 포함하는 안전한 하한
대응 등급	Medium
후속 조치	pfSense Alias `block_scanners`에 src_ip 추가

9.2.5 Snort 고심각도 룰 매칭

Priority: 1 알람이 단시간 누적되는 경우 즉시 통보한다.

```
index=snort sourcetype=snort_alert
| rex "\[Priority:\s(<priority>\d+)\]"
| where priority="1"
| stats count by src_ip, alert_msg
| where count >= 3
```

항목	값
임계치 근거	Priority 1은 Snort 기본 분류상 `attempted-admin`, `trojan-activity` 등 즉시 대응 대상
대응 등급	Critical
후속 조치	관제팀 즉시 호출 + 격리 검토

9.2.6 룰 요약

룰 ID	시나리오	인덱스	임계치	등급
R-01	매크로 봇 예매	`web_log`	분당 50건/IP	High
R-02	크리덴셜 스테핑	`auth`, `was_app`	5분 5계정 또는 20시도	Critical
R-03	SQLi 다발	`waf`	10분 10건/IP	High
R-04	XSS 다발	`waf`	10분 10건/IP	Medium
R-05	포트스캔	`pfsense`	10분 10포트/IP	Medium
R-06	Snort Priority1	`snort`	3건/IP	Critical

9.3 알림(Alert) 설정

9.2에서 정의한 SPL 룰을 Splunk Alert로 등록하여, 트리거 시 관제팀(SOC-mint)에 이메일·Slack으로 즉시 통보하고 동시에 요약 인덱스에 보존한다.

9.3.1 Alert 생성 절차

각 Saved Search 화면에서 Save As → Alert를 선택하여 다음과 같이 구성한다.

항목	값
Title	룰 ID + 시나리오명 (예: `R-02_CredentialStuffing`)
App	`search`

Permissions	Shared in App
Alert type	Scheduled
Time Range	룰에 정의된 윈도우(예: 5분/10분)
Cron Schedule	`*/5 * * * *` (5분 주기 권장)
Trigger condition	Number of Results / Per-Result
Trigger	조건 충족 시 1회
Throttling	동일 `src_ip` 기준 5분 1회로 제한

9.3.2 Trigger Condition 매핑

룰 ID	Trigger	조건
R-01 매크로 봇	Per-Result	결과 1건 이상 발생 시 즉시
R-02 크리덴셜 스테핑	Number of Results > 0	윈도우 내 1건 이상
R-03 SQLi 다발	Per-Result	결과 즉시 트리거
R-04 XSS 다발	Number of Results > 0	동일
R-05 포트스캔	Number of Results > 0	동일
R-06 Snort P1	Per-Result	결과 즉시

9.3.3 Throttling

동일 공격 출발지로부터의 중복 알림을 방지하기 위해 throttling을 적용한다.

항목	값
Suppress results containing field value	`src_ip`
Suppress for	`300 seconds` (5분)

9.3.4 Alert Actions

(1) Email

Settings → Server settings → Email settings에서 SMTP를 먼저 등록한다.

항목	값
----	---

Mail Host	사내 SMTP 게이트웨이
Send as	`splunk@soc.local`
Recipients	`soc@soc.local`
Subject	`[SOC][\$name\$] \$result.src_ip\$ 탐지`
Include	Trigger time, Results in CSV, Link to Alert

(2) Slack Webhook

Apps → Find more apps → Slack Notification Alert을 설치한 후 다음과 같이 설정한다.

항목	값
Channel	`#soc-alert`
Webhook URL	Slack Incoming Webhook URL
Message	`:rotating_light: *[\$name\$]* src_ip=\$result.src_ip\$ count=\$result.count\$`
Attachment	Splunk search URL

(3) Summary Index 적재

장기 추세 분석을 위해 트리거된 알람을 summary_soc 인덱스에 누적 저장한다.

```
... (탐지 SPL) ...
| collect index=summary_soc sourcetype=soc_alert marker="rule=R-02,severity=Critical"
```

또는 GUI에서 Add Actions → Summary Indexing → Index: summary_soc 를 선택한다.

9.3.5 심각도 등급표

등급	의미	통보 채널	SLA
Info	참고성 이벤트, 자동 대응 불필요	Summary Index	N/A
Low	잠재 위험, 추세 관찰	Summary Index +	24시간 내 확인

	대상	Slack	
Medium	차단·조사 필요	Email + Slack	4시간 내 대응
High	실제 공격 진행, 즉시 차단	Email + Slack + Summary	1시간 내 대응
Critical	침해 가능성 확인, 격리 검토	Email + Slack + 전화 호출	즉시 대응

9.3.6 룰 ↔ 액션 매핑 요약

룰 ID	등급	Email	Slack	Summary
R-01 매크로 봇	High	O	O	O
R-02 크리덴셜 스테핑	Critical	O	O	O
R-03 SQLi 다발	High	O	O	O
R-04 XSS 다발	Medium	O	O	O
R-05 포트스캔	Medium	-	O	O
R-06 Snort P1	Critical	O	O	O

9.3.7 동작 검증

Kali(10.44.44.44)에서 다음 명령으로 룰을 발화시켜 알림 흐름을 점검한다.

```
# R-03 SQLi 다발 트리거
for i in $(seq 1 15); do
  curl -sk "https://10.0.10.2/search?q=' OR 1=1--" >/dev/null
done

# R-05 포트스캔 트리거
nmap -sS -p 1-1000 10.0.10.2
```

Splunk Web의 Activity → Triggered Alerts에 해당 Alert가 노출되고, Slack 채널 및 summary_soc 인덱스에 동일 이벤트가 적재되면 정상 동작으로 판정한다.

10. AI 기반 이상 탐지 / 분석

규칙 기반 탐지의 한계를 보완하기 위한 AI 분석 적용 방안을 기술한다.

10.1 AI 적용 영역

룰 기반 탐지(Snort, ModSecurity, SPL Correlation Search)는 시그니처에 부합하는 공격을 신속하게 차단할 수 있으나, 시그니처가 없는 신종 위협, 정상 트래픽을 흉내내는 저속 공격, 다단계 우회 행위에 대해서는 탐지 누락이 발생한다. 본 인프라에서는 룰 기반 탐지의 한계를 보완하기 위해 Splunk에 적재된 로그를 기반으로 비지도/지도 학습 모델을 병행 운용한다.

10.1.1 적용 포인트

적용 영역	입력 데이터	모델	출력
비정상 로그인 패턴 분류	WAS 인증 로그 (`/login` 응답, 사용자 ID, 시간, 출발지 IP), Oracle 감사 로그	Isolation Forest (비지도)	이상치 점수(0~1), 임계치 초과 시 alert
봇/사람 구분	Nginx access log의 User-Agent, 요청 간격 (Δt), URL sequence, click pattern	Random Forest (지도)	bot/human 라벨 + 확률
DDoS/스캔 시계열 이상	pfSense filter log, Nginx access log를 1 분 단위 시계열로 집계 (RPS, unique src, error 비율)	LSTM Autoencoder	재구성 오차 기반 이상 점수

10.1.2 실행 환경

경량 모델(Isolation Forest, Random Forest)은 Splunk Machine Learning Toolkit(MLTK)으로 직접 학습·추론하여 Splunk 내부에서 폐쇄적으로 운영한다. LSTM Autoencoder처럼 딥러닝 프레임워크가 필요한 모델은 splunk VM(10.0.200.201) 내 별도 Python 가상환경(/opt/ai/venv)에 PyTorch를 설치하여 외부 Python 프로세스로 학습·추론을 수행한다.

구분	위치	패키지
Splunk MLTK	splunk VM `/opt/splunk/etc/apps/Splunk_ ML_Toolkit`	MLTK 5.x, PSC 4.x

외부 Python	splunk VM `/opt/ai/venv`	python3.9, scikit-learn, pandas, torch, joblib, fastapi
-----------	--------------------------	---

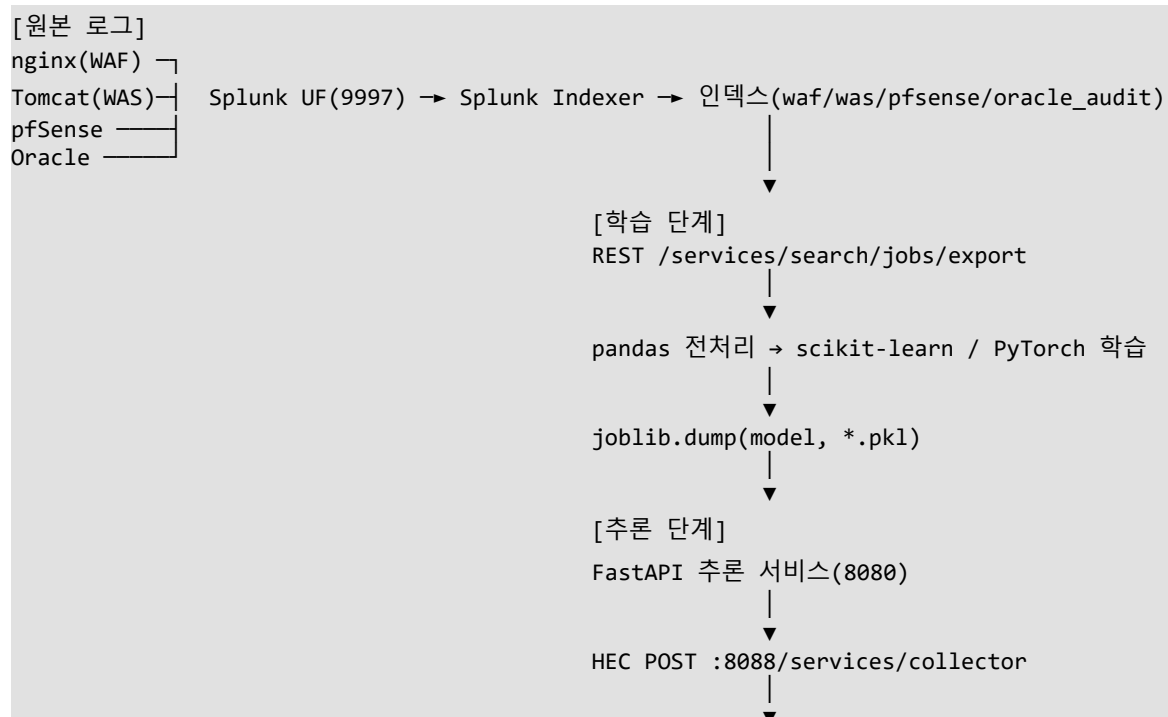
10.1.3 운영 원칙

- 룰 기반 탐지는 차단(Block) 권한을 가지며, AI 모델은 1차적으로 점수만 산출하여 SOC 분석가의 판단을 보조한다.
- 동일 이벤트가 룰과 AI 모델에서 동시에 high-confidence로 판정될 경우 SOAR 흐름에 따라 자동 차단 후보가 된다.
- 모델은 주 1회 재학습하여 트래픽 패턴 변화에 적응한다.

10.2 데이터 파이프라인

AI 모델은 정상 운영 트래픽을 학습 데이터로 사용하기 때문에, Splunk에 축적된 인덱스(waf, was, pfsense, oracle_audit)에서 학습용 데이터를 추출하고, 추론 결과는 다시 Splunk로 회수하는 양방향 파이프라인을 구축한다.

10.2.1 전체 흐름



Splunk 인덱스 ai_results



대시보드 / Correlation Search / Alert

10.2.2 학습 데이터 추출

Splunk REST API의 search/jobs/export 엔드포인트를 사용하여 SPL 결과를 CSV/JSON으로 스트리밍 수신한다. 외부 Python(10.0.200.201)에서 splunk 로컬 8089 포트로 호출한다.

```
curl -k -u admin:'rhkswp1234' \
  https://10.0.200.201:8089/services/search/jobs/export \
  -d search='search index=waf earliest=-30d@d latest=@d
    | table _time clientip uri http_user_agent status' \
  -d output_mode=csv \
  -o /opt/ai/data/waf_30d.csv
```

비지도 학습용 데이터셋은 30일 분량, 지도 학습용 라벨링 데이터셋은 SOC 분석가가 별도 검증한 라벨 파일(/opt/ai/data/labels.csv)을 join하여 구성한다.

10.2.3 전처리 및 학습

전처리는 pandas로 수행한다. 결측치 처리, 시계열 리샘플링(1분), 범주형 인코딩(OneHot), 정규화(StandardScaler)를 적용한 후 모델별로 학습 스크립트를 분리한다.

모델	학습 스크립트	산출물
Isolation Forest	`/opt/ai/train_login_if.py`	`/opt/ai/models/login_if.pkl`
Random Forest	`/opt/ai/train_bot_rf.py`	`/opt/ai/models/bot_rf.pkl`
LSTM Autoencoder	`/opt/ai/train_ddos_lstm.py`	`/opt/ai/models/ddos_lstm.pt`

```
source /opt/ai/venv/bin/activate
python /opt/ai/train_login_if.py \
  --input /opt/ai/data/login_30d.csv \
  --output /opt/ai/models/login_if.pkl
```

10.2.4 추론 결과 회수

추론 결과는 Splunk HTTP Event Collector(HEC)를 통해 ai_results 인덱스로 전송한다. HEC 토큰은 Splunk Web → Settings → Data inputs → HTTP Event Collector에서 생성한다.

```
curl -k https://10.0.200.201:8088/services/collector \
-H "Authorization: Splunk <HEC_TOKEN>" \
-d '{"index":"ai_results","sourcetype":"ai:login",
    "event":{"model":"login_if","src_ip":"203.0.113.10",
            "user":"admin","score":0.92,"label":"anomaly"}}'
```

ai_results 인덱스는 원본 로그 인덱스와 분리하여 보존 기간을 90일로 설정하고, 분석가가 모델별·시간대별로 결과를 추적할 수 있도록 한다.

10.3 모델 연동 및 결과 활용

학습이 완료된 모델은 FastAPI 기반 추론 서비스로 래핑하여 Splunk와 연동한다. Splunk에서 발생한 이벤트가 추론 서비스를 호출하면 score와 anomaly_label을 응답받고, 그 결과를 다시 HEC로 ai_results 인덱스에 적재한다.

10.3.1 FastAPI 추론 서비스

splunk VM(10.0.200.201)에서 uvicorn으로 8080 포트에 추론 서비스를 기동한다. systemd 유닛으로 등록하여 부팅 시 자동 시작한다.

```
sudo tee /etc/systemd/system/ai-infer.service <<'EOF'
[Unit]
Description=AI Inference Service
After=network.target

[Service]
User=ai
WorkingDirectory=/opt/ai
ExecStart=/opt/ai/venv/bin/uvicorn app.main:app \
  --host 0.0.0.0 --port 8080 --workers 2
Restart=always

[Install]
WantedBy=multi-user.target
EOF
```

```
sudo systemctl daemon-reload
sudo systemctl enable --now ai-infer
```

서비스는 모델별로 엔드포인트를 분리한다.

엔드포인트	메서드	입력	응답
/predict/login`	POST	{user, src_ip, hour, fail_cnt}`	{score, label}`
/predict/bot`	POST	{ua, interval, click_seq}`	{score, label}`
/predict/ddos`	POST	{ts_window:[{rps,uniq_src,err_ratio}, ...]}`	{recon_err, label}`

10.3.2 Splunk 연동

Splunk와 FastAPI를 연동하는 방법은 두 가지를 병행한다.

연동 방식	용도	호출 시점
Custom Search Command (`aipredict`)	대량 배치 추론	SPL 검색 시
Alert Action Webhook	실시간 단건 추론	Correlation Search 트리거 시

Custom Search Command는 /opt/splunk/etc/apps/ai_app/bin/aipredict.py에 streaming command로 작성하여 SPL에서 다음과 같이 사용한다.

```
index=waf earliest=-15m
| table _time clientip http_user_agent uri
| aipredict model=bot
| where score > 0.8
```

Alert Action Webhook은 Splunk Web → Settings → Alert actions → Webhook에

http://10.0.200.201:8080/predict/login을 등록하여, 실패 로그인 임계치 초과 alert가 발생할 때 즉시 추론을 수행한다.

10.3.3 결과 적재 및 활용

추론 결과는 모두 ai_results 인덱스에 저장되며, SOC 대시보드에서 다음 패널로 시각화한다.

패널	SPL
시간대별 이상 점수	<code>`index=ai_results model=ddos_lstm`</code>
모델별 anomaly 건수	<code>`index=ai_results label=anomaly`</code>
Top 이상 출발지	<code>`index=ai_results label=anomaly`</code>
봇 의심 UA Top	<code>`index=ai_results model=bot_rf label=bot`</code>

ai_results 인덱스의 high-score 이벤트는 별도 Correlation Search로 모니터링하여, score $\geq$ 0.9 이벤트가 5분 내 3건 이상 발생할 경우 SOC팀에 메일·Splunk 알림으로 통보한다.

11. 대응 및 운영 프로세스

탐지 이후의 대응 절차와 지속 운영 방안을 정리한다.

11.1 인시던트 대응 절차

탐지된 보안 이벤트는 정의된 단계와 R&R에 따라 대응한다. 본 인프라는 SOC팀(SOC-mint, 10.0.100.2), 개발팀(DEV-mint, 10.0.150.2), 시스템 운영팀(splunk/pfSense 콘솔)이 분리되어 있으므로 단계별 책임자를 명확히 한다.

11.1.1 대응 단계

단계	활동	도구	책임
1. 탐지	Splunk Correlation Search / Snort alert / WAF audit 로그 임계치 초과	Splunk Alert, Sguil	SIEM 자동
2. 1차 분석	SOC-mint에서 Splunk 검색 + Security Onion(Sguil/Kibana) 동시 확인, 공격자 IP·요청 패턴·페이로드 식	Splunk Web, Sguil	SOC 분석가

	별		
3. 격리	pfSense Aliases에 `BLOCK_AI` 추가 → Firewall Rule로 WAN 차단, 또는 Snort Block Offenders 기능 활성화	pfSense WebGUI	SOC 분석가 + 시스템 운영
4. 근본 원인 분석	Tomcat `/home/was/tomcat/lo gs/`, Oracle 감사 로그, WAF audit 로그를 시 간순으로 상관 분석. SQLi/XSS/RCE 시도 여 부 확인	Splunk, sqlplus, less	SOC + 개발팀
5. 패치·룰 업데이트	애플리케이션 코드 패 치(개발팀), CRS rule 추가(시스템 운영), Snort 룰 추가, SPL 임 계치 조정	git, nginx, snort, Splunk	개발팀 + 시스템 운영
6. 사후 보고	인시던트 보고서(IR Report) 작성, 재발 방 지 대책 수립, 분기 보 고 회의 보고	문서 템플릿	SOC 리드

11.1.2 R&R 매트릭스

활동	SOC 분석	시스템 운영	개발팀
알람 1차 트리아지	R	C	I
공격 IP 차단 (pfSense/Snort)	R	A	I
WAS 코드 취약점 패치	C	I	R
WAF/Snort 룰 신규 작 성	A	R	C
Oracle 계정·권한 점검	C	R	I
인시던트 보고서 작성	R	C	C

(R=Responsible, A=Accountable, C=Consulted, I=Informed)

11.1.3 격리 조치 예시

pfSense에서 공격자 IP를 즉시 차단하는 절차는 다음과 같다.

```
Firewall ▶ Aliases ▶ IP ▶ Add
Name      : BLOCK_AI
Type      : Host(s)
Network   : 203.0.113.10

Firewall ▶ Rules ▶ WAN ▶ Add (맨 위)
Action     : Block
Interface  : WAN
Source     : Single host or alias → BLOCK_AI
Destination : any
Description : IR-2026-xxxx auto block
```

Snort의 Block Offenders는 Services ▶ Snort ▶ Interfaces ▶ WAN ▶ Edit ▶ Block Offenders 체크 후 적용한다.

11.1.4 통보 체계

심각도	통보 대상	채널	통보 SLA
Critical (서비스 중단/데이터 유출 의심)	SOC 리드, 시스템 운영팀장, 개발팀장	Splunk Alert + 메일 + 유선	15분
High (지속 공격, 차단 후 재시도)	SOC 리드, 시스템 운영팀장	Splunk Alert + 메일	1시간
Medium (룰 기반 단발 탐지)	SOC 당직자	Splunk Alert	4시간
Low (스캔 시도, 차단 성공)	SOC 일일 리포트	일일 보고	24시간

11.2 운영 및 유지보수

탐지·차단·로깅 인프라는 시간이 경과함에 따라 트래픽 패턴이 변화하고, false positive가 누적되며, 룰셋·시그니처가 노후화된다. 본 인프라는 주간/월간/분기 주기로 정기 점검을 수행하여 탐지 정확도와 가용성을 유지한다.

11.2.1 주간 점검 (매주 월요일)

항목	작업	명령/위치
Snort false positive 정리	1주간 alert 중 정상 트래픽 분류, `disablesid.conf`에 등록	pfSense ▶ Services ▶ Snort ▶ SID Mgmt
WAF false positive 정리	ModSecurity audit log 검토, 정상 요청 차단된 룰 `SecRuleRemoveById`	`/etc/nginx/modsec/exclusions.conf`
SPL 임계치 조정	Correlation Search의 trigger threshold 재산정	Splunk Web ▶ Alerts
디스크 사용량 점검	Splunk indexer, Oracle archive log, nginx log	`df -h`, `du -sh` /opt/splunk/var/lib/splunk/*`

11.2.2 월간 점검 (매월 첫째주)

월간 점검의 핵심은 백업이다. 모든 핵심 시스템의 설정과 데이터를 외부 저장소(NAS 또는 oracle-db /backup)로 보관한다.

대상	백업 도구	명령
Oracle DB	RMAN 자동 백업	`rman target / cmdfile=/home/oracle/scripts/ backup.rcv`
Splunk 설정	btool 전체 덤프 + `\$SPLUNK_HOME/etc` tar	`splunk btool check; tar czf splunk_etc_\$(date +%F).tgz /opt/splunk/etc`
pfSense	Diagnostics ▶ Backup & Restore → XML 다운로드	WebGUI
WAF(nginx/ModSecurity)		`tar czf waf_\$(date +%F).tgz /etc/nginx /etc/modsec`
WAS 설정	`/home/was/tomcat/conf`, 애플리케이션 war	`tar czf was_\$(date +%F).tgz /home/was/tomcat/conf`
Security Onion 룰	`/etc/nsm/rules`	`tar czf so_rules_\$(date +%F).tgz /etc/nsm/rules`

RMAN 백업 스크립트 예시는 다음과 같다.

```
# /home/oracle/scripts/backup.rcv
RUN {
  ALLOCATE CHANNEL c1 DEVICE TYPE DISK FORMAT '/backup/rman/%U';
  BACKUP DATABASE PLUS ARCHIVELOG;
  DELETE NOPROMPT OBSOLETE;
  RELEASE CHANNEL c1;
}
```

월간 백업본은 7개월 보존(롤링 7세대)을 원칙으로 한다.

11.2.3 분기 침투 테스트 (매 분기)

kali_attacker(10.44.44.44)에서 정의된 시나리오로 침투 테스트를 수행하여 탐지/차단 체계의 유효성을 검증한다.

시나리오	도구	대상	기대 결과
포트 스캔	`nmap -sS -T4 10.0.10.0/24`	DMZ	Snort 포트스캔 alert + pfSense block
SQL Injection	`sqlmap -u "http://<WAF>/login" --data "user=a&pass=b"`	WAF→WAS	ModSecurity CRS 942xxx 차단, Splunk alert
무차별 로그인	`hydra -l admin -P rockyou.txt http-post-form ...`	WAF→WAS `/login`	login_if 모델 anomaly + WAF rate-limit
디렉터리 스캐닝	`gobuster dir -u http://<WAF>/ -w common.txt`	WAF	CRS 913xxx scanner 차단
취약 파일 업로드	`curl -F file=@shell.jsp ...`	WAS	CRS 933xxx + WAS 업로드 정책 차단

각 시나리오 종료 후 Splunk에서 탐지율을 계산하고, 미탐 항목은 룰 추가 또는 모델 재학습 대상으로 등록한다.

11.2.4 정기 점검 체크리스트

분류	항목	주기
네트워크	VyOS 라우팅 테이블, pfSense 인터페이스 상태	주
방화벽	pfSense rule hit 통계, 미사용 룰 정리	월
IDS	Snort 룰 업데이트('pfctl', Snort updates), Sguil 쿼리 적체	주
WAF	CRS 버전 확인, exclusion 규칙 검토	월
SIEM	인덱스 라이선스 사용량, 라이선스 위반 여부	주
계정	Linux/oracle 계정 사용 이력, 미사용 계정 잠금	월
백업	백업본 복원 테스트(샘플)	분기
AI 모델	재학습 결과 정확도/재현율 검토	주

12. 부록

12.1 용어 정리

본 문서에서 사용한 약어와 용어는 다음과 같다.

12.1.1 인프라/네트워크 용어

약어	영문	의미
DMZ	Demilitarized Zone	외부와 내부망 사이의 완충 구역. 본 인프라에서는 dmz-net(10.0.10.0/24)에 WAF와 WAS를 배치
VLAN	Virtual LAN	가상 LAN. ESXi 포트그룹으로 논리적 망 분리 구현
NAT	Network Address Translation	사설 IP를 공인 IP로 변환. pfSense Outbound NAT/Port Forward에서 사용
WAN	Wide Area Network	외부망 인터페이스

LAN	Local Area Network	내부망 인터페이스
OPT	Optional Interface	pfSense에서 WAN/LAN 외 추가 인터페이스 (OPT1: dev, OPT2: dmz, OPT3: intra)

12.1.2 보안 구성 요소

약어	영문	의미
WAF	Web Application Firewall	웹 애플리케이션 방화벽. 본 인프라는 nginx + ModSecurity + OWASP CRS
WAS	Web Application Server	웹 애플리케이션 서버. 본 인프라는 Tomcat 9 + Spring MVC
DB	Database	데이터베이스. Oracle XE 21c
IDS	Intrusion Detection System	침입 탐지 시스템. Security Onion(Snort/Suricata)
IPS	Intrusion Prevention System	침입 방지 시스템. pfSense Snort Block Offenders로 구현
SIEM	Security Information and Event Management	보안 정보·이벤트 통합 관리. Splunk Enterprise
SOC	Security Operations Center	보안 관제 센터. 본 인프라는 SOC-mint VM
SOAR	Security Orchestration, Automation and Response	보안 자동화·대응 플랫폼. 본 인프라는 Splunk Alert + Webhook으로 경량 구현
HEC	HTTP Event Collector	Splunk HTTP 이벤트 수집기 (8088/tcp)
UF	Universal Forwarder	Splunk 로그 수집 에이전트

12.1.3 탐지·룰셋

약어	영문	의미
SPL	Search Processing Language	Splunk 검색 질의 언어
CRS	Core Rule Set	OWASP가 배포하는 ModSecurity 기본 룰셋
SID	Snort Signature ID	Snort 룰 식별자
MITRE ATT&CK	Adversarial Tactics, Techniques,	MITRE의 공격 전술·기법 프레

	and Common Knowledge	임워크
--	----------------------	-----

12.1.4 웹 공격 유형

약어	영문	의미
SQLi	SQL Injection	SQL 구문을 주입하여 DB를 조작·탈취하는 공격
XSS	Cross-Site Scripting	웹 페이지에 악성 스크립트를 주입하는 공격
CSRF	Cross-Site Request Forgery	사용자가 의도하지 않은 요청을 위조하여 실행시키는 공격
RCE	Remote Code Execution	원격에서 임의 코드를 실행하는 공격
LFI/RFI	Local/Remote File Inclusion	로컬/원격 파일 포함 취약점
SSRF	Server-Side Request Forgery	서버가 내부 자원에 요청을 보내도록 유도하는 공격
DDoS	Distributed Denial of Service	분산 서비스 거부 공격

12.1.5 AI/데이터

약어	영문	의미
MLTK	Machine Learning Toolkit	Splunk의 머신러닝 앱
IF	Isolation Forest	비지도 이상 탐지 알고리즘
RF	Random Forest	앙상블 결정트리 분류 모델
LSTM	Long Short-Term Memory	시계열 처리에 적합한 RNN 계열 모델
AE	Autoencoder	입력 재구성 기반 이상 탐지 모델

12.2 참고 자료

본 문서를 작성하는 과정에서 참조한 공식 문서 및 커뮤니티 자료는 다음과 같다.

12.2.1 네트워크·방화벽

구분	자료명	URL
VyOS	VyOS 1.3 Documentation	https://docs.vyos.io/en/equuleus/
pfSense	Netgate pfSense Docs	https://docs.netgate.com/pfsense/en/latest/
pfSense	Netgate Hangouts (튜토리얼)	https://www.netgate.com/resources

12.2.2 WAF / 웹 보안

구분	자료명	URL
ModSecurity	SpiderLabs/ModSecurity GitHub	https://github.com/SpiderLabs/ModSecurity
ModSecurity-nginx	ModSecurity nginx connector	https://github.com/SpiderLabs/ModSecurity-nginx
OWASP CRS	Core Rule Set 공식 사이트	https://coreruleset.org/
OWASP	OWASP Top 10 (2021)	https://owasp.org/Top10/
nginx	nginx 공식 문서	https://nginx.org/en/docs/

12.2.3 IDS / 위협 헌팅

구분	자료명	URL
Snort	Snort 공식 사이트	https://www.snort.org/
Snort	Snort Users Manual	https://docs.snort.org/
Security Onion	Security Onion 공식 사이트	https://securityonionsolutions.com/
MITRE ATT&CK	Enterprise Matrix	https://attack.mitre.org/matrices/enterprise/

12.2.4 SIEM / 로그 분석

구분	자료명	URL
Splunk	Splunk Enterprise Docs	https://docs.splunk.com/Documentation/Splunk
Splunk	Splunk Forwarder Docs	https://docs.splunk.com/Documentation/Forwarder

Splunk	SPL Search Reference	https://docs.splunk.com/Documentation/Splunk/latest/SearchReference
Splunk	Machine Learning Toolkit	https://docs.splunk.com/Documentation/MachineLearningToolkit

12.2.5 데이터베이스 / WAS

구분	자료명	URL
Oracle XE	Oracle Database Express Edition	https://www.oracle.com/database/technologies/appdev/xe.html
Oracle	Database Security Guide	https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/
Apache Tomcat	Tomcat 9 Documentation	https://tomcat.apache.org/tomcat-9.0-doc/
Spring	Spring Framework Reference	https://docs.spring.io/spring-framework/reference/
MyBatis	MyBatis 3 User Guide	https://mybatis.org/mybatis-3/

12.2.6 가이드라인 / 표준

구분	자료명	비고
KISA	주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드	한국인터넷진흥원
NIST	SP 800-61 Rev.2 Computer Security Incident Handling Guide	인시던트 대응 절차 참조
NIST	SP 800-92 Guide to Computer Security Log Management	로그 관리 정책 참조
CIS	CIS Benchmarks (Ubuntu 20.04, Oracle Linux 8)	호스트 하드닝 참조

12.3 변경 이력